PRAXISHANDBUCH

Active Directory Security

Angriffe verstehen, Schwachstellen erkennen und Windows-Domänen wirksam absichern

```
PS> Get-ADDomain | Select-Object DNSRoot
nova.int
PS> Get-ADGroupMember "Domain Admins"
PS> nltest /dclist:nova.int
```

EIN VERZEICHNIS ENTSCHEIDET. WER ES KENNT, KANN ES SCHÜTZEN.

Mit Übungen, Diagrammen, Spickzettel, Glossar und Index · Autor: Eugen Becker

Inhaltsverzeichnis

Vorwort 1

Warum Active Directory ein zentrales Angriffsziel ist 1

Bedeutung von Identitäten und Berechtigungen 1

Active Directory in Unternehmen 1

Verbindung zwischen Windows Security, Ethical Hacking und Blue Team 2

Für wen ist dieses Handbuch? 2

Aufbau des Buches 2

Hinweis zu Angriffsdarstellungen 3

Voraussetzungen für die Praxisübungen 3

Kapitel 1: Einführung – Was ist Active Directory Security? 4

Was ist Active Directory? 4

Geschichte und Entwicklung 4

Active Directory Domain Services (AD DS) 5

Zentrale Identitätsverwaltung 5

Benutzer, Computer und Gruppen 5

Domänen und Gesamtstrukturen 5

LDAP 6

Kerberos 6

NTLM 6

Gruppenrichtlinien 6

Active Directory als Sicherheitsgrenze 7

Warum Active Directory ein attraktives Angriffsziel ist 7

Typische Sicherheitsprobleme 7

Kontrollfragen 8

Lernzielkontrolle 9

Kapitel 2: Active-Directory-Architektur verstehen 10

Die Bausteine im Überblick 10

Domänen und Gesamtstruktur 11

Domänencontroller und Global Catalog 11

Organisationseinheiten 11

Sites, Subnets und Replikation 12

FSMO-Rollen 12
DNS und Active Directory 12
LDAP-Verzeichnisstruktur und Distinguished Names 12
Security Identifier 13
Gruppenmitgliedschaften und Berechtigungsmodell 13
Service Accounts, Managed Service Accounts und gMSA 14
Praxis: Die Testdomäne untersuchen 14
Kontrollfragen 17
Lernzielkontrolle 17

Kapitel 3: Authentifizierung – Kerberos und NTLM im Überblick 19

Was die Authentifizierung leistet 19
Kerberos in einem Satz 19
NTLM in einem Satz 20
Warum beide Verfahren relevant sind 20
Wo die Angriffe ansetzen 20
Kontrollfragen 20
Lernzielkontrolle 21

Kapitel 4: Active-Directory-Angriffe verstehen 22

Warum Methodik vor Werkzeug kommt 22
Angriffsflächen 22
Reconnaissance und Enumeration 23
Benutzeraufklärung und Gruppenanalyse 23
Berechtigungsanalyse und Service Accounts 23
Fehlkonfigurationen 23
Angriffswege innerhalb einer Domäne 24
Privilege Escalation 24
Lateral Movement 24
Persistenz 24
Domain Compromise 24
MITRE ATT&CK und Active Directory 25
Praxis: Angriffsflächen in der Testdomäne lesen 25
Kontrollfragen 26
Lernzielkontrolle 27

Kapitel 5: Kerberoasting 28
Was ist Kerberoasting? 28
Warum Dienstkonten gefährdet sind 29
Zusammenhang zwischen Kerberos und SPNs 29
Service Tickets 29
Voraussetzungen 30
Verschlüsselungstypen 30
Ablauf eines Kerberoasting-Angriffs 30
Erkennung 31
Schutzmaßnahmen 31
Praxis: Dienstkonten in der Testdomäne prüfen 31
Typische Fehler 35
Kontrollfragen 36
Lernzielkontrolle 36

Kapitel 6: AS-REP Roasting 38
Was ist AS-REP Roasting? 38
Zweck der Vorauthentifizierung 39
Warum deaktivierte Vorauthentifizierung problematisch ist 39
AS-REQ und AS-REP 39
Angriffsprinzip 39
Voraussetzungen 40
Auswirkungen 40
Erkennung 40
Schutzmaßnahmen 40
Praxis: Konten mit deaktivierter Vorauthentifizierung finden und korrigieren 41
Typische Fehler 44
Kontrollfragen 44
Lernzielkontrolle 45

Kapitel 7: Pass-the-Hash und Pass-the-Ticket 46
Die Ausgangslage: Anmeldeinformationen im Speicher 46
NTLM-Hash-Grundlagen 47
Pass-the-Hash 47
Kerberos-Tickets 47

Pass-the-Ticket 48
Unterschiede 48
Voraussetzungen 48
Angriffsablauf 48
Mögliche Auswirkungen 49
Erkennung 49
Schutzmechanismen 49
Praxis: Anmeldeereignisse und Schutzfunktionen prüfen 50
Typische Fehler 53
Kontrollfragen 53
Lernzielkontrolle 54

Kapitel 8: Active-Directory-Rechte und Privilege Escalation 55

Berechtigungen in Active Directory 55
Kritische Rechte 56
Vererbte Berechtigungen 56
Fehlkonfigurierte OUs 57
Überprivilegierte Benutzer 57
Gruppenverschachtelung 57
Domain Admins und Enterprise Admins 57
Privilege Escalation über Berechtigungen 58
Erkennung 58
Schutzmaßnahmen 58
Praxis: Berechtigungen untersuchen und korrigieren 59
Typische Fehler 62
Kontrollfragen 63
Lernzielkontrolle 63

Kapitel 9: BloodHound und Angriffspfadanalyse 64

Was ist BloodHound? 64
Warum Graphanalysen wichtig sind 65
Knoten und Beziehungen 65
Benutzer, Gruppen und Computer 65
Sessions 65
Admin Rights 66
Angriffspfade 66

SharpHound und Datensammlung 66
Graphabfragen 66
Analyse kritischer Beziehungen 67
Grenzen der Datensammlung 67
Datenschutz und sichere Verwendung 67
Praxis: Angriffspfade in der Testdomäne analysieren 67
Typische Fehler 69
Kontrollfragen 70
Lernzielkontrolle 71

Kapitel 10: Active-Directory-Persistenz und Domänenkompromittierung 72

Was Persistenz bedeutet 72
Gefährdete Benutzerkonten 73
Manipulierte Gruppenmitgliedschaften 73
Delegationskonfigurationen 73
Ungewöhnliche Berechtigungen 73
Gruppenrichtlinienmissbrauch 73
Replikationsrechte und DCSync 74
Schlüssel der Domäne und das Konto krbtgt 74
Credential Theft 75
Erkennung verdächtiger Änderungen 75
Wiederherstellung einer kompromittierten Domäne 75
Praxis: Persistenzspuren in der Testdomäne prüfen 75
Typische Fehler 77
Kontrollfragen 77
Lernzielkontrolle 78

Kapitel 11: Active-Directory-Delegation und kritische Konfigurationen 79

Was Delegation ist 79
Unbeschränkte Delegation 80
Beschränkte Delegation 80
Ressourcenbasierte Delegation 80
SPN-Konfiguration 81
Vertrauensstellungen 81

Risiken fehlerhafter Delegation 81
Sichere Konfiguration 82
Praxis: Delegation und Vertrauen untersuchen 82
Typische Fehler 85
Kontrollfragen 86
Lernzielkontrolle 87

Kapitel 12: Active Directory absichern – Hardening 88
Grundprinzipien 88
Least Privilege 88
Tiering-Modell 89
Separate Administratorkonten 89
Privileged Access Workstations 89
Microsoft LAPS 90
LDAP-Sicherheit 90
SMB-Signierung und NTLM-Einschränkungen 90
Kerberos-Hardening 91
Sichere Gruppenrichtlinien 91
Passwort- und Kontosperrrichtlinien 91
MFA und phishing-resistente Authentifizierung 91
Patchmanagement und Domänencontroller-Härtung 92
Backup und Recovery 92
Praxis: Den Stand der Domäne prüfen und härten 92
Typische Fehler 96
Kontrollfragen 96
Lernzielkontrolle 97

Kapitel 13: Active-Directory-Monitoring und Angriffserkennung 98
Warum Monitoring Angriffe überhaupt sichtbar macht 98
Windows-Ereignisprotokolle 99
Erweiterte Überwachungsrichtlinie 99
Sysmon 99
Wichtige Ereignis-IDs 100
Erkennung von Gruppenänderungen 100
Kerberos-Ereignisse 101

DCSync-Erkennung 101
SIEM, Microsoft Sentinel und Defender for Identity 102
MITRE ATT&CK und die Erkennung 102
Praxis: Überwachung aktivieren und Ereignisse auswerten 102
Typische Fehler 105
Kontrollfragen 106
Lernzielkontrolle 107

Kapitel 14: Incident Response bei kompromittiertem Active Directory 108

Kleiner Vorfall oder Domänenkompromittierung 108
Verdacht auf Domänenkompromittierung 109
Erste Bewertung 109
Eindämmung 109
Beweissicherung 109
Analyse privilegierter Konten 110
Untersuchung des krbtgt-Kontos 110
Untersuchung von Domänencontroller-Änderungen 110
Credential Rotation 110
Wiederherstellung und KRBTGT-Kennwortwechsel 111
Vertrauenswürdige Wiederherstellung 111
Überwachung nach dem Vorfall 111
Dokumentation und Lessons Learned 111
Praxis: Einen Vorfall in der Testdomäne bearbeiten 112
Typische Fehler 114
Kontrollfragen 115
Lernzielkontrolle 116

Kapitel 15: Praxisprojekt – Eine Windows-Domäne prüfen, angreifen lassen und absichern 117

Ausgangslage und Voraussetzungen 117
Aufgabe 1: Auftrag formulieren und Domäne prüfen 118
Aufgabe 2: Baseline sichern 118
Aufgabe 3: Angriffsfläche analysieren 119
Aufgabe 4: Kontrollierte Simulation 120
Aufgabe 5: Erkennung aktivieren und prüfen 121

Aufgabe 6: Härtung umsetzen 122
Aufgabe 7: Vorher-Nachher-Vergleich und Bericht 123
Restrisiken, die im Bericht stehen müssen 124
Qualitätsprüfung des Projekts 124
Kontrollfragen 125
Lernzielkontrolle 125

Anhang 126

Active-Directory-Spickzettel 126
Windows-Security-Ereignisse im Überblick 127
Verschlüsselungstypen und Bitwerte 129
Sysmon-Übersicht 129
Hardening-Checkliste 130
GPO-Sicherheitscheckliste 131
Incident-Response-Checkliste 131
Verzeichnis der PowerShell-Befehle 132
Muster eines Abschlussberichts 134
Glossar 135
Quellenverzeichnis 137
Index 139

Vorwort

In den meisten Unternehmen entscheidet ein einziges Verzeichnis darüber, wer was darf: Active Directory speichert Benutzer, Computer und Gruppen und legt fest, welche Anmeldung wo gilt. Wer dieses Verzeichnis kontrolliert, kontrolliert in der Regel die gesamte Windows-Umgebung. Genau deshalb ist Active Directory seit Jahren eines der häufigsten Ziele, wenn Angreifer in Unternehmensnetze eindringen.

Warum Active Directory ein zentrales Angriffsziel ist

Ein gewöhnliches Benutzerkonto kann in einer Domäne oft mehr sehen, als man erwartet. Gruppenmitgliedschaften, Dienstkonten und Berechtigungen auf Objekten ergeben zusammen ein Geflecht, das über Jahre gewachsen ist und selten vollständig überblickt wird. Ein Angreifer muss deshalb nicht den Administrator knacken, wenn er einen Weg findet, der über viele kleine, für sich harmlose Schritte dorthin führt.

Bedeutung von Identitäten und Berechtigungen

In einer Windows-Domäne ist die Identität eines Kontos wichtiger als das Gerät, an dem es sich anmeldet. Wer ein Konto mit weitreichenden Rechten übernimmt, bewegt sich damit durch alle Systeme, die dieses Konto akzeptieren. Das Buch versucht deshalb immer beide Fragen zugleich zu beantworten: Welche Identität ist betroffen, und welche Berechtigungen hängen an ihr?

Active Directory in Unternehmen

Die meisten Organisationen mit Windows-Clients betreiben mindestens einen Domänencontroller. Häufig gibt es mehrere Standorte, dazu Dienstkonten für Anwendungen und Sicherungssysteme, und oft gewachsene Strukturen aus Umzügen, Übernahmen und Projekten. Diese Vielfalt macht Active Directory mächtig, aber auch schwer zu prüfen.

Verbindung zwischen Windows Security, Ethical Hacking und Blue Team

Die Windows-Security-Reihe dieser Fachbibliothek behandelt Grundlagen der Windows-Sicherheit und die Absicherung einer Domäne. Dieses Buch baut darauf auf und setzt Grundlagen wie Gruppenrichtlinien, Kerberos und NTLM als bekannt voraus. Wo ein Thema dort ausführlich steht, verweist das Buch darauf, statt es zu wiederholen.

Der Blick ist doppelt. Wer ein Angreifer ist, sucht Schwachstellen, die sich ausnutzen lassen. Wer die Domäne verteidigt, sucht dieselben Schwachstellen, um sie vorher zu schließen oder einen Angriff früh zu erkennen. Beide Perspektiven arbeiten mit denselben Werkzeugen und denselben Ereignissen.

Für wen ist dieses Handbuch?

Das Buch richtet sich an Administratoren, die ihre Domäne verstehen und prüfen wollen, an Analysten, die Angriffe erkennen müssen, und an Ethical Hacker, die Schwachstellen in autorisierten Tests bewerten. Vorausgesetzt werden Grundkenntnisse in Windows-Administration und Netzwerken. Ein Anfänger findet hier eine verständliche Einführung, ein erfahrener Administrator findet vor allem die Zusammenhänge zwischen Rechten, Angriffspfaden und Erkennung.

Aufbau des Buches

Das Buch gliedert sich in drei Teile. Kapitel 1 und 2 erklären Active Directory und seine Architektur. Kapitel 4 bis 6 und Kapitel 8 und 9 behandeln Angriffsmethodik, Rechte und Angriffspfade, jeweils mit Erkennung und Gegenmaßnahmen. Kapitel 10 behandelt Persistenz und Domänenkompromittierung. Kapitel 11 bis 14 widmen sich Delegation, Hardening, Monitoring und Incident Response. Ein verkürztes Praxisprojekt auf der Domäne `nova.int` verbindet die Teile.

Hinweis zu Angriffsdarstellungen

Das Buch erklärt, wie Angriffe funktionieren und warum sie funktionieren. Es enthält keine ausführbaren Angriffsketten gegen fremde Systeme. Die Demonstrationen laufen ausschließlich in der isolierten Laborumgebung, die im Buch beschrieben ist. Befehle sind nach der Dokumentation der Hersteller zusammengestellt und wurden vor der Veröffentlichung nicht praktisch getestet. Prüfe sie vor dem Einsatz in deiner eigenen Testdomäne.

Voraussetzungen für die Praxisübungen

Du brauchst eine isolierte Testumgebung mit einem Windows-Server 2022 als Domänencontroller und einem Windows-11-Client. Die Befehle nutzen das Modul ActiveDirectory aus den Remoteserver-Verwaltungstools (RSAT) beziehungsweise dem Serverbetriebssystem. Das Modul funktioniert unter Windows PowerShell 5.1 und PowerShell 7 unterschiedlich gut; die Übungen geben an, welche Version sie voraussetzen. Die Domäne heißt `nova.int`, wie in der Windows-Security-Reihe.

Kapitel 1: Einführung – Was ist Active Directory Security?

Lernziele

- Du erklärst, was Active Directory Domain Services leistet und welche Dienste dazugehören.
- Du benennst die Rolle von LDAP, Kerberos, NTLM und Gruppenrichtlinien im Zusammenspiel.
- Du begründest, warum Active Directory als Sicherheitsgrenze gilt und warum es angegriffen wird.

Was ist Active Directory?

Active Directory ist Microsofts Verzeichnisdienst für Windows-Netzwerke. Seine Kernkomponente heißt Active Directory Domain Services (AD DS). Sie speichert Objekte wie Benutzer, Computer, Gruppen und Organisationseinheiten in einer zentralen Datenbank und stellt sie allen Systemen der Domäne zur Verfügung. Ein Benutzer meldet sich einmal an, und die Domäne entscheidet, auf welche Ressourcen er zugreifen darf.

Das ist der eigentliche Zweck: Identitäten und Berechtigungen werden an einer Stelle verwaltet, nicht auf jedem einzelnen Rechner. Für ein Unternehmen mit hunderten Arbeitsplätzen ist das unverzichtbar. Für einen Angreifer ist dieselbe Zentralisierung attraktiv, weil eine Kompromittierung an der richtigen Stelle viele Systeme gleichzeitig öffnet.

Geschichte und Entwicklung

Active Directory wurde mit Windows 2000 eingeführt und hat seitdem viele Versionen erlebt, die auf dem Verzeichnisdienst aufbauen. Die Grundprinzipien sind geblieben: Domänen, LDAP als Zugriffsprotokoll und Kerberos als Standard-Authentifizierung. Neuere Versionen haben Funktionsebenen, Schutzmechanismen und Verwaltungsfunktionen ergänzt. Wer ältere Domänen betreibt, findet deshalb oft Konfigurationen, die aus einer früheren Zeit stammen und heute als riskant gelten.

Active Directory Domain Services (AD DS)

AD DS läuft auf Domänencontrollern, also auf Servern, die die Verzeichnisdatenbank halten und Anmeldungen bearbeiten. Eine Domäne hat in der Regel mehrere Domänencontroller, die sich die Datenbank über Replikation teilen, damit der Ausfall eines Servers keine Anmeldung verhindert.

Zentrale Identitätsverwaltung

Jedes Konto in der Domäne hat eine eindeutige Sicherheitskennung, den Security Identifier (SID), und einen Namen. Berechtigungen werden nicht am Namen festgemacht, sondern am SID. Das schützt vor Verwechslungen bei umbenannten Konten, hat aber eine Folge: Wer die SID-Zuordnung versteht, versteht auch, wie Rechte vergeben werden.

Benutzer, Computer und Gruppen

Benutzerkonten sind Personen oder Dienste zugeordnet. Computerkonten repräsentieren Arbeitsplätze und Server in der Domäne und besitzen eigene Kennwörter. Gruppen fassen Konten zusammen und sind der wichtigste Hebel für Berechtigungen, denn Rechte werden meist an Gruppen vergeben, nicht an einzelne Personen. Gruppen können ineinander verschachtelt werden, und genau diese Verschachtelung ist eine der häufigsten Ursachen für unbeabsichtigte Rechte.

Domänen und Gesamtstrukturen

Eine Domäne ist eine Verwaltungs- und Sicherheitsgrenze mit eigener Datenbank. Mehrere Domänen können zu einer Gesamtstruktur (Forest) gehören, die ein gemeinsames Schema teilt. Die Gesamtstruktur ist nach heutigem Verständnis die eigentliche Sicherheitsgrenze, weil Administratoren einer Domäne unter Umständen Einfluss auf andere Domänen derselben Struktur haben.

LDAP

Das Lightweight Directory Access Protocol ist das Protokoll, über das Anwendungen und Dienste das Verzeichnis abfragen und ändern. Es ist die Sprache, in der Active Directory mit der Außenwelt spricht. Die Standardports sind 389 für LDAP und 636 für LDAP über TLS (LDAPS). Ob eine Verbindung verschlüsselt oder signiert ist, entscheidet über den Schutz der übertragenen Daten, was Kapitel 12 behandelt.

Kerberos

Kerberos ist das Standard-Authentifizierungsprotokoll in Active Directory. Es arbeitet mit Tickets, die ein Domänencontroller ausstellt, und vermeidet, dass Passwörter bei jeder Anmeldung über das Netz übertragen werden. Die Grundlagen behandelt die Windows-Security-Reihe in Band 2, Kapitel 7. Dieses Buch greift Kerberos dort auf, wo Angriffe darauf aufsetzen.

NTLM

NTLM ist das ältere Authentifizierungsverfahren von Windows. Es ist aus Kompatibilitätsgründen noch vorhanden und in vielen Domänen aktiv, obwohl es gegenüber Kerberos schwächer ist. Angriffe wie Pass-the-Hash setzen darauf auf. Wie NTLM funktioniert und wie man es einschränkt, erklärt Band 2 ebenfalls; Kapitel 12 dieses Buches nimmt die Einschränkung als Hardening-Maßnahme auf.

Gruppenrichtlinien

Gruppenrichtlinienobjekte (GPOs) verteilen Einstellungen an Benutzer und Computer der Domäne. Sie sind ein mächtiges Verwaltungswerkzeug und zugleich ein Angriffsziel: Wer eine GPO verändern darf, kann Einstellungen auf allen Systemen beeinflussen, auf die sie angewendet wird. Band 2, Kapitel 4 behandelt GPOs im Detail.

Active Directory als Sicherheitsgrenze

Die Domäne wird oft als Sicherheitsgrenze betrachtet, doch das ist nur eine Annahme, die ein Angreifer nicht respektieren muss. Ist ein Konto mit weitreichenden Rechten kompromittiert, endet die Grenze an der Stelle, an der dieses Konto Zugriff hat. Deshalb genügt es nicht, die äußeren Zugänge zu sichern. Entscheidend ist, welche Identitäten existieren und was sie dürfen.

Warum Active Directory ein attraktives Angriffsziel ist

Drei Eigenschaften machen Active Directory attraktiv. Erstens enthält es die Informationen, die ein Angreifer braucht, um sich zu orientieren: Benutzer, Gruppen, Computer und deren Beziehungen. Zweitens bündelt es Berechtigungen, so dass wenige Konten viel kontrollieren. Drittens sind viele Fehlkonfigurationen schwer zu sehen, weil sie über Jahre hinweg entstanden sind.

Typische Sicherheitsprobleme

Die häufigsten Probleme sind veraltete Konten mit aktiven Berechtigungen, Dienstkonten mit schwachen oder seit Jahren unveränderten Kennwörtern, zu weit verschachtelte Gruppen, Administratorkonten, die auf Arbeitsplätzen angemeldet sind, und ungeprüfte Delegationen. Die Kapitel 4 bis 11 behandeln diese Probleme einzeln.

> **Gut zu wissen**
>
> Die Begriffe Fehlkonfiguration, Sicherheitslücke, Angriffsversuch und erfolgreiche Kompromittierung meinen nicht dasselbe. Eine Fehlkonfiguration ist eine Einstellung, die nicht zur Sicherheitsrichtlinie passt. Eine Sicherheitslücke ist ein Fehler im Produkt selbst, den der Hersteller korrigieren muss. Ein Angriffsversuch ist eine Handlung, die einen Schutz überwinden soll, egal ob sie gelingt. Eine erfolgreiche Kompromittierung liegt vor, wenn der Angreifer tatsächlich Zugriff erlangt hat. Diese Unterscheidung zieht sich durch das Buch.

> **Zusammenfassung**
>
> • Active Directory speichert Identitäten und Berechtigungen zentral und ist deshalb ein lohnendes Ziel.
> • LDAP, Kerberos, NTLM und Gruppenrichtlinien sind die Bausteine, über die Dienste und Benutzer mit der Domäne arbeiten.
> • Die Gesamtstruktur ist die eigentliche Sicherheitsgrenze, nicht die einzelne Domäne.
> • Fehlkonfigurationen, Sicherheitslücken, Angriffsversuche und Kompromittierungen sind getrennt zu betrachten.

Kontrollfragen

1. Was speichert Active Directory Domain Services? (leicht)
2. Welche Ports verwendet LDAP im Standard? (leicht)
3. Warum werden Berechtigungen an Gruppen statt an einzelne Konten vergeben, und welche Folge hat das? (mittel)
4. Unterscheide Fehlkonfiguration und Sicherheitslücke an einem Beispiel. (mittel)
5. Ein Administrator sagt: „Unsere Domäne ist sicher, weil die Firewall den Zugang zu den Domänencontrollern sperrt.“ Welche Annahme steckt darin, und warum trägt sie nicht? (schwer)

Lösungshinweise: 1. Benutzer, Computer, Gruppen und Organisationseinheiten mit ihren Eigenschaften und Berechtigungen. 2. 389 für LDAP und 636 für LDAPS. 3. Gruppen vereinfachen die Verwaltung, weil Rechte gesammelt werden können. Die Folge ist, dass verschachtelte oder überladene Gruppen unbeabsichtigt viele Rechte bündeln, die niemand mehr überblickt. 4. Eine Fehlkonfiguration ist zum Beispiel ein Dienstkonto mit zu weitreichenden Rechten. Eine Sicherheitslücke wäre ein Fehler im Produkt, den der Hersteller per Patch beheben muss. 5. Die Annahme ist, dass der Zugang von außen die einzige Bedrohung ist. Ein Angreifer, der bereits ein Konto im internen Netz kompromittiert hat, umgeht die Firewall, und die Domäne verliert dann ihre Schutzwirkung.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die Dienste und Protokolle einer Domäne in ihrem Zusammenspiel beschreiben kannst,
- [ ] erklären kannst, warum Gruppen den wichtigsten Hebel für Rechte bilden,
- [ ] die vier Begriffe aus dem Info-Kasten sicher unterscheidest.

Kapitel 2: Active-Directory-Architektur verstehen

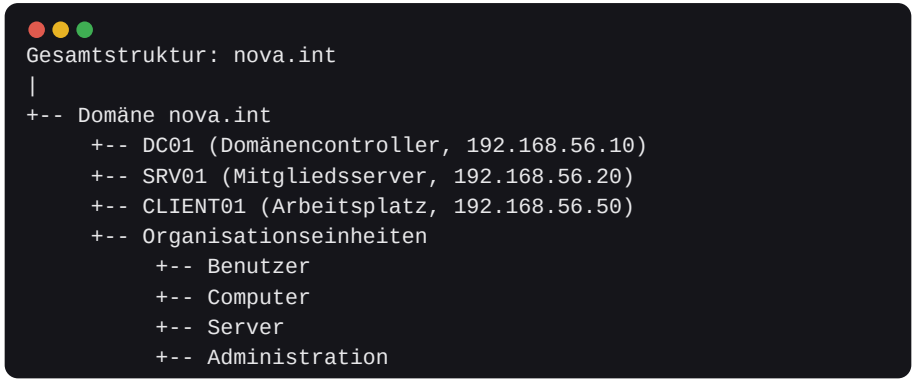
Lernziele

- Du beschreibst den Aufbau einer Gesamtstruktur aus Domänen, Domänencontrollern und Organisationseinheiten.
- Du liest Distinguished Names und SIDs und erklärst, was sie über ein Objekt aussagen.
- Du untersuchst eine Testdomäne mit PowerShell und ordnest die Ausgaben richtig ein.

Die Bausteine im Überblick

Eine Active-Directory-Umgebung besteht aus mehreren ineinandergreifenden Ebenen. Die oberste ist die Gesamtstruktur (Forest). Sie enthält eine oder mehrere Domänen, jede Domäne wird von Domänencontrollern betrieben, und innerhalb einer Domäne ordnen Organisationseinheiten die Objekte. Physisch spiegeln Sites und Subnets die Netzwerkstandorte wider.

Diagramm 2.1: Gesamtarchitektur einer Testumgebung



Die Testdomäne aus Band 2 der Windows-Security-Reihe besteht aus diesen Systemen. Die Organisationseinheiten entsprechen den Angaben

dieses Buches. Die vollständige Beschreibung der Laborumgebung steht im Praxisprojekt am Ende des Buches.

Domänen und Gesamtstruktur

Eine Domäne ist ein Verwaltungs- und Replikationsbereich mit eigener Datenbank. Die Gesamtstruktur umfasst alle Domänen, die ein gemeinsames Schema und eine gemeinsame Konfiguration teilen. Vertrauensstellungen verbinden Domänen miteinander; Kapitel 11 behandelt ihre Risiken.

Für die Sicherheit ist die Gesamtstruktur entscheidend. Administratoren mit weitreichenden Rechten in der Gesamtstruktur, etwa in der Gruppe Enterprise Admins, können Änderungen in allen Domänen vornehmen. Eine Domäne, die sich als eigenständig versteht, ist deshalb nur so unabhängig wie die höchsten Konten der Gesamtstruktur.

Domänencontroller und Global Catalog

Ein Domänencontroller hält eine vollständige Kopie der Datenbank seiner Domäne und bearbeitet Anmeldungen. Ein Global Catalog ist eine zusätzliche Funktion, die eine teilweise Kopie aller Domänen der Gesamtstruktur bereitstellt. Er wird unter anderem für Suchanfragen über Domänengrenzen hinweg gebraucht.

Organisationseinheiten

Organisationseinheiten (OU) sind Container, in denen Objekte nach Zweck oder Verantwortung gruppiert werden. Sie sind nicht zwingend Sicherheitsgrenzen, werden aber häufig als Ansatzpunkt für Gruppenrichtlinien und Delegation genutzt. Eine OU wie Administration mit eingeschränktem Zugriff ist deshalb ein sinnvolles Muster, sofern die Berechtigungen auf ihr korrekt gesetzt sind.

Sites, Subnets und Replikation

Sites bilden physische Standorte ab. Subnets ordnen IP-Bereiche diesen Standorten zu, damit Clients den nächsten Domänencontroller finden. Domänencontroller tauschen Änderungen über Replikation aus. Eine Änderung an einem Benutzer auf DC01 erscheint erst nach einiger Zeit auf allen anderen Domänencontrollern. Diese Verzögerung ist normal, muss aber bei Untersuchungen berücksichtigt werden, weil sich Zustände zwischen den Controllern kurzfristig unterscheiden können.

FSMO-Rollen

Fünf Rollen müssen eindeutig vergeben sein, weil sie Änderungen koordinieren, die nicht beliebig verteilt werden dürfen. Der Schema-Master verwaltet das Schema der Gesamtstruktur, der Domänennamen-Master die Domänen. Der RID-Master vergibt Bereiche für neue Objekte, der PDC-Emulator behandelt Kennwortänderungen und Zeitsynchronisation, der Infrastruktur-Master verwaltet Verweise auf Objekte in anderen Domänen. Der PDC-Emulator ist für Sicherheit besonders relevant, weil er bei Kennwortfehlern als erster befragt wird und oft zentrale Zeitquelle ist.

DNS und Active Directory

Active Directory ist eng mit DNS verbunden. Domänencontroller veröffentlichen Dienstdatensätze (SRV-Einträge) wie `_ldap._tcp.dc._msdcs`, über die Clients sie finden. Ist DNS falsch konfiguriert, funktionieren Anmeldung und Replikation nicht. Für die Analyse ist DNS deshalb eine eigene Quelle: Die Dienstdatensätze zeigen, welche Server sich als Domänencontroller anbieten.

LDAP-Verzeichnisstruktur und Distinguished Names

Das Verzeichnis ist baumförmig aufgebaut. Jedes Objekt hat einen Distinguished Name (DN), der seinen Pfad vom Stamm beschreibt. Ein Beispiel für den Benutzer max.mustermann lautet:

Diagramm 2.2: Aufbau eines Distinguished Name

```
CN=Max Mustermann,OU=Benutzer,DC=nova,DC=int

CN   gemeinsamer Name des Objekts
OU   Organisationseinheit, in der das Objekt liegt
DC   Domänenkomponente, hier die Domäne nova.int
```

Der DN verrät, wo ein Objekt liegt. Er verrät nicht, welche Rechte es hat. Eine Person, die in einer OU Administration liegt, kann dort ohne Weiteres weniger Rechte haben als ein Konto in der OU Benutzer, wenn die Gruppenmitgliedschaften es so vorsehen.

Security Identifier

Jedes Konto und jede Gruppe bekommt bei der Erstellung einen SID. Er hat die Form `S-1-5-21-<Domänenkennung>-<RID>`. Die Domänenkennung besteht aus drei numerischen Teilwerten; die Platzhalter stehen für diese Werte und für die RID. Die letzte Zahl, die relative ID (RID), unterscheidet das Objekt innerhalb der Domäne. Einige RIDs sind fest vergeben: 500 für das eingebaute Administratorkonto, 502 für das Konto krbtgt, 512 für die Gruppe Domain Admins und 519 für die Gruppe Enterprise Admins. Die Domänenkennung ist für alle Objekte der Domäne gleich.

Der SID ist die eigentliche Identität in Zugriffsrechten. Ein Konto, das gelöscht und neu angelegt wird, bekommt einen neuen SID, auch wenn Name und Eigenschaften gleich sind. Berechtigungen, die noch auf den alten SID verweisen, greifen dann nicht mehr. Umgekehrt bleibt der alte SID in alten Zugriffslisten sichtbar, was bei Untersuchungen Hinweise gibt.

Gruppenmitgliedschaften und Berechtigungsmodell

Berechtigungen hängen an Objekten als Zugriffssteuerungslisten (ACL). Eine Gruppe erhält eine Berechtigung, Mitglieder erben sie. Verschachtelte Gruppen erben nach dem gleichen Prinzip, weshalb ein Konto Rechte haben kann, die nirgends direkt vergeben wurden. Kapitel 8 zeigt, wie solche Ketten sichtbar werden.

Service Accounts, Managed Service Accounts und gMSA

Dienste laufen unter Konten. Ein klassisches Dienstkonto hat ein Kennwort, das jemand festlegen und pflegen muss. In der Praxis wird es oft nie geändert, was es zu einem lohnenden Ziel macht. Managed Service Accounts (MSA) und Group Managed Service Accounts (gMSA) verwalten das Kennwort automatisch. Die Windows-Security-Reihe behandelt die Umstellung in Band 2, Kapitel 12. Dieses Buch greift sie in Kapitel 5 wieder auf, weil sie das Kerberoasting verhindern.

Praxis: Die Testdomäne untersuchen

Die folgenden Übungen laufen auf DC01 oder einem Client mit installierten Remoteserver-Verwaltungstools. Sie lesen nur Daten und verändern nichts.

Übung A: Domäne und Gesamtstruktur auslesen

Lernziel: die zentralen Eigenschaften der Domäne und der Gesamtstruktur feststellen. **Voraussetzungen:** Modul ActiveDirectory, Leserecht im Verzeichnis. Teste die Übung unter Windows PowerShell 5.1 und unter PowerShell 7 mit installiertem Modul.

Befehle zu Übung A

```
PS> Get-ADDomain | Select-Object Name, DNSRoot, NetBIOSName,
    PDCEmulator, DomainMode
PS> Get-ADForest | Select-Object Name, ForestMode, SchemaMaster,
    DomainNamingMaster
```

Erklärung: `Get-ADDomain` liefert Eigenschaften der aktuellen Domäne. `DNSRoot` ist der vollständige Domänenname, `PDCEmulator` der Server, der die Rolle hält. `Get-ADForest` liefert die Gesamtstruktur. `DomainMode` und `ForestMode` nennen die Funktionsebene, die bestimmt, welche Sicherheitsfunktionen verfügbar sind. **Erwartetes Ergebnis:** Der Domänenname lautet `nova.int`, der PDC-Emulator zeigt auf DC01. Die Funktionsebene entspricht der Version, die du installiert hast. **Überprüfung:** Der Name aus `DNSRoot` stimmt mit dem Namen aus dem Vorwort überein. **Fehleranalyse:** `Get-ADDomain` nicht gefunden? Installiere die Remoteserver-Verwaltungstools beziehungsweise die Rolle und prüfe mit

`Get-Module -ListAvailable ActiveDirectory`.

Übung B: Domänencontroller identifizieren

Lernziel: alle Domänencontroller einer Domäne bestimmen und ihre Standorte prüfen. **Aufgabenstellung:** Lies die Domänencontroller aus und vergleiche das Ergebnis mit `nltest`.

Befehle zu Übung B

```
PS> Get-ADDomainController -Filter * | Select-Object Name,
    IPv4Address, Site, OperatingSystem
PS> nltest /dclist:nova.int
```

Erklärung: `-Filter *` liefert alle Controller. `Site` nennt den Standort. `nltest /dclist` fragt denselben Bestand über ein älteres Werkzeug ab. Beide Angaben müssen übereinstimmen. **Erwartetes Ergebnis:** DC01 erscheint mit IP-Adresse 192.168.56.10 und dem Standort Default-First-Site-Name oder dem von dir gewählten Standort. **Fehleranalyse:** Ein Controller fehlt in einer der beiden Ausgaben? Prüfe mit `repadmin /showrepl`, ob die Replikation funktioniert, und notiere die Abweichung.

Übung C: Organisationseinheiten analysieren

Lernziel: die OU-Struktur lesen und mit der Projektbeschreibung vergleichen. **Aufgabenstellung:** Liste alle Organisationseinheiten mit ihrem vollständigen Pfad.

Befehle zu Übung C

```
PS> Get-ADOrganizationalUnit -Filter * | Select-Object Name,
    DistinguishedName
```

Erklärung: Der Filter `*` liefert alle OUs. Der DistinguishedName zeigt den vollständigen Pfad, der bei verschachtelten Strukturen wichtig ist. **Erwartetes Ergebnis:** Die OUs Benutzer, Computer, Server und Administration erscheinen, zusammen mit den Standard-OUs wie Domain Controllers. **Überprüfung:** Vergleiche die Liste mit der Projektbeschreibung. Abweichungen sind kein Fehler im Buch, sondern eine Dokumentationsfrage für deine Umgebung.

Übung D: Benutzer und Gruppen auflisten

Lernziel: Benutzerkonten und Mitglieder privilegierter Gruppen feststellen. **Aufgabenstellung:** Lies alle Benutzer mit Aktivierungsstatus aus und dann die Mitglieder der Gruppe Domain Admins.

Befehle zu Übung D

```
PS> Get-ADUser -Filter * -Properties Enabled | Select-Object
    SamAccountName, Enabled
PS> Get-ADGroupMember -Identity "Domain Admins" | Select-Object
    Name, SamAccountName
```

Erklärung: `-Properties Enabled` fordert das Attribut an, das im Standard nicht geladen wird. `Get-ADGroupMember` listet die direkten Mitglieder. Verschachtelte Mitglieder erscheinen nur mit der Option `-Recursive`. **Erwartetes Ergebnis:** Die Benutzerliste enthält max.mustermann und svc_backup. Die Gruppe Domain Admins enthält mindestens das Administratorkonto. **Überprüfung:** Ein Konto, das du nicht erklären kannst, ist ein Prüfpunkt. Notiere ihn mit Name und Herkunft. **Fehleranalyse:** Die Gruppe Domain Admins ist leer? Das ist unwahrscheinlich, weil das Administratorkonto dort üblicherweise Mitglied ist. Prüfe die Schreibweise des Gruppennamens.

Übung E: SID und Gruppenzugehörigkeit eines Kontos bestimmen

Lernziel: den SID eines Kontos lesen und seine RID einordnen. **Aufgabenstellung:** Lies den SID von max.mustermann aus und prüfe die eigene Identität auf DC01 oder CLIENT01 mit `whoami`.

Befehle zu Übung E

```
PS> Get-ADUser -Identity max.mustermann -Properties SID |
    Select-Object SamAccountName, SID
PS> whoami /user
```

Erklärung: Die Eigenschaft SID liefert den vollständigen Security Identifier. `whoami /user` zeigt den SID des angemeldeten Kontos. Die letzte Zahl im SID ist die RID. **Erwartetes Ergebnis:** Der SID von max.mustermann beginnt mit `S-1-5-21-` und endet mit einer RID, die oberhalb von 1000 liegt,

da es sich um ein benutzerdefiniertes Konto handelt. **Überprüfung:** Der SID aus beiden Ausgaben ist identisch, wenn du dich als max.mustermann angemeldet hast. **Fehleranalyse:** Der SID ist leer? Die Eigenschaft muss mit `-Properties SID` angefordert werden.

Kontrollfragen

1. Welche Ebene einer Active-Directory-Umgebung kontrolliert die Gesamtstruktur? (leicht)
2. Was verrät ein Distinguished Name, und was verrät er nicht? (leicht)
3. Welche RID hat das eingebaute Administratorkonto, und warum ist sie bei Untersuchungen nützlich? (mittel)
4. Warum ist die Replikationsverzögerung bei einer Untersuchung relevant? (mittel)
5. Ein Dienstkonto hat einen SID, der nach einer Löschung und Neuanlage verändert ist, obwohl Name und Gruppen gleich geblieben sind. Welche Auswirkungen hat das auf Berechtigungen, und wo wäre der alte SID noch sichtbar? (schwer)

Lösungshinweise: 1. Die Gesamtstruktur, über die Enterprise Admins Änderungen in allen Domänen vornehmen können. 2. Der DN zeigt den Pfad eines Objekts im Verzeichnisbaum, nicht seine Rechte. 3. RID 500. Sie kennzeichnet das eingebaute Administratorkonto unabhängig vom Namen, der umbenannt sein kann. 4. Zwischen den Controllern können sich Zustände kurzfristig unterscheiden, deshalb muss der Zeitpunkt der Beobachtung je Controller festgehalten werden. 5. Berechtigungen, die auf den alten SID verweisen, greifen für das neue Konto nicht mehr. Der alte SID bleibt in Zugriffslisten sichtbar, besonders in ACLs auf Dateien und Objekten.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die Bausteine von der Gesamtstruktur bis zur OU in ihrer Reihenfolge beschreibst,
- [ ] DN und SID lesen und die Bedeutung der RID erklären kannst,
- [ ] die Domäne mit PowerShell untersucht und die Ausgaben einordnest,

[ ] weißt, warum du Replikations- und Zeitangaben dokumentieren musst.

Zusammenfassung

- Die Gesamtstruktur ist die höchste Verwaltungsebene und damit das eigentliche Sicherheitsgrenzen-Modell.
- Ein SID ist die Identität eines Objekts, der DN nur sein Ort im Verzeichnis.
- FSMO-Rollen, Replikation und DNS bestimmen, wie zuverlässig die Domäne arbeitet und was sie zeigt.
- Die Übungen lesen nur Daten und liefern die Grundlage für alle folgenden Kapitel.

Kapitel 3: Authentifizierung – Kerberos und NTLM im Überblick

Lernziele

- Du beschreibst den Unterschied zwischen Kerberos und NTLM in einem Satz.
- Du erkennst, an welchen Stellen Angriffe auf die Authentifizierung ansetzen.
- Du weißt, wo die Grundlagen ausführlich stehen und wo dieses Buch darauf aufbaut.

Gut zu wissen

Dieses Kapitel ist ein Verweis. Die Grundlagen von Kerberos und NTLM, einschließlich Tickets, Schlüssel und Protokollablauf, behandelt Band 2 der Windows-Security-Reihe in Kapitel 7. Die Angriffe auf beide Verfahren stehen in Band 3, Kapitel 9 und 10. Dieses Kapitel fasst nur zusammen, was du für die folgenden Kapitel brauchst.

Was die Authentifizierung leistet

Authentifizierung beantwortet die Frage, wer gerade spricht. Active Directory beantwortet sie für Benutzer und Computer zentral. Die Entscheidung, was danach erlaubt ist, trifft die Autorisierung über Gruppen und Berechtigungen (Kapitel 8). Die beiden Vorgänge liegen eng beieinander, werden in Berichten aber oft verwechselt.

Kerberos in einem Satz

Kerberos stellt nach einer erfolgreichen Anmeldung Tickets aus, mit denen sich ein Benutzer bei einzelnen Diensten ausweist, ohne sein Kennwort erneut zu übertragen. Die Tickets werden vom Domänencontroller ausgestellt und tragen Informationen über das Konto.

NTLM in einem Satz

NTLM ist ein Herausforderungs-Antwort-Verfahren, bei dem der Server einen Zufallswert schickt und der Client mit einem aus dem Kennwort-Hash abgeleiteten Wert antwortet. Der Hash selbst wird dabei nicht übertragen, wohl aber dessen Wirkung. Genau das nutzt Pass-the-Hash (Kapitel 7).

Warum beide Verfahren relevant sind

Solange NTLM in einer Domäne aktiv ist, kann ein Angreifer zwischen beiden Verfahren wechseln, je nachdem, welches Ziel akzeptiert. Kerberos ist die stärkere Wahl, verlangt aber korrekte Namensauflösung über DNS und korrekte Dienstkennungen (SPN). Fehlen diese, fällt die Authentifizierung auf NTLM zurück. Kapitel 12 beschreibt, wie sich das einschränken lässt.

Wo die Angriffe ansetzen

Die Kapitel 5, 6 und 7 dieses Buches behandeln drei Angriffsansätze auf die Authentifizierung: die Offline-Prüfung von Dienst-Tickets (Kerberoasting), die fehlende Vorauthentifizierung (AS-REP Roasting) und die Wiederverwendung von Hashes oder Tickets (Pass-the-Hash, Pass-the-Ticket). Alle drei nutzen die Protokolle korrekt, aber mit Konten, deren Schutz schwächer ist als er sein sollte.

> **Zusammenfassung**
>
> • Kerberos stellt Tickets aus, NTLM arbeitet mit Herausforderung und Antwort.
> • Die Grundlagen stehen in Band 2, Kapitel 7, die Angriffe in Band 3, Kapitel 9 und 10.
> • Angriffe auf die Authentifizierung nutzen korrekte Protokolle mit schwach geschützten Konten.

Kontrollfragen

1. Was stellt Kerberos nach einer Anmeldung aus? (leicht)
2. Warum wird bei NTLM das Kennwort nicht direkt übertragen, und warum genügt der Hash trotzdem für eine Anmeldung? (mittel)

3. Welche Bedingung führt dazu, dass Kerberos auf NTLM ausweicht? (mittel)

Lösungshinweise: 1. Tickets, mit denen sich ein Benutzer bei einzelnen Diensten ausweist. 2. Der Client antwortet auf eine Herausforderung mit einem Wert, der aus dem Hash abgeleitet ist. Wer den Hash besitzt, kann diese Antwort erzeugen, ohne das Kennwort zu kennen. 3. Fehlende oder falsche Namensauflösung über DNS oder fehlende passende Dienstkennung (SPN).

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] Kerberos und NTLM in je einem Satz beschreiben kannst,
- [ ] weißt, wo die ausführlichen Grundlagen stehen.

Kapitel 4: Active-Directory-Angriffe verstehen

Lernziele

- Du beschreibst die Phasen eines Angriffs auf eine Domäne in ihrer typischen Reihenfolge.
- Du ordnest jede Phase einer Technik aus dem MITRE-ATT&CK-Katalog zu.
- Du erklärst, warum ein Angriff innerhalb einer Domäne häufig über viele kleine, harmlos wirkende Schritte gelingt.

WARNUNG – Sicherheitsrisiko

Dieses Kapitel beschreibt Angriffe auf Prinzipebene, damit du sie erkennen und verhindern kannst. Es enthält keine ausführbaren Angriffsketten. Die Übungen beschränken sich auf Lesen und Auswerten in der eigenen Testdomäne.

Warum Methodik vor Werkzeug kommt

Angriffe auf Active Directory bestehen aus Schritten, die einander ergänzen. Ein Werkzeug führt diese Schritte aus, aber wer nur das Werkzeug kennt, versteht nicht, warum eine Fehlkonfiguration einen Angriff ermöglicht. Dieses Kapitel gibt das Gerüst, in das Kapitel 5 bis 11 die einzelnen Techniken einordnen.

Angriffsflächen

Eine Angriffsfläche ist alles, was ein Angreifer erreichen oder beeinflussen kann: Konten, Gruppen, Dienste, Gruppenrichtlinien, Vertrauensbeziehungen, Delegationen. In einer Domäne ist die Fläche groß, weil jedes Konto mit einer Anmeldung eine Ausgangsposition ist. Die Frage ist deshalb nicht nur, welche Konten privilegiert sind, sondern auch, welche Konten von außen oder von innen erreichbar sind.

Reconnaissance und Enumeration

Vor jedem Angriff steht die Erkundung. Im Verzeichnis kann ein gewöhnliches, authentifiziertes Konto erstaunlich viel lesen: Benutzer, Gruppen, Computer, teils Eigenschaften anderer Konten. Diese Lesbarkeit ist eine Grundfunktion, keine Lücke. Sie bedeutet aber, dass jedes Konto eine Quelle für Aufklärung ist.

Der Angreifer sucht hier typischerweise nach Benutzern, Gruppenzugehörigkeiten, Dienstkonten und Computern. Für den Verteidiger ist dieselbe Information ein Prüfauftrag: Welche Informationen liefert ein normales Konto, und ist das gewollt?

Benutzeraufklärung und Gruppenanalyse

Aus der Benutzerliste entstehen Hypothesen: Welche Konten sind alt, welche gehören zu Diensten, welche haben Namen, die Privilegien vermuten lassen. Die Gruppenanalyse prüft, welche Gruppen Privilegien tragen und wie sie verschachtelt sind. Verschachtelung ist der häufigste Grund, warum Rechte in einer Domäne niemand mehr versteht.

Berechtigungsanalyse und Service Accounts

Die Berechtigungsanalyse fragt, auf welchen Objekten welche Rechte liegen, vererbt oder direkt. Dienstkonten sind dabei besonders interessant, weil sie oft seit Jahren unverändert sind und Rechte besitzen, die für ihre Aufgabe nicht nötig wären. Kapitel 5 zeigt, wie ein solches Konto über seinen Dienstnamen sichtbar wird.

Fehlkonfigurationen

Die meisten erfolgreichen Angriffe nutzen Fehlkonfigurationen, nicht Fehler im Produkt. Eine Fehlkonfiguration ist eine Einstellung, die von der Sicherheitsrichtlinie abweicht: ein Konto ohne Vorauthentifizierung (Kapitel 6), eine Delegation, die zu weit reicht (Kapitel 11), ein Dienstkonto mit schwachem Kennwort (Kapitel 5).

Angriffswege innerhalb einer Domäne

Ein Angriffsweg verbindet mehrere Schritte. Ein Konto mit geringen Rechten ist Mitglied einer Gruppe, die eine Berechtigung auf einem Computer hat. Auf diesem Computer ist ein privilegiertes Konto angemeldet, dessen Anmeldedaten im Speicher liegen. Jeder Schritt wirkt für sich harmlos. Die Kette ist das Problem. Kapitel 8 und 9 zeigen, wie solche Ketten gefunden werden.

Privilege Escalation

Privilege Escalation bedeutet, mit geringen Rechten größere zu erlangen. In Active Directory geschieht das meist nicht über einen Exploit, sondern über Berechtigungen, die ein Konto über Gruppen oder ACLs ohnehin besitzt.

Lateral Movement

Lateral Movement ist die Bewegung von einem Computer zum nächsten. Dafür genügen gültige Anmeldedaten, die der Angreifer erlangt hat. Typische Wege sind Remotedienste, die ein Konto mit lokalen Administratorrechten nutzt, und Anmeldungen über Netzwerkprotokolle, die Pass-the-Hash oder Pass-the-Ticket erlauben (Kapitel 7).

Persistenz

Persistenz sichert den Zugang über das ursprüngliche Ereignis hinaus. Das kann eine zusätzliche Gruppenmitgliedschaft sein, ein verändertes Konto, eine Gruppenrichtlinie oder eine Delegation. Kapitel 10 behandelt diese Mechanismen und ihre Erkennung.

Domain Compromise

Eine vollständige Domänenkompromittierung liegt vor, wenn ein Angreifer die höchsten Rechte besitzt oder die Anmeldeinformationen aller Konten erhalten kann. Ab diesem Punkt hilft es nicht mehr, ein einzelnes Passwort zu ändern. Kapitel 14 behandelt die Wiederherstellung.

MITRE ATT&CK und Active Directory

Das Framework MITRE ATT&CK beschreibt Angriffstechniken mit einer eindeutigen Kennung. Die Technikbezeichnungen in diesem Buch orientieren sich daran. Eine Auswahl der Kennungen, die in den folgenden Kapiteln vorkommen:

- T1087, Account Discovery (Kontenerkundung)
- T1069, Permission Groups Discovery (Gruppenerkundung)
- T1558.003, Kerberoasting
- T1558.004, AS-REP Roasting
- T1550.002, Pass the Hash
- T1550.003, Pass the Ticket
- T1003.006, DCSync

Die Kennungen werden über neue Versionen des Katalogs gelegentlich ergänzt oder umgruppiert. Prüfe den aktuellen Stand auf der Webseite von MITRE ATT&CK, bevor du sie in einem Bericht verwendest.

Praxis: Angriffsflächen in der Testdomäne lesen

Die Übungen laufen mit einem gewöhnlichen Benutzerkonto auf CLIENT01 und mit einem Administratorkonto auf DC01. Sie lesen nur.

Übung A: Was sieht ein gewöhnliches Konto?

Lernziel: die Lesbarkeit des Verzeichnisses aus Sicht eines normalen Benutzers erleben. **Voraussetzungen:** Anmeldung als max.mustermann auf CLIENT01. Diese Übung braucht kein Modul.

Befehle zu Übung A

```
PS> whoami /groups
PS> net group "Domain Users" /domain
```

Erklärung: `whoami /groups` zeigt die Gruppen des angemeldeten Kontos, inklusive der Gruppen, die es durch Verschachtelung erbt. `net group ... /domain` listet die Mitglieder einer Domänengruppe, wenn das Konto das Recht dazu hat. **Erwartetes Ergebnis:** Das Konto sieht seine eigenen

Gruppen und die Mitglieder allgemeiner Gruppen. Mitglieder privilegierter Gruppen sind nicht einsehbar, wenn die Konfiguration das verhindert. **Überprüfung:** Notiere, welche Informationen du gesehen hast. Diese Liste ist die Angriffsfläche eines normalen Kontos.

Übung B: Verschachtelung sichtbar machen

Lernziel: eine verschachtelte Gruppe auflösen und ihre effektiven Mitglieder bestimmen. **Voraussetzungen:** Administratorkonto auf DC01, Modul ActiveDirectory. **Aufgabenstellung:** Löse die Gruppe IT-Admins rekursiv auf und vergleiche mit der direkten Mitgliederliste.

Befehle zu Übung B

```
PS> Get-ADGroupMember -Identity "IT-Admins"
PS> Get-ADGroupMember -Identity "IT-Admins" -Recursive
```

Erklärung: Die erste Abfrage zeigt nur direkte Mitglieder, die zweite löst alle verschachtelten Gruppen auf. Der Unterschied zeigt, welche Konten Rechte erben, ohne dass sie direkt genannt sind. **Erwartetes Ergebnis:** Die rekursive Liste enthält mehr Konten als die direkte, sofern Gruppen verschachtelt sind. **Überprüfung:** Jedes Konto der rekursiven Liste, das nicht direkt in IT-Admins steht, ist ein Befund, der erklärt werden muss. **Fehleranalyse:** Die Gruppe IT-Admins existiert nicht? Prüfe den Namen mit `Get-ADGroup -Filter *` und passe die Übung an deine Umgebung an.

Übung C: Angriffsweg auf Papier skizzieren

Lernziel: einen Angriffsweg als Kette aus Konten, Gruppen und Systemen darstellen. **Aufgabenstellung:** Zeichne auf Basis der Übungen A und B eine Kette: vom Konto max.mustermann über Gruppen und Berechtigungen bis zu einem Ziel mit hohen Rechten. Kennzeichne jeden Schritt mit der Technikkennung aus dem Abschnitt MITRE ATT&CK. **Erwartetes Ergebnis:** Ein Diagramm, in dem jeder Übergang begründet ist. Wenn die Kette nicht vollständig ist, markierst du die fehlenden Glieder als offen. **Überprüfung:** Kann jemand, der das Diagramm nicht kennt, die Kette nachvollziehen?

Kontrollfragen

1. Warum ist die Lesbarkeit des Verzeichnisses kein Fehler, aber trotzdem eine Angriffsfläche? (leicht)

2. Was unterscheidet Privilege Escalation im Active Directory von einem klassischen Exploit? (mittel)

3. Warum fallen verschachtelte Gruppen bei der Berechtigungsanalyse so häufig auf? (mittel)

4. Ein Angreifer besitzt Anmeldedaten eines Kontos ohne besondere Rechte. Welche Schritte kann er trotzdem gehen, und welche Kennung trägt der Schritt des Lesens des Verzeichnisses? (schwer)

Lösungshinweise: 1. Die Lesbarkeit ist eine Grundfunktion für den Betrieb. Sie liefert dem Angreifer aber Informationen für jede weitere Phase. 2. Sie nutzt vorhandene Berechtigungen und Gruppenmitgliedschaften, statt eine Schwachstelle im Produkt auszunutzen. 3. Rechte werden über Gruppen weitergegeben, und Verschachtelung macht die effektive Mitgliedschaft für Menschen unübersichtlich. 4. Er kann das Verzeichnis lesen, Gruppen auflösen und nach Diensten suchen. Der Schritt des Lesens fällt unter Account Discovery (T1087), die Gruppenerkundung unter T1069.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

[ ] die Phasen eines Angriffs in ihrer Reihenfolge beschreibst,

[ ] jede Phase einer Technik aus dem Abschnitt MITRE ATT&CK zuordnest,

[ ] mit den Übungen A bis C deine eigene Angriffsfläche einschätzen kannst.

> **Zusammenfassung**
>
> • Angriffe auf Active Directory bestehen aus Erkundung, Rechteerweiterung, Bewegung und Persistenz, die einander ergänzen.
> • Die meisten Angriffe nutzen Fehlkonfigurationen, nicht Fehler im Produkt.
> • Verschachtelte Gruppen und vererbte Rechte sind die häufigste Ursache für unübersichtliche Angriffspfade.
> • Jeder Schritt wird mit einer Technikkennung dokumentiert, die vor dem Bericht aktuell geprüft wird.

Kapitel 5: Kerberoasting

Lernziele

- Du erklärst, warum ein Dienstticket für jedes authentifizierte Konto anforderbar ist und welche Schwäche daraus entsteht.
- Du identifizierst Dienstkonten mit Dienstnamen (SPN) und bewertest ihre Verschlüsselung und Kennwortalter.
- Du erkennst Kerberoasting-Muster in den Ereignissen und setzt die Gegenmaßnahmen um.

WARNUNG – Sicherheitsrisiko

Dieses Kapitel erklärt das Prinzip des Angriffs und zeigt, wie er sich erkennen und verhindern lässt. Die Übungen fordern ausschließlich Tickets an, wie es jede Anwendung im Netzwerk tut, und werten die Ereignisse aus. Ein Auslesen oder Prüfen fremder Kennwörter gehört nicht zu diesem Buch.

Was ist Kerberoasting?

Kerberoasting ist ein Angriff auf Dienstkonten. Er nutzt aus, dass jedes authentifizierte Konto in der Domäne ein Dienstticket für jeden registrierten Dienst anfordern darf, unabhängig davon, ob es diesen Dienst nutzt. Ein Teil dieses Tickets ist mit dem Kennwort des Dienstkontos verschlüsselt. Ein Angreifer, der das Ticket besitzt, kann es offline prüfen, ohne dass auf dem Domänencontroller Fehlversuche entstehen.

Die Technik ist seit vielen Jahren bekannt und steht im MITRE-ATT&CK-Katalog unter T1558.003. Sie ist besonders wirksam, weil sie kaum auffällt, solange niemand die Ticketanforderungen überwacht.

Warum Dienstkonten gefährdet sind

Ein Dienstkonto führt einen Dienst aus, etwa eine Datensicherung oder eine Webanwendung. Sein Kennwort wird selten geändert, weil eine Änderung den Dienst unterbrechen kann. Oft wird es außerdem zu hoch privilegiert angelegt, damit der Dienst zuverlässig läuft. Ein altes, schwaches Kennwort mit weitreichenden Rechten ist genau das, was ein Angreifer sucht.

Zusammenhang zwischen Kerberos und SPNs

Ein Dienst wird in Kerberos über einen Dienstnamen identifiziert, den Service Principal Name (SPN). Beispiele sind `HTTP/intranet.nova.int` oder `MSSQLSvc/sql01.nova.int:1433`. Ist ein SPN einem Benutzerkonto zugeordnet, nicht einem Computerkonto, dann verschlüsselt der Domänencontroller die Tickets für diesen Dienst mit dem Kennwort dieses Benutzerkontos. Genau darin liegt die Schwäche.

Service Tickets

Ein Dienstticket wird auf Anforderung ausgestellt. Der Client sendet dem Domänencontroller seinen Ticket-Granting-Ticket-Nachweis und den gewünschten SPN. Der Domänencontroller antwortet mit einem Ticket, das den Dienst bestätigt, und dessen verschlüsselter Teil nur mit dem Kennwort des Dienstkontos geöffnet werden kann. Der Client selbst kann den Inhalt nicht lesen, benötigt ihn aber auch nicht. Er gibt das Ticket an den Dienst weiter.

> **Gut zu wissen**
>
> Das Verfahren ist korrekt. Kerberos sorgt dafür, dass Dienste sich gegenseitig ausweisen. Das Problem entsteht nur, wenn das Kennwort des Dienstkontos schwach ist: Dann kann das verschlüsselte Ticket außerhalb des Netzes geprüft werden, bis ein Kennwort passt.

Voraussetzungen

Der Angriff braucht ein beliebiges, aktiviertes Domänenkonto, einen oder mehrere SPNs, die einem Benutzerkonto zugeordnet sind, und ein Dienstkonto, dessen Kennwort schwach genug ist. Kein Administratorrecht ist nötig. Genau deshalb sind Dienstkonten mit SPN in einer Domäne ein so wichtiger Prüfpunkt.

Verschlüsselungstypen

Kerberos kann Tickets mit unterschiedlichen Verfahren verschlüsseln. RC4 ist älter und schneller zu prüfen, AES ist moderner und für Angriffe aufwendiger. Das Attribut `msDS-SupportedEncryptionTypes` beschreibt, welche Verschlüsselungstypen ein Konto unterstützt. Die Bits bedeuten: 0x4 für RC4, 0x8 für AES128, 0x10 für AES256. Es legt nicht fest, welcher Typ für ein konkretes Ticket verwendet wird. Dieser Typ ergibt sich aus der Aushandlung zwischen Client, Domänencontroller und den vorhandenen Schlüsseln des Kontos. Das tatsächlich verwendete Verfahren steht im Ereignis 4769 im Feld Ticket Encryption Type. Fehlt das Attribut, gilt der Standard des Domänencontrollers. Die Updates ab dem 8. November 2022 (CVE-2022-37966) ändern die Standardauswahl für Kerberos-Sitzungsschlüssel bei Konten ohne explizit gesetzten Verschlüsselungstyp. Welcher Typ für das Dienstticket tatsächlich verwendet wurde, ist weiterhin anhand des Ereignisses 4769 und des Feldes Ticket Encryption Type zu prüfen. Ein nicht gesetztes Attribut ist deshalb kein Beleg dafür, dass das Dienstticket mit AES verschlüsselt wurde. Microsoft hat außerdem angekündigt, RC4 als angenommenen Standard auf Domänencontrollern abzuschalten. Den aktuellen Stand prüfst du in der Microsoft-Dokumentation zu Kerberos-RC4.

Ablauf eines Kerberoasting-Angriffs

Diagramm 5.1: Kerberoasting-Prinzip (vereinfacht)

```
1. Konto ermittelt SPNs per LDAP-Abfrage
2. Konto fordert beim KDC Dienstickets an
3. Tickets sind mit dem Kennwort des Dienstkontos verschlüsselt
4. Angreifer prüft die Tickets außerhalb des Netzes
5. Bei schwachem Kennwort: Konto kompromittiert
```

Die Schritte 1 und 2 sehen für den Domänencontroller aus wie normaler Betrieb. Erst die Häufung und die Verschlüsselungswahl verraten, dass etwas anderes geschieht.

Erkennung

Jede Ticketanforderung erzeugt ein Ereignis mit der Kennung 4769 im Sicherheitsprotokoll des Domänencontrollers. Es enthält den angeforderten Dienstnamen, das anfordernde Konto und den Verschlüsselungstyp des Tickets. Ein Verschlüsselungstyp 0x17 steht für RC4, 0x12 für AES256, 0x11 für AES128.

Auffällig sind drei Muster: viele Anforderungen eines einzelnen Kontos für unterschiedliche Dienstkonten in kurzer Zeit, Anforderungen mit RC4 für Dienste, die AES unterstützen, und Anforderungen für Konten, die einen SPN besitzen, aber nicht als Dienst genutzt werden. Keines dieser Muster beweist einen Angriff allein. Wer ein Muster findet, prüft den Kontext: Welches Konto, welche Uhrzeit, welche Systeme?

Schutzmaßnahmen

Die wirksamste Gegenmaßnahme ist ein Group Managed Service Account (gMSA). Sein Kennwort ist lang, zufällig und wird vom System automatisch gewechselt. Es ist für Menschen nicht bekannt, und ein Angriff auf das Kennwort ist praktisch aussichtslos. Die Einrichtung behandelt Band 2, Kapitel 12. Dieses Kapitel zeigt die Umstellung in Übung F.

Wo ein gMSA nicht möglich ist, helfen ein langes, zufälliges Kennwort von mindestens 25 Zeichen, die Erzwingung von AES, die Entfernung ungenutzter SPNs und das Entziehen von Rechten, die das Dienstkonto nicht braucht. Ein Dienstkonto gehört nicht in die Gruppe Domain Admins.

Praxis: Dienstkonten in der Testdomäne prüfen

Die Übungen laufen auf DC01 mit einem Administratorkonto und auf CLIENT01 mit dem Benutzerkonto max.mustermann. Die Dienstkonten entsprechen der Projektbeschreibung: svc_backup ist das Testdienstkonto.

Übung A: Dienstkonten mit SPN identifizieren

Lernziel: alle Benutzerkonten mit einem SPN finden und ihren Zustand bewerten. **Voraussetzungen:** Modul ActiveDirectory, Leserecht.

Befehle zu Übung A

```
PS> Get-ADUser -Filter {ServicePrincipalName -like "*"}
    -Properties ServicePrincipalName, PasswordLastSet, Enabled |
    Select-Object SamAccountName, Enabled, PasswordLastSet,
        ServicePrincipalName
```

Erklärung: Der Filter wählt nur Benutzerkonten mit einem SPN. `PasswordLastSet` zeigt, wann das Kennwort zuletzt geändert wurde. Das ist der wichtigste Hinweis auf Alter und Risiko. **Erwartetes Ergebnis:** Das Konto svc_backup erscheint, sofern du den SPN in Übung C angelegt hast. Ein Computerkonto erscheint nicht, weil es nicht zu dieser Abfrage gehört. **Überprüfung:** Notiere zu jedem Dienstkonto den Zeitpunkt der letzten Kennwortänderung. **Fehleranalyse:** Keine Treffer? Prüfe mit `setspn -L svc_backup` (Übung C), ob der SPN gesetzt ist.

Übung B: Verschlüsselungstyp des Dienstkontos bestimmen

Lernziel: das Attribut auslesen und die Bits richtig deuten. **Aufgabenstellung:** Lies `msDS-SupportedEncryptionTypes` von svc_backup aus.

Befehle zu Übung B

```
PS> Get-ADUser -Identity svc_backup -Properties
    msDS-SupportedEncryptionTypes |
    Select-Object SamAccountName, msDS-SupportedEncryptionTypes
```

Erklärung: Der Wert ist eine Bitmaske. 0x4 bedeutet RC4, 0x8 AES128, 0x10 AES256. Ein Wert von 28 entspricht 0x1C, also RC4, AES128 und AES256 zusammen. Ein leerer Wert bedeutet den Standard des Domänencontrollers. **Erwartetes Ergebnis:** Ein Zahlenwert oder ein leeres Feld. Übersetze den Wert anhand der Bitmaske. **Überprüfung:** Entspricht die Interpretation der Liste aus dem Abschnitt Verschlüsselungstypen? **Fehleranalyse:** Der Wert wirkt unerwartet? Prüfe, ob du den richtigen Konto-Namen verwendest.

Übung C: Dienstname setzen und ein Ticket anfordern

Lernziel: einen SPN einem Dienstkonto zuordnen und als normales Benutzerkonto ein Dienstticket anfordern, so wie es eine Anwendung täte. **Voraussetzungen:** Administratorkonto auf DC01 für den SPN, Benutzerkonto max.mustermann auf CLIENT01 für die Anforderung. **Aufgabenstellung:** Setze den SPN auf DC01 und fordere auf CLIENT01 ein Ticket an.

Befehle zu Übung C

```
PS> setspn -S HTTP/backup.nova.int nova\svc_backup
PS> setspn -L svc_backup
PS> klist purge
PS> klist get HTTP/backup.nova.int
```

Erklärung: `setspn -S` setzt den SPN und prüft vorher, ob er bereits existiert. `setspn -L` listet alle SPNs des Kontos. `klist purge` leert den lokalen Ticketspeicher, damit das folgende Ticket frisch angefordert wird. `klist get` fordert das Dienstticket für den angegebenen SPN an. **Erwartetes Ergebnis:** `setspn -L` zeigt `HTTP/backup.nova.int`. `klist get` meldet, dass ein Ticket für den Dienst angefordert wurde, und ein anschließendes `klist` zeigt es im Ticketspeicher. **Überprüfung:** Das Ticket erscheint im Speicher mit dem SPN und einem Verschlüsselungstyp. **Erklärung zu klist get:** Der Befehl fordert das Ticket für den SPN beim Domänencontroller an. Er stellt keine Verbindung zum Dienst her. Ob der Name zuvor per DNS aufgelöst wird, hängt von der Namensauflösung des Clients ab und ist nicht Teil der Ticketanforderung. **Fehleranalyse:** `klist get` schlägt fehl? Prüfe mit `klist` und `setspn -L`, ob der SPN bekannt ist, und prüfe die Verbindung zum Domänencontroller. **Sicherheitsbetrachtung:** Dieser SPN ist ein Testdienst. Entferne ihn nach dem Projekt mit `setspn -D HTTP/backup.nova.int nova\svc_backup`.

Übung D: Ticketanforderungen im Sicherheitsprotokoll finden

Lernziel: die Ereignisse 4769 auswerten und den Verschlüsselungstyp ablesen. **Voraussetzungen:** Übung C abgeschlossen, Leserecht auf dem Sicherheitsprotokoll von DC01.

Befehle zu Übung D

```
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4769}
    -MaxEvents 10 |
    Format-List TimeCreated, Message
```

Erklärung: `Id=4769` filtert auf Dienstticket-Anforderungen. `Format-List` zeigt Zeit und vollständigen Text. Im Text stehen Dienstname, Konto und `Ticket Encryption Type`. **Erwartetes Ergebnis:** Ein Ereignis mit dem Dienstnamen HTTP/backup.nova.int und dem Konto, das die Anforderung gestellt hat. Das Feld Ticket Encryption Type zeigt den tatsächlich verwendeten Typ. Dieser Wert muss nicht dem Wert aus Übung B entsprechen. Der Wert aus Übung B gibt nur an, welche Typen das Konto unterstützt. **Überprüfung:** Stimmen Zeitpunkt und Konto mit deiner Anforderung aus Übung C überein? Die Zeit ist lokal angezeigt, notiere die Zeitzone. **Fehleranalyse:** Kein Ereignis? Die Überwachung für Kerberos-Dienstticket-Vorgänge ist möglicherweise nicht aktiv. Prüfe die Richtlinien (Kapitel 13).

Übung E: AES für das Dienstkonto erzwingen

Lernziel: den Verschlüsselungstyp auf AES einschränken und die Wirkung im Protokoll prüfen. **Voraussetzungen:** Administratorkonto auf DC01. **Aufgabenstellung:** Setze den Wert auf AES128 und AES256 ohne RC4. Wiederhole danach Übung C und D.

Befehle zu Übung E

```
PS> Set-ADUser -Identity svc_backup -Replace
    @{'msDS-SupportedEncryptionTypes'=24}
PS> klist purge
PS> klist get HTTP/backup.nova.int
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4769}
    -MaxEvents 1 | Format-List TimeCreated, Message
```

Erklärung: Der Wert 24 entspricht 0x18, also AES128 und AES256 zusammen. RC4 ist damit ausgeschlossen. `-Replace` setzt das Attribut vollständig. Das anschließende `klist purge` und `klist get` erzwingen eine neue Anforderung. **Erwartetes Ergebnis:** Das neue Ereignis zeigt einen AES-Typ, etwa 0x12 für AES256. **Überprüfung:** RC4 erscheint im neuen Ereignis nicht mehr. **Fehleranalyse:** Die Anforderung funktioniert

nicht mehr? Ein anderer Client, ein altes System oder eine Anwendung unterstützt AES nicht. Das ist ein Befund: Die Umstellung braucht eine Abstimmung mit dem Betrieb.

Übung F: Dienstkonto durch ein gMSA ersetzen

Lernziel: die wirksamste Gegenmaßnahme in der Testdomäne umsetzen. **Voraussetzungen:** Der KDS-Root-Key muss existieren (Band 2, Kapitel 12). Die Umstellung gilt für einen Testdienst auf SRV01. **Aufgabenstellung:** Lege ein gMSA an, das nur SRV01 nutzen darf, und prüfe es auf dem Server.

Befehle zu Übung F

```
PS> New-ADServiceAccount -Name svc_backup_g -DNSHostName
    svc_backup_g.nova.int
    -PrincipalsAllowedToRetrieveManagedPassword 'SRV01$'
PS> Get-ADServiceAccount -Identity svc_backup_g
```

Erklärung: `New-ADServiceAccount` legt das gMSA an. `-PrincipalsAllowedToRetrieveManagedPassword` bestimmt, welches Computerkonto das Kennwort abrufen darf; das Dollarzeichen kennzeichnet das Computerkonto. Das Kennwort selbst wird nicht angezeigt und nicht verwaltet. Auf SRV01 wird das Konto danach mit `Install-ADServiceAccount -Identity svc_backup_g` installiert. **Erwartetes Ergebnis:** `Get-ADServiceAccount` zeigt das Konto mit der Gruppe der berechtigten Computer. **Überprüfung:** Das gMSA hat keinen SPN, der von einem Benutzer verwaltet wird, und sein Kennwort ist nicht bekannt. **Fehleranalyse:** Fehler beim Anlegen? Prüfe, ob der KDS-Root-Key vorhanden ist und ob der Name 15 Zeichen nicht überschreitet.

Typische Fehler

- Ein Dienstkonto mit SPN und Mitgliedschaft in Domain Admins
- Ein altes Kennwort ohne Änderung seit Jahren
- Ungenutzte SPNs, die niemand mehr prüft
- RC4 bleibt erlaubt, obwohl alle Dienste AES unterstützen
- Ein Angriff wird als normaler Betrieb gewertet, weil niemand die Ereignisse 4769 auswertet

Zusammenfassung

- Kerberoasting nutzt, dass jedes Konto Dienstickets anfordern darf und die Tickets mit dem Kennwort des Dienstkontos verschlüsselt sind.
- Die Erkennung beruht auf Ereignis 4769 mit Dienstname, Konto und Verschlüsselungstyp.
- Ein gMSA oder ein langes, zufälliges Kennwort mit AES-Erzwingung ist die wirksamste Gegenmaßnahme.
- Dienstkonten gehören nicht in privilegierte Gruppen.

Kontrollfragen

1. Welche Bedingung muss ein Konto erfüllen, damit ein Kerberoasting-Angriff möglich ist? (leicht)
2. Was bedeutet der Verschlüsselungswert 0x17 in einem Ereignis 4769? (leicht)
3. Warum fällt Kerberoasting im normalen Betrieb so selten auf? (mittel)
4. Die Übung E setzt AES erzwungen. Welche Anwendung könnte danach ausfallen, und wie prüfst du es? (mittel)
5. Ein Dienstkonto hat ein Kennwort, das seit sechs Jahren unverändert ist, und ist Mitglied von Domain Admins. Welche Risiken entstehen, und welche Maßnahmen priorisierst du? (schwer)

Lösungshinweise: 1. Ein aktiviertes Domänenkonto mit einem zugeordneten SPN; keine Administratorrechte sind nötig. 2. Die Tickets sind mit RC4 verschlüsselt. 3. Die Anforderungen sehen aus wie normaler Dienstbetrieb, und ohne Auswertung der Ereignisse fehlt der Kontext. 4. Ein Client oder eine Anwendung, die nur RC4 kann. Prüfbar über die Ereignisse 4769 und die Rückmeldungen der Anwendung. 5. Ein altes Kennwort kann geprüft werden, und die Gruppe Domain Admins gibt dem Konto Rechte über die ganze Domäne. Priorität haben die Entfernung aus Domain Admins und die Umstellung auf ein gMSA oder ein langes, zufälliges Kennwort.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] SPNs und Dienstkonten in deiner Domäne findest und bewertest,

[ ] den Verschlüsselungstyp über `msDS-SupportedEncryptionTypes` deutest,

[ ] Ereignis 4769 auswertest und den Verschlüsselungstyp abliest,

[ ] eine Umstellung auf AES oder gMSA umsetzt und ihre Wirkung prüfst.

Kapitel 6: AS-REP Roasting

Lernziele

- Du erklärst, welche Schutzfunktion die Kerberos-Vorauthentifizierung hat und was ihr Fehlen bedeutet.
- Du findest Konten mit deaktivierter Vorauthentifizierung und bewertest ihr Risiko.
- Du korrigierst die Konfiguration und dokumentierst den Vorher-Nachher-Zustand.

WARNUNG – Sicherheitsrisiko

Dieses Kapitel erklärt das Prinzip des Angriffs und zeigt, wie er sich verhindern lässt. Es enthält keine Angriffsschritte. Die Übungen prüfen Konfigurationen und legen ein Testkonto an, dessen Einstellung du danach zurücksetzt.

Was ist AS-REP Roasting?

AS-REP Roasting ist ein Angriff auf Benutzerkonten, für die Kerberos keine Vorauthentifizierung verlangt. Ohne diese Prüfung antwortet der Domänencontroller auf eine Anfrage für ein solches Konto mit einer Nachricht, die mit dem Kennwort des Kontos verschlüsselt ist. Wer die Nachricht empfängt, kann sie außerhalb des Netzes prüfen. Die Technik steht im MITRE-ATT&CK-Katalog unter T1558.004.

Der Name verweist auf die Antwort des Domänencontrollers, den AS-REP. Er ist der Teil der Kerberos-Anmeldung, der ein Ticket-Granting-Ticket ausstellt.

Zweck der Vorauthentifizierung

Bei der normalen Anmeldung beweist der Client zuerst, dass er das Kennwort kennt, bevor der Domänencontroller antwortet. Er sendet einen Zeitstempel, der mit dem Kennwort verschlüsselt ist. Nur ein Client mit dem richtigen Kennwort kann diesen Zeitstempel erzeugen. Der Domänencontroller prüft ihn und antwortet erst dann. Damit wird verhindert, dass ein Unbefugter eine verschlüsselte Antwort auf Vorrat erhält.

Warum deaktivierte Vorauthentifizierung problematisch ist

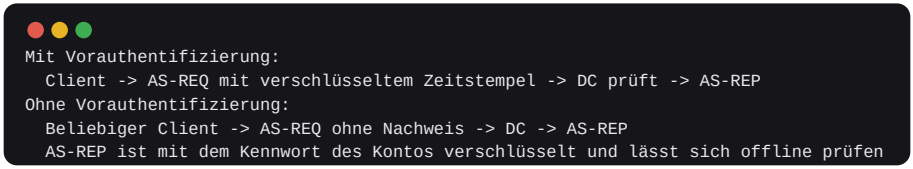
Die Einstellung „Kerberos-Vorauthentifizierung ist nicht erforderlich“ entfernt diesen Schritt. Das Konto kann dann von jedem Client im Netz angefragt werden, ohne Kennwort. Die Einstellung wird manchmal gesetzt, um Kompatibilität mit alten Systemen zu erreichen, oder aus Versehen bei einer Massenänderung. Sie ist ein Fehler, sobald ein Konto auf diese Weise ungeschützt ist.

AS-REQ und AS-REP

Die erste Nachricht einer Kerberos-Anmeldung ist die Anforderung AS-REQ, die der Client an den Domänencontroller sendet. Die Antwort heißt AS-REP. Mit Vorauthentifizierung enthält die Anforderung den verschlüsselten Zeitstempel. Ohne sie fehlt er, und der Domänencontroller antwortet trotzdem. Der Unterschied liegt also in einer einzigen Prüfung, die fehlt.

Angriffsprinzip

Diagramm 6.1: AS-REP Roasting (vereinfacht)



Der entscheidende Schutz ist die Vorauthentifizierung. Die Verschlüsselung selbst ist korrekt. Ein gutes Kennwort macht das Offline-Prüfen praktisch wirkungslos, deshalb ist die Kombination aus fehlender Vorauthentifizierung und schwachem Kennwort gefährlich.

Voraussetzungen

Der Angreifer braucht Netzwerkzugang zu einem Domänencontroller und den Namen eines betroffenen Kontos. Auf der Seite der Domäne braucht es nur die falsche Einstellung. Kein Administratorrecht ist nötig, und deshalb ist die Prüfung dieser Einstellung ein Routineschritt jeder Domänenanalyse.

Auswirkungen

Ein kompromittiertes Konto bringt die Rechte mit, die es in der Domäne hat. Bei einem normalen Benutzerkonto ist der Schaden begrenzt, bei einem Konto mit Rechten auf Servern oder in Gruppen mit Verwaltungsrechten wird der Angriff zum Einstieg in die Domäne. Die Auswirkung hängt also ausschließlich davon ab, was das Konto darf.

Erkennung

Eine Anforderung ohne Vorauthentifizierung erzeugt das Ereignis 4768 (Kerberos-Ticket-Granting-Ticket angefordert) im Sicherheitsprotokoll des Domänencontrollers. Das Feld Pre-Authentication Type zeigt den Typ der Vorauthentifizierung. Der Wert 0 bedeutet, dass keine Vorauthentifizierung stattfand. Normale Anmeldungen erzeugen den Wert 2 für Zeitstempel.

Die Erkennung beruht also auf zwei Schritten: die Konfiguration der Konten prüfen, und Anforderungen mit dem Typ 0 im Protokoll suchen. Jeder Treffer mit dem Typ 0 ist ein Befund, der untersucht werden muss. Für die Bewertung gehören außerdem der Ergebniscode des Vorgangs, das betroffene Konto und der zeitliche Zusammenhang mit anderen Vorgängen dazu. Ein einzelnes Ereignis beweist keinen Angriff; Treffer werden mit Häufung und Kontext bewertet.

Schutzmaßnahmen

Die Vorauthentifizierung muss für alle Konten aktiv sein. Wo ein altes System sie nicht unterstützt, ist das Risiko zu dokumentieren und das Konto zu isolieren, mit einem langen, zufälligen Kennwort und ohne Rechte über das Nötige hinaus. Bei Dienstkonten hilft die Umstellung auf gMSA aus Kapitel 5.

Praxis: Konten mit deaktivierter Vorauthentifizierung finden und korrigieren

Die Übungen laufen auf DC01 mit einem Administratorkonto. Das Testkonto testpreauth wird nur für diese Übung angelegt und danach wieder entfernt.

Übung A: Betroffene Konten finden

Lernziel: alle Benutzerkonten mit deaktivierter Vorauthentifizierung in der Domäne bestimmen. **Voraussetzungen:** Modul ActiveDirectory, Leserecht.

Befehle zu Übung A

```
PS> Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true}
    -Properties DoesNotRequirePreAuth |
    Select-Object SamAccountName, Enabled, DoesNotRequirePreAuth
```

Erklärung: Das Attribut `DoesNotRequirePreAuth` zeigt die Einstellung als Wahrheitswert. Der Filter wählt alle Konten mit dem Wert `$true`. Die Ausgabe enthält auch deaktivierte Konten, die du getrennt bewerten musst. **Erwartetes Ergebnis:** In einer sauber konfigurierten Domäne erscheint kein Konto. Jedes gefundene Konto ist ein Befund. **Überprüfung:** Notiere Konto, Status und Zweck. Ein Konto ohne erkennbaren Zweck ist ein Kandidat für die Entfernung. **Fehleranalyse:** Die Abfrage liefert zu viele Treffer? Prüfe, ob die Domäne Altsysteme enthält, und dokumentiere sie als Ausnahme.

Übung B: Testkonto mit deaktivierter Vorauthentifizierung anlegen

Lernziel: die Einstellung gezielt setzen, damit die folgenden Übungen einen Fall haben, an dem sie arbeiten. **Voraussetzungen:** Administratorkonto auf DC01. **Aufgabenstellung:** Lege das Testkonto testpreauth an und deaktiviere für dieses Konto die Vorauthentifizierung.

Befehle zu Übung B

```
PS> New-ADUser -Name testpreauth -SamAccountName testpreauth
    -Enabled $true `
    -AccountPassword (Read-Host -AsSecureString "Kennwort für
        testpreauth")
PS> Set-ADAccountControl -Identity testpreauth
    -DoesNotRequirePreAuth $true
```

```
PS> Get-ADUser -Identity testpreauth -Properties
    DoesNotRequirePreAuth | Select-Object SamAccountName,
    DoesNotRequirePreAuth
```

Erklärung: `New-ADUser` legt das Konto an. `Read-Host -AsSecureString` fragt das Kennwort ab, ohne es im Befehl oder in der Historie zu speichern. `Set-ADAccountControl` setzt das Flag für die Vorauthentifizierung. Die letzte Zeile prüft das Ergebnis. **Erwartetes Ergebnis:** Der Wert `DoesNotRequirePreAuth` ist `True`. **Überprüfung:** Übung A zeigt das Konto nun als betroffen. **Fehleranalyse:** Das Kennwort erfüllt die Richtlinie nicht? Die Fehlermeldung nennt die fehlenden Anforderungen. Wähle ein längeres Kennwort. **Sicherheitsbetrachtung:** Dieses Konto ist eine bewusst falsche Konfiguration in deiner Testdomäne. Entferne es nach Übung E.

Übung C: Eine Anmeldung mit Vorauthentifizierung im Protokoll lesen

Lernziel: den Normalfall kennenlernen, damit der Ausnahmefall im Protokoll erkennbar wird. **Voraussetzungen:** Anmeldung von testpreauth an CLIENT01, Leserecht auf dem Sicherheitsprotokoll von DC01. **Aufgabenstellung:** Melde dich an CLIENT01 mit testpreauth an, lies auf DC01 das Ereignis 4768 aus.

Befehle zu Übung C

```
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4768}
    -MaxEvents 5 |
    Format-List TimeCreated, Message
```

Erklärung: `Id=4768` filtert auf Anforderungen eines Ticket-Granting-Tickets. Im Text steht der Kontoname und der Wert von `Pre-Authentication Type`. **Erwartetes Ergebnis:** Der Ereignistext für testpreauth enthält einen Wert im Feld Pre-Authentication Type. Welcher Wert erscheint, hängt vom anfragenden Client ab, und das Protokoll zeigt es dir. Notiere den Wert wörtlich. Eine einzelne normale Anmeldung beweist weder, dass das Konto sicher ist, noch, dass es ungeschützt ist. **Überprüfung:** Der Zeitpunkt und der Kontoname stimmen mit deiner Anmeldung überein. **Fehleranalyse:** Kein Ereignis? Die Überwachung der Kerberos-Anmeldung ist

möglicherweise nicht aktiv. Prüfe die Richtlinie in Kapitel 13. **Hinweis:** Dieses Buch zeigt nur die Sicht des normalen Clients. Eine Anfrage ohne Vorauthentifizierung ist mit den Bordmitteln von Windows nicht erzeugbar. Die Erkennung beruht deshalb auf der Auswertung des Feldes und auf der Konfigurationsprüfung aus Übung A.

Übung D: Einstellung korrigieren

Lernziel: die Konfiguration auf den richtigen Zustand zurücksetzen und die Korrektur belegen. **Aufgabenstellung:** Aktiviere die Vorauthentifizierung für testpreauth und prüfe, dass das Konto nicht mehr als betroffen erscheint.

Befehle zu Übung D

```
PS> Set-ADAccountControl -Identity testpreauth
    -DoesNotRequirePreAuth $false
PS> Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true}
    -Properties DoesNotRequirePreAuth | Select-Object
    SamAccountName
```

Erklärung: Der Wert `$false` schaltet die Ausnahme ab. Die zweite Abfrage aus Übung A zeigt die verbleibenden betroffenen Konten; testpreauth ist nicht mehr dabei. **Erwartetes Ergebnis:** Die Liste enthält testpreauth nicht mehr. **Überprüfung:** Halte den Vorher-Nachher-Zustand im Protokoll fest, mit Zeit und Befehl. **Fehleranalyse:** Das Konto erscheint weiterhin? Prüfe, ob der Befehl ohne Fehlermeldung durchlief und ob die Abfrage denselben Filter verwendet.

Übung E: Kennwortrichtlinie prüfen und Testkonto entfernen

Lernziel: die Stärke der Kennwörter als zweite Verteidigungslinie prüfen und die Testumgebung aufräumen. **Aufgabenstellung:** Lies die Standard-Kennwortrichtlinie der Domäne und entferne danach das Testkonto.

Befehle zu Übung E

```
PS> Get-ADDefaultDomainPasswordPolicy | Select-Object
    MinPasswordLength, PasswordHistoryCount, LockoutThreshold
PS> Remove-ADUser -Identity testpreauth -Confirm:$false
```

Erklärung: Die Richtlinie zeigt die Mindestlänge und die Sperrschwelle. Eine kurze Mindestlänge macht das Offline-Prüfen eines abgefangenen Antwortwertes deutlich leichter, deshalb gehört sie zur Analyse. `Remove-ADUser` löscht das Testkonto; `-Confirm:$false` unterdrückt die Rückfrage. **Erwartetes Ergebnis:** Die Mindestlänge steht als Zahl in der Ausgabe und lässt sich gegen deine Richtlinie vergleichen. Das Testkonto ist danach nicht mehr vorhanden. **Überprüfung:** `Get-ADUser -Identity testpreauth` meldet, dass das Konto nicht existiert. **Fehleranalyse:** Die Mindestlänge liegt unter dem Wert, den deine Richtlinie vorgibt? Notiere das als Befund. Die Umstellung ist eine Entscheidung für die Gesamtdomäne und muss mit dem Betrieb abgestimmt werden.

Typische Fehler

- Die Einstellung wird bei einer Massenänderung aus Kompatibilitätsgründen gesetzt und nie zurückgenommen
- Ein Konto mit deaktivierter Vorauthentifizierung hat Rechte über das Nötige hinaus
- Ein kurzes Kennwort macht das Offline-Prüfen einfach
- Das Ergebnis der Konfigurationsprüfung wird nicht dokumentiert

> **Zusammenfassung**
>
> - Die Vorauthentifizierung verhindert, dass der Domänencontroller eine verschlüsselte Antwort an Unbefugte ausgibt.
> - Deaktivierte Vorauthentifizierung ist eine Fehlkonfiguration und wird über `DoesNotRequirePreAuth` gefunden.
> - Ereignis 4768 mit Pre-Authentication Type 0 ist der Befund im Protokoll.
> - Die Korrektur ist einfach, ihre Wirkung muss dokumentiert werden.

Kontrollfragen

1. Welche Aufgabe erfüllt die Vorauthentifizierung? (leicht)
2. Welches Attribut zeigt in Active Directory, ob ein Konto ohne Vorauthentifizierung angefragt werden kann? (leicht)
3. Warum ist das Kennwort des betroffenen Kontos für den Schutz entscheidend? (mittel)

4. Das Konto svc_legacy ist betroffen und hat keinen erkennbaren Zweck. Welche Schritte priorisierst du? (mittel)

5. Im Protokoll erscheint Ereignis 4768 mit Pre-Authentication Type 2 für ein Konto, das als betroffen markiert ist. Was bedeutet das, und was bedeutet es nicht? (schwer)

Lösungshinweise: 1. Sie beweist dem Domänencontroller, dass der Client das Kennwort kennt, bevor eine Antwort ausgegeben wird. 2. `DoesNotRequirePreAuth`. 3. Ohne Vorauthentifizierung kann eine verschlüsselte Antwort auf Vorrat erhalten werden, und nur ein schwaches Kennwort lässt sich dann offline prüfen. 4. Zuerst prüfen, ob das Konto genutzt wird, dann die Einstellung zurücknehmen und das Kennwort erneuern. Bei Abhängigkeit ein Ausnahmekonzept mit Isolation. 5. Der normale Client hat die Vorauthentifizierung verwendet. Das bedeutet nicht, dass das Konto sicher ist, weil die Konfiguration trotzdem falsch ist und Anfragen ohne Zeitstempel möglich bleiben.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die Rolle der Vorauthentifizierung erklären kannst,
- [ ] betroffene Konten mit `DoesNotRequirePreAuth` findest,
- [ ] Ereignis 4768 und sein Feld Pre-Authentication Type deutest,
- [ ] die Korrektur umsetzt und ihre Wirkung dokumentierst.

Kapitel 7: Pass-the-Hash und Pass-the-Ticket

Lernziele

- Du erklärst, warum ein NTLM-Hash oder ein Kerberos-Ticket für eine Anmeldung genügt, ohne dass das Kennwort bekannt ist.
- Du unterscheidest Pass-the-Hash und Pass-the-Ticket und benennst die Voraussetzungen beider.
- Du prüfst die Schutzmechanismen Credential Guard, Protected Users und das Tiering-Modell in der Testdomäne.

WARNUNG – Sicherheitsrisiko

Dieses Kapitel erklärt, wo Anmeldeinformationen liegen und warum ihre Weitergabe funktioniert. Es enthält keine Anleitung zum Auslesen von Anmeldeinformationen. Die Übungen werten Ereignisse aus und prüfen Schutzfunktionen.

Die Ausgangslage: Anmeldeinformationen im Speicher

Wer an einem Windows-Computer angemeldet ist, hat Anmeldeinformationen im Speicher des Systems liegen. Der Sicherheitsdienst LSASS hält dafür Daten vor, damit Dienste und Zugriffe ohne neue Kennworteingabe funktionieren. Welche Daten dort liegen, hängt von der Art der Anmeldung ab. Ein Administrator, der sich an einem Arbeitsplatz anmeldet, hinterlässt dort in der Regel mehr als ein gewöhnlicher Benutzer.

Dieser Umstand ist die Grundlage beider Angriffe. Der Angreifer muss nicht das Kennwort kennen, sondern nur einen Wert, der den Anmeldeprozess ersetzt.

NTLM-Hash-Grundlagen

Der NTLM-Hash ist ein Abbild des Kennworts, das bei NTLM-Anmeldungen als Schlüssel dient. Der Hash liegt auf dem Domänencontroller in der Datenbank und auf den Systemen, an denen sich das Konto angemeldet hat. Wer den Hash besitzt, kann die NTLM-Anmeldung durchführen, ohne das Kennwort zu kennen. Band 3 der Windows-Security-Reihe behandelt den Hash und seine Bedeutung in Kapitel 10 ausführlich.

Pass-the-Hash

Pass-the-Hash bezeichnet eine NTLM-Anmeldung, bei der statt des Kennworts der Hash verwendet wird. Der Zielserver prüft nur, ob der Client die Herausforderung mit dem richtigen Schlüssel beantwortet, und das gelingt auch mit dem Hash.

Diagramm 7.1: Pass-the-Hash (Grundprinzip)

```
Zugriff auf einen Rechner mit Anmeldeinformationen eines Kontos
  -> Hash des Kontos liegt im Speicher
  -> NTLM-Anmeldung an einem anderen Server mit diesem Hash
  -> Server prüft die Antwort auf die Herausforderung, nicht das Kennwort
  -> Anmeldung gelingt mit den Rechten des Kontos
```

Pass-the-Hash funktioniert nur, wenn NTLM akzeptiert wird. Kerberos-only-Dienste oder Konten in der Schutzgruppe Protected Users lehnen sie ab. Die Einschränkung von NTLM (Kapitel 12) ist deshalb die direkte Gegenmaßnahme.

Kerberos-Tickets

Kerberos arbeitet mit Tickets. Nach einer Anmeldung besitzt der Client ein Ticket-Granting-Ticket (TGT), mit dem er Dienstickets anfordert. Diese Tickets liegen im Speicher, solange die Sitzung besteht. Sie haben eine begrenzte Gültigkeit, die in der Domänenrichtlinie festgelegt ist.

Pass-the-Ticket

Pass-the-Ticket bezeichnet die Wiederverwendung eines Kerberos-Tickets auf einem anderen System. Das Ticket beweist dem Dienst die Identität des Kontos, solange es gültig ist. Der Angreifer braucht das Kennwort nicht und auch keinen Hash, sondern nur das Ticket.

Unterschiede

Pass-the-Hash nutzt einen dauerhaften Wert, der solange gilt, bis das Kennwort geändert wird. Pass-the-Ticket nutzt einen zeitlich begrenzten Nachweis. Die Gegenmaßnahmen unterscheiden sich entsprechend: Gegen Hashes helfen das Verbot von NTLM und der Schutz des Speichers, gegen Tickets vor allem kurze Gültigkeiten und das Verhindern des Zugriffs auf fremde Sitzungen.

Voraussetzungen

Beide Angriffe setzen einen Zugriff auf einen Rechner voraus, auf dem ein interessantes Konto angemeldet ist. Dazu kommen für Pass-the-Hash die Akzeptanz von NTLM am Ziel und für Pass-the-Ticket ein gültiges Ticket. Die wichtigste Voraussetzung ist in der Praxis die Verwaltung der Rechte: Ein lokaler Administrator auf einem Arbeitsplatz kann oft Sitzungen fremder Konten sehen, die dort angemeldet sind.

Angriffsablauf

Der Ablauf besteht aus vier Phasen: Zugriff auf einen Rechner, Erlangung der Anmeldeinformationen aus dem Speicher, Weitergabe an ein Zielsystem und Nutzung der Rechte des Kontos. Das Entscheidende ist die dritte Phase. Ohne Weitergabe bleibt der Zugriff auf den ersten Rechner begrenzt.

Mögliche Auswirkungen

Die Auswirkung hängt von dem Konto ab, dessen Anmeldeinformationen erbeutet wurden. Ein Konto mit Rechten auf Servern oder in Verwaltungsgruppen erlaubt die Bewegung durch die Domäne. Ein Administrator, dessen Sitzung auf einem Arbeitsplatz liegt, ist ein häufiger Weg zu weitreichenden Rechten. Deshalb sind Tiering und Trennung der Administratorkonten (Kapitel 12) zentral.

Erkennung

Für NTLM-Anmeldungen am Domänencontroller gibt es das Ereignis 4776, das die Prüfung der Anmeldedaten protokolliert. Anmeldungen an Servern erzeugen Ereignisse 4624 mit dem Feld Authentication Package, das NTLM oder Kerberos angibt. Auffällig ist eine NTLM-Anmeldung eines Administrators an Systemen, an denen er normalerweise per Kerberos arbeitet, oder eine Anmeldung von einem Rechner, der dafür nicht vorgesehen ist.

Bei Pass-the-Ticket ist die Erkennung schwieriger, weil das Ticket dem Dienst gültig erscheint. Hinweise sind Anmeldungen desselben Kontos von zwei Rechnern kurz nacheinander, ungewöhnliche Quellen für Kerberos-Anmeldungen und Tickets mit außergewöhnlicher Gültigkeit.

Schutzmechanismen

Credential Guard isoliert die Geheimnisse der Anmeldung in einer geschützten Umgebung, die der normale Betriebssystemzugriff nicht erreicht. Die Funktion erfordert passende Hardware und Virtualisierungsunterstützung, und sie lässt sich nicht auf jedem System aktivieren.

Die Schutzgruppe Protected Users schränkt Konten ein: Mitglieder dürfen sich nicht per NTLM anmelden, Kerberos verwendet keine schwachen Verfahren, und die Lebensdauer der Tickets ist begrenzt. Für Administratorkonten ist das eine sinnvolle Grundeinstellung.

Das Tiering-Modell teilt Administration in Ebenen. Tier 0 umfasst Domänencontroller und Identitätsdienste, Tier 1 Server, Tier 2 Arbeitsplätze. Ein Konto der höheren Ebene meldet sich nie auf einer niedrigeren an. So

bleibt ein Hash von Tier 2 wertlos für Tier 0.

Least Privilege bedeutet, dass jedes Konto nur die Rechte besitzt, die es braucht. Das verringert, was ein erbeuteter Hash oder ein Ticket erlaubt.

Praxis: Anmeldeereignisse und Schutzfunktionen prüfen

Die Übungen laufen auf DC01 und CLIENT01. Sie lesen Ereignisse und prüfen Einstellungen, sie verändern nur die Mitgliedschaft in der Schutzgruppe.

Übung A: NTLM-Prüfungen am Domänencontroller auswerten

Lernziel: die NTLM-Prüfungen der Domäne sichtbar machen.
Voraussetzungen: Leserecht auf dem Sicherheitsprotokoll von DC01.

Befehle zu Übung A

```
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4776}
    -MaxEvents 10 |
    Format-List TimeCreated, Message
```

Erklärung: Ereignis 4776 zeigt, dass der Domänencontroller die Anmeldedaten eines Kontos über NTLM geprüft hat. Im Text stehen Kontoname, Quellrechner und Ergebnis. **Erwartetes Ergebnis:** Einträge für die Anmeldungen, die du in dieser Sitzung durchgeführt hast, mit dem Ergebnis Erfolg oder Fehler. **Überprüfung:** Notiere, wie viele NTLM-Prüfungen du in einer Stunde siehst. Viele NTLM-Prüfungen in einer normalen Domäne sind ein Hinweis, dass Dienste NTLM verwenden, das eigentlich nicht nötig ist. **Fehleranalyse:** Kein Ereignis? Die Überwachung der Anmeldeprüfung ist möglicherweise nicht aktiv (Kapitel 13).

Übung B: NTLM-Anmeldungen an einem Server finden

Lernziel: Anmeldungen mit dem Authentifizierungspaket NTLM von Kerberos-Anmeldungen unterscheiden. **Voraussetzungen:** Leserecht auf dem Sicherheitsprotokoll von SRV01 oder einem anderen Server.

Befehle zu Übung B

```
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624}
```

```
    -MaxEvents 50 |
    Where-Object { $_.Message -match 'Authentication
        Package:\s+NTLM' } |
    Format-List TimeCreated, Message
```

Erklärung: Der Filter wählt Anmeldungen mit dem Authentifizierungspaket NTLM. Kerberos-Anmeldungen tragen dort den Wert Kerberos. Die Anfrage wertet nur die letzten 50 Ereignisse aus. **Erwartetes Ergebnis:** Eine Liste der NTLM-Anmeldungen. Für ein Konto mit Kerberos-Zugriff sollte diese Liste leer sein. **Überprüfung:** Prüfe, ob eine NTLM-Anmeldung eines Kontos auftaucht, das in dieser Sitzung über Kerberos angemeldet war. **Fehleranalyse:** Die Liste ist leer, obwohl du NTLM erwartest? Erhöhe die Anzahl der Ereignisse, oder prüfe mit `-MaxEvents 500`.

Übung C: Protected Users prüfen und ein Testkonto aufnehmen

Lernziel: die Schutzgruppe kennen und die Wirkung der Mitgliedschaft nachvollziehen. **Voraussetzungen:** Administratorkonto auf DC01, ein Testkonto testschutz. Lege es wie in Kapitel 6, Übung B an, aber ohne die Einstellung zur Vorauthentifizierung. **Aufgabenstellung:** Lies die Mitglieder der Gruppe Protected Users und nimm testschutz auf.

Befehle zu Übung C

```
PS> Get-ADGroupMember -Identity "Protected Users" | Select-Object
    Name
PS> Add-ADGroupMember -Identity "Protected Users" -Members
    testschutz
PS> Get-ADGroupMember -Identity "Protected Users" | Select-Object
    Name
```

Erklärung: Die erste Abfrage zeigt den Ausgangszustand. `Add-ADGroupMember` nimmt das Testkonto auf. Die Wirkung tritt bei neuen Anmeldungen ein, nicht bei bestehenden Sitzungen. **Erwartetes Ergebnis:** testschutz erscheint in der zweiten Liste. Eine NTLM-Anmeldung dieses Kontos scheitert danach. **Überprüfung:** Melde dich mit testschutz an, und versuche, die Wirkung über Übung B nachzuvollziehen: Eine NTLM-Anmeldung dieses Kontos darf nicht mehr im Protokoll erscheinen. **Fehleranalyse:** Die Gruppe existiert nicht? Sie ist ab Windows Server 2012

R2 vorhanden. Prüfe die Domänenfunktionsebene.
Sicherheitsbetrachtung: Nimm nur Testkonten auf. Für Administratorkonten gilt diese Schutzgruppe nur nach einer Prüfung, weil bestimmte Dienste sie nicht vertragen.

Übung D: Credential Guard prüfen

Lernziel: feststellen, ob Credential Guard auf einem Rechner aktiv ist.
Voraussetzungen: CLIENT01, Windows 11.

Befehle zu Übung D

```
PS> Get-CimInstance -ClassName Win32_DeviceGuard -Namespace
    root\Microsoft\Windows\DeviceGuard |
    Select-Object SecurityServicesRunning
```

Erklärung: Die Klasse `Win32_DeviceGuard` meldet die laufenden Sicherheitsdienste der virtualisierungsbasierten Sicherheit. Die Eigenschaft `SecurityServicesRunning` enthält eine Liste mit Zahlen für die einzelnen Dienste. Die Zuordnung der Zahl zu Credential Guard prüfst du in der Microsoft-Dokumentation für deine Version, bevor du die Ausgabe deutest. **Erwartetes Ergebnis:** Auf einem Rechner ohne Credential Guard fehlt die entsprechende Zahl. Auf einem Rechner mit aktivem Credential Guard erscheint sie. **Überprüfung:** Notiere das Ergebnis mit Rechnername und Version. **Fehleranalyse:** Die Abfrage liefert keinen Wert? Die Virtualisierungsunterstützung ist möglicherweise nicht eingeschaltet, oder die Funktion ist nicht konfiguriert.

Übung E: Tiering-Verstöße finden

Lernziel: Administratorkonten identifizieren, die auf niedrigeren Ebenen angemeldet sind. **Aufgabenstellung:** Lies die Mitglieder von Domain Admins und prüfe in den Anmeldeereignissen von CLIENT01, ob diese Konten dort angemeldet waren.

Befehle zu Übung E

```
PS> Get-ADGroupMember -Identity "Domain Admins" | Select-Object
    SamAccountName
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624}
    -MaxEvents 100 |
    Where-Object { $_.Message -match 'Logon Type:\s+(2|10)' } |
```

```
Format-List TimeCreated, Message
```

Erklärung: Der erste Befehl listet die Administratorkonten. Der zweite sucht interaktive Anmeldungen (Typ 2) und Remotedesktopanmeldungen (Typ 10). Auf einem Arbeitsplatz sollte kein Domänenadministrator interaktiv angemeldet sein. **Erwartetes Ergebnis:** Eine Liste, die für jedes Administratorkonto auf CLIENT01 zeigt, ob es angemeldet war. **Überprüfung:** Jeder Treffer ist ein Verstoß gegen das Tiering-Modell und wird im Bericht als Befund aufgenommen. **Fehleranalyse:** Keine Treffer? Prüfe, ob das Administratorkonto in deiner Testumgebung überhaupt auf CLIENT01 angemeldet war. Ein leeres Ergebnis ist für die Umgebung in Ordnung, aber nicht für die Aussage über alle Rechner.

Typische Fehler

- NTLM wird aus Gewohnheit zugelassen, obwohl kein Dienst es braucht
- Administratorkonten melden sich an Arbeitsplätzen an
- Die Schutzgruppe Protected Users wird ohne Prüfung auf alle Administratorkonten angewendet, und Dienste brechen aus
- Credential Guard wird angenommen, ohne die Konfiguration zu prüfen

> **Zusammenfassung**
>
> - Pass-the-Hash und Pass-the-Ticket nutzen Anmeldeinformationen, die im Speicher liegen, ohne dass das Kennwort bekannt sein muss.
> - Der entscheidende Schritt ist die Weitergabe. Verhindert man sie, bleibt der Zugriff begrenzt.
> - Credential Guard, Protected Users, das Tiering-Modell und Least Privilege sind die Gegenmaßnahmen.
> - Erkennung beruht auf Ereignissen 4776 und 4624 und auf Mustern, die zum Kontext passen.

Kontrollfragen

1. Was ersetzt ein Angreifer beim Pass-the-Hash durch das Kennwort? (leicht)

2. Warum unterscheidet sich die Gültigkeitsdauer eines Hashes von der eines Tickets? (leicht)

3. Warum schützt das Tiering-Modell auch dann, wenn ein Konto erbeutet wird? (mittel)

4. Ein Administrator meldet sich täglich an einem Arbeitsplatz an. Welche Befunde entstehen, und welche Maßnahme hat Vorrang? (mittel)

5. Ein Konto erscheint in einer NTLM-Anmeldung, obwohl alle Dienste Kerberos unterstützen. Welche Erklärungen sind möglich, und wie prüfst du sie? (schwer)

Lösungshinweise: 1. Den Hash, den der Zielserver als Schlüsselnachweis akzeptiert. 2. Ein Hash gilt, bis das Kennwort geändert wird; ein Ticket nur bis zu seinem Ablaufzeitpunkt. 3. Ein erbeuteter Hash einer niedrigeren Ebene erlaubt keine Anmeldung an Systemen der höheren Ebene, weil die Konten dort nicht angemeldet sind und die Trennung verhindert, dass ihre Anmeldedaten dort liegen. 4. Ein Verstoß gegen das Tiering-Modell. Vorrang hat die Trennung in ein separates Administratorkonto, das nur auf Tier 0 und Tier 1 eingesetzt wird. 5. Mögliche Ursachen sind eine Anwendung, die NTLM fest verwendet, eine Anmeldung per IP-Adresse statt Name, oder eine Anmeldung über einen Dienst ohne Kerberos-Unterstützung. Prüfen lässt sich das über das Feld der Anmeldung, den verwendeten Zielnamen und die Konfiguration der Anwendung.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] Pass-the-Hash und Pass-the-Ticket sauber unterscheidest,
- [ ] NTLM-Anmeldungen in den Ereignissen findest,
- [ ] die Schutzfunktionen Credential Guard, Protected Users und Tiering prüfst,
- [ ] Verstöße gegen das Tiering-Modell im Protokoll erkennst.

Kapitel 8: Active-Directory-Rechte und Privilege Escalation

Lernziele

- Du erklärst, wie Berechtigungen in Active Directory als ACL, DACL, SACL und ACE aufgebaut sind.
- Du erkennst kritische Rechte wie GenericAll, WriteDACL und WriteOwner und ihre Wirkung.
- Du findest vererbte und direkte Berechtigungen und korrigierst eine Fehlkonfiguration mit Sicherung.

WARNUNG – Sicherheitsrisiko

Dieses Kapitel erklärt Berechtigungen und die Wege, auf denen sie sich zu Rechteerweiterungen verketten. Die Übungen lesen Berechtigungen aus und ändern in der Testdomäne nur einen Testeintrag, nach vorheriger Sicherung.

Berechtigungen in Active Directory

Jedes Objekt im Verzeichnis hat eine Zugriffssteuerungsliste. Sie legt fest, wer was mit dem Objekt tun darf. Die Liste besteht aus Einträgen, den Access Control Entries (ACE). Jeder Eintrag nennt einen Sicherheitsprinzipal, also ein Konto oder eine Gruppe, ein Recht und ob es erlaubt oder verweigert wird.

Die Begriffe sind ähnlich, aber nicht gleich:

- **ACL** (Access Control List): die gesamte Liste eines Objekts
- **DACL** (Discretionary ACL): die Liste, die Zugriffe erlaubt oder verweigert
- **SACL** (System ACL): die Liste, die festlegt, welche Zugriffe protokolliert werden
- **ACE** (Access Control Entry): ein einzelner Eintrag in einer dieser Listen

Für die Analyse ist die DACL am wichtigsten, weil sie bestimmt, wer ein Objekt ändern darf. Die SACL zeigt, ob Änderungen überhaupt protokolliert

werden, und ist die Grundlage der Erkennung in Kapitel 13.

Kritische Rechte

Einige Rechte sind so mächtig, dass ihr Besitz einem vollständigen Zugriff auf das Objekt entspricht:

- **GenericAll**: alle Rechte auf dem Objekt, einschließlich Änderung der Mitgliedschaft und des Kennworts.
- **GenericWrite**: Schreibrechte auf viele Attribute, darunter solche, die Dienste oder Anmeldung beeinflussen.
- **WriteDACL**: die Berechtigung, die DACL des Objekts zu ändern. Wer sie besitzt, kann sich selbst das Recht geben, alles andere zu tun.
- **WriteOwner**: die Berechtigung, den Eigentümer des Objekts zu ändern. Der Eigentümer kann danach die DACL ändern, deshalb ist dieses Recht ebenfalls kritisch.
- **Reset Password** (das erweiterte Recht zum Zurücksetzen des Kennworts): erlaubt, das Kennwort eines anderen Kontos zu setzen, ohne das alte zu kennen.

Diese Rechte sind die Bausteine von Rechteketten. Ein Konto mit WriteDACL auf einer Gruppe kann sich selbst in die Gruppe eintragen. Ist die Gruppe privilegiert, ist der Schritt zur Rechteerweiterung kurz.

Vererbte Berechtigungen

Berechtigungen werden von übergeordneten Containern auf untergeordnete Objekte vererbt. Ein Recht, das auf einer OU gesetzt wird, gilt für alle Objekte darin, auch für solche, die später angelegt werden. Vererbung ist ein sinnvolles Verwaltungsmittel, sie macht aber schwer sichtbar, wo ein Recht tatsächlich wirkt. Ein Eintrag auf einer hohen Ebene kann Hunderte Objekte betreffen, ohne dass man es am einzelnen Objekt sieht.

Fehlkonfigurierte OUs

Eine OU ist eine häufige Quelle von Fehlkonfigurationen. Wird einer Gruppe ein weitreichendes Recht auf der OU Benutzer oder Computer gewährt, betrifft das alle Konten und Computer darin. Liegt in derselben OU ein Dienstkonto oder ein Administratorkonto, erweitert sich der Schaden entsprechend. Die Prüfung solcher Strukturen gehört zum Standardumfang jeder Analyse.

Überprivilegierte Benutzer

Ein überprivilegiertes Konto besitzt mehr Rechte, als seine Aufgabe braucht. Typische Ursachen sind Konten, die einmal für ein Projekt in eine Gruppe aufgenommen wurden und dort geblieben sind, und Dienstkonten mit Rechten, die der Dienst nie benutzt. Jedes überprivilegierte Konto ist ein Ausgangspunkt für eine Kette.

Gruppenverschachtelung

Verschachtelte Gruppen sind der häufigste Grund für unerwartete effektive Rechte. Eine Gruppe, die in Domain Admins verschachtelt ist, macht ihre Mitglieder zu Domänenadministratoren, auch wenn niemand das beabsichtigt hat. Kapitel 4 hat dafür die rekursive Abfrage gezeigt.

Domain Admins und Enterprise Admins

Die Gruppen Domain Admins und Enterprise Admins haben die höchsten Rechte. Mitglieder von Domain Admins können die Domäne vollständig verwalten, Mitglieder von Enterprise Admins die gesamte Gesamtstruktur. Jede Verbindung zu diesen Gruppen, direkt oder über Verschachtelung, ist ein Angriffsziel und ein Prüfpunkt.

Privilege Escalation über Berechtigungen

Privilege Escalation im Active Directory entsteht meist aus einer Kette: Ein Konto besitzt ein Recht auf ein Objekt, mit dem es die Mitgliedschaft, das Kennwort oder die Berechtigungen eines anderen Objekts ändern kann, und dieses Objekt führt wieder zu einem Recht, bis am Ende die Gruppe der höchsten Rechte erreicht ist. Die Kette besteht aus einfachen Schritten, die jeweils durch eine einzelne Berechtigung möglich sind.

Diagramm 8.1: Aufbau einer Zugriffssteuerungsliste

```
Objekt: OU=Server,DC=nova,DC=int
  DACL
    ACE 1: Gruppe IT-Admins        -> GenericAll        erlaubt, vererbt
    ACE 2: Konto svc_backup        -> Reset Password    erlaubt, direkt
    ACE 3: Gruppe Helpdesk         -> ReadProperty      erlaubt, vererbt
  SACL
    ACE 4: Gruppe Everyone         -> Schreibzugriffe   protokolliert
```

Die Einträge zeigen, wie Vererbung und Direktrechte nebeneinander stehen. Der Befund ist immer der Eintrag mit dem Recht, nicht die Gruppe allein.

Erkennung

Änderungen an Berechtigungen erzeugen Ereignisse, wenn die SACL des Objekts das vorsieht. Das Ereignis 5136 meldet die Änderung eines Verzeichnisobjekts, das Ereignis 4662 einen Zugriff auf ein Objekt mit Verzeichnisdiensten. Ohne eine passende SACL bleiben solche Änderungen unsichtbar. Die Einrichtung der Überwachung behandelt Kapitel 13.

Schutzmaßnahmen

Das Prinzip der geringsten Rechte ist die wichtigste Grundlage. Berechtigungen gehören an Gruppen, nicht an einzelne Konten, und Gruppen werden regelmäßig überprüft. Vererbung wird bewusst eingesetzt und dokumentiert. Dienstkonten erhalten nur die Rechte, die ihr Dienst braucht. Änderungen an Berechtigungen auf kritischen OUs werden überwacht und müssen begründet sein.

Praxis: Berechtigungen untersuchen und korrigieren

Die Übungen laufen auf DC01 mit einem Administratorkonto. Die Testumgebung enthält eine OU namens Test mit einem Testobjekt.

Übung A: Berechtigungen einer OU auslesen

Lernziel: die DACL einer OU lesen und die Einträge den Konten und Gruppen zuordnen. **Voraussetzungen:** Modul ActiveDirectory, Laufwerk AD: verfügbar (wird vom Modul bereitgestellt).

Befehle zu Übung A

```
PS> (Get-Acl "AD:\OU=Server,DC=nova,DC=int").Access |
    Select-Object IdentityReference, ActiveDirectoryRights,
        AccessControlType, IsInherited
```

Erklärung: `Get-Acl` liest die ACL des Objekts über den AD-Pfad. `.Access` liefert die Einträge. `IdentityReference` nennt Konto oder Gruppe, `ActiveDirectoryRights` das Recht, `AccessControlType` Erlauben oder Verweigern, `IsInherited` ob der Eintrag vererbt wurde. **Erwartetes Ergebnis:** Eine Liste von Einträgen mit Gruppen und Konten, die auf der OU Rechte haben. Vererbte Einträge sind mit True markiert. **Überprüfung:** Jede Gruppe, die du nicht erklären kannst, ist ein Prüfpunkt. **Fehleranalyse:** Der AD-Pfad ist nicht gefunden? Prüfe mit `Get-PSDrive AD`, ob das Laufwerk existiert, und ob der Distinguished Name stimmt.

Übung B: Direkte Berechtigungen von vererbten trennen

Lernziel: die Direkteinträge gezielt herausfiltern. **Aufgabenstellung:** Zeige nur die Einträge, die nicht vererbt sind.

Befehle zu Übung B

```
PS> (Get-Acl "AD:\OU=Server,DC=nova,DC=int").Access |
    Where-Object { -not $_.IsInherited } |
    Select-Object IdentityReference, ActiveDirectoryRights
```

Erklärung: Der Filter wählt Einträge, die direkt auf der OU gesetzt wurden. Diese Einträge sind meist die Stellen, an denen jemand bewusst etwas geändert hat, und deshalb der Ausgangspunkt jeder Prüfung. **Erwartetes**

Ergebnis: Eine kurze Liste mit wenigen Einträgen. **Überprüfung:** Ist für jeden Direkteintrag ein Grund dokumentiert?

Übung C: Kritische Rechte finden

Lernziel: Einträge mit GenericAll, WriteDACL oder WriteOwner auf einer OU aufspüren. **Aufgabenstellung:** Suche auf den OUs der Domäne nach den drei kritischen Rechten.

Befehle zu Übung C

```
PS> Get-ADOrganizationalUnit -Filter * | ForEach-Object {
    $ou = $_.DistinguishedName
    (Get-Acl "AD:\$ou").Access |
    Where-Object { $_.ActiveDirectoryRights -match
        'GenericAll|WriteDacl|WriteOwner' } |
    Select-Object @{N='OU';E={$ou}}, IdentityReference,
        ActiveDirectoryRights
}
```

Erklärung: `Get-ADOrganizationalUnit` liefert alle OUs. Für jede wird die ACL gelesen. Der reguläre Ausdruck erfasst die drei kritischen Rechte. Die Auswahl von `IdentityReference` zeigt, welches Konto oder welche Gruppe das Recht hält. **Erwartetes Ergebnis:** Für normale Konfigurationen ist die Liste klein. Die Gruppe der Administratoren darf dort Rechte haben. Jeder andere Treffer ist zu begründen. **Überprüfung:** Vergleiche das Ergebnis mit der Liste aus Übung B. **Fehleranalyse:** Die Ausgabe ist leer, obwohl du Treffer erwartest? Prüfe, ob der reguläre Ausdruck die Schreibweise des Rechts in deiner Version trifft, und probiere die Abfrage zunächst auf einer einzelnen OU.

Übung D: Verschachtelte Gruppen in Domain Admins

Lernziel: Gruppen in der Gruppe der Domänenadministratoren finden. **Aufgabenstellung:** Liste die Mitglieder von Domain Admins, die selbst Gruppen sind.

Befehle zu Übung D

```
PS> Get-ADGroupMember -Identity "Domain Admins" | Where-Object {
    $_.objectClass -eq 'group' } |
    Select-Object Name, SamAccountName
```

Erklärung: Der Filter wählt Mitglieder der Klasse Gruppe. Jede gefundene Gruppe muss rekursiv aufgelöst werden (Kapitel 4, Übung B), um ihre Konten zu finden. **Erwartetes Ergebnis:** In einer sauberen Testdomäne ist die Liste leer. Eine Gruppe in dieser Liste ist ein Befund, der begründet werden muss. **Überprüfung:** Löse jede gefundene Gruppe mit `Get-ADGroupMember -Identity <Name> -Recursive` auf und dokumentiere die Konten.

Übung E: Fehlberechtigung sichern und korrigieren

Lernziel: eine Berechtigung korrigieren, ohne die ursprüngliche Konfiguration zu verlieren. **Voraussetzungen:** Administratorkonto, eine Test-OU mit einem Testeintrag, den du zuvor angelegt hast: Gruppe Helpdesk mit dem Recht GenericAll auf der OU Test. **Aufgabenstellung:** Sichere die ACL der OU Test, entferne den Eintrag für Helpdesk und prüfe das Ergebnis.

Befehle zu Übung E

```
PS> $acl = Get-Acl "AD:\OU=Test,DC=nova,DC=int"
PS> (Get-Acl
    "AD:\OU=Test,DC=nova,DC=int").GetSecurityDescriptorSddlForm('A
    ll') | Out-File .\acl_test_backup.sddl
PS> $acl.Access | Where-Object { $_.IdentityReference -like
    '*Helpdesk' } |
    ForEach-Object { $acl.RemoveAccessRule($_) } | Out-Null
PS> Set-Acl -Path "AD:\OU=Test,DC=nova,DC=int" -AclObject $acl
PS> (Get-Acl "AD:\OU=Test,DC=nova,DC=int").Access | Select-Object
    IdentityReference, ActiveDirectoryRights
```

Erklärung: Die erste Zeile liest die ACL in eine Variable. Die Sicherung speichert den Sicherheitsdeskriptor als SDDL-Text in einer Datei. Diese Form ist lesbar und lässt sich mit `SetSecurityDescriptorSddlForm` wieder in eine ACL überführen. Die Sicherung umfasst die Berechtigungen des Objekts, nicht seine Attribute. Die folgende Zeile entfernt die Einträge für Helpdesk aus dem Objekt im Speicher. `Set-Acl` schreibt die geänderte Liste zurück. Die letzte Zeile prüft das Ergebnis. **Erwartetes Ergebnis:** Der Eintrag für Helpdesk erscheint nicht mehr. Die Sicherungsdatei acl_test_backup.sddl existiert. **Wiederherstellung:** `$acl = Get-Acl "AD:\OU=Test,DC=nova,DC=int"`, dann `$acl.SetSecurityDescriptorSddlForm((Get-Content .\acl_test_backup.sddl -Raw))`, dann `Set-Acl -Path`

`"AD:\OU=Test,DC=nova,DC=int" -AclObject $acl`. **Überprüfung:** Die Wiederherstellung ist in der Testdomäne auszuprobieren, bevor du dich darauf verlässt. Die Abfrage aus Übung A muss danach den Helpdesk-Eintrag wieder zeigen. Vererbte Einträge werden über diese Sicherung nicht verändert, sondern nur über die Vererbung am übergeordneten Objekt. **Hinweis zu komplexen ACEs:** `RemoveAccessRule` entfernt nur einen Eintrag, der in Recht, Art und Sicherheitsprinzipal exakt übereinstimmt. Einträge mit Objekt- oder Eigenschaftsbezug werden mit diesem Vergleich nicht immer gefunden. Sieh dir deshalb die Einträge vor der Änderung an und prüfe nach der Änderung erneut. **Fehleranalyse:** `Set-Acl` meldet einen Zugriffsfehler? Prüfe, ob du Administratorrechte auf der OU hast, und ob der Eintrag vererbt wurde. Vererbte Einträge lassen sich nicht direkt entfernen, sondern nur über die Vererbung unterbinden. **Sicherheitsbetrachtung:** Die Sicherungsdatei enthält die Berechtigungsstruktur der OU. Behandle sie wie vertrauliche Konfiguration und lösche sie nach dem Projekt.

Typische Fehler

- Eine Berechtigung auf einer hohen OU wird übersehen, weil sie vererbt wird
- Dienstkonten erhalten Rechte, die der Dienst nicht braucht
- Verschachtelte Gruppen werden nicht rekursiv aufgelöst
- Eine ACL wird ohne Sicherung geändert
- Das Ergebnis einer Prüfung wird nicht mit dem Zeitpunkt festgehalten

> **Zusammenfassung**
>
> - Die DACL bestimmt Zugriffe, die SACL bestimmt, was protokolliert wird.
> - GenericAll, WriteDACL, WriteOwner und Reset Password sind die Rechte, mit denen Ketten entstehen.
> - Vererbung und Verschachtelung machen Rechte schwer sichtbar und sind deshalb die wichtigsten Prüfpunkte.
> - Jede Korrektur beginnt mit einer Sicherung der ACL.

Kontrollfragen

1. Was unterscheidet die DACL von der SACL? (leicht)
2. Warum ist WriteDACL ein kritisches Recht? (mittel)
3. Ein Eintrag wird als vererbt angezeigt. Wo musst du suchen, um ihn zu ändern? (mittel)
4. Ein Konto hat das Recht Reset Password auf einer OU mit Dienstkonten. Welche Kette ist denkbar, und welche Maßnahme unterbricht sie zuerst? (schwer)
5. Warum sollte die Sicherung der ACL vor einer Änderung und nicht danach erstellt werden? (leicht)

Lösungshinweise: 1. Die DACL legt Zugriffe fest, die SACL legt fest, welche Zugriffe protokolliert werden. 2. Wer die DACL ändern darf, kann sich selbst jedes andere Recht auf dem Objekt geben. 3. Am übergeordneten Container, dort wird die Vererbung gesetzt. Am untergeordneten Objekt lässt sich nur die Vererbung unterbinden. 4. Das Konto kann Kennwörter der Dienstkonten setzen und einen Dienst übernehmen. Zuerst unterbrichst du das Recht Reset Password auf den Dienstkonten und setzt die Vererbung auf der OU zurück. 5. Nur eine Sicherung vor der Änderung zeigt den Zustand, den du wiederherstellen musst, wenn die Änderung Probleme macht.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] DACL, SACL und ACE unterscheidest und die Rechte GenericAll, WriteDACL und WriteOwner erklärst,
- [ ] vererbte und direkte Berechtigungen auf einer OU trennst,
- [ ] verschachtelte Gruppen in Domain Admins findest,
- [ ] eine Berechtigung sichern, korrigieren und prüfen kannst.

Kapitel 9: BloodHound und Angriffspfadanalyse

Lernziele

- Du erklärst, wie BloodHound Active-Directory-Beziehungen als Graphen darstellt.
- Du führst eine Datensammlung in der isolierten Testdomäne durch und importierst sie.
- Du identifizierst Angriffspfade, priorisierst sie und leitest Maßnahmen ab.

WARNUNG – Sicherheitsrisiko

Die Datensammlung in diesem Kapitel findet ausschließlich in der isolierten Testdomäne statt, mit einem Konto, das dafür vorgesehen ist. Die gesammelten Daten enthalten Informationen über alle Konten der Domäne. Behandle sie wie vertrauliche Daten: verschlüsselt speichern, nur dem Prüfteam zugänglich machen und nach der Analyse löschen.

Was ist BloodHound?

BloodHound ist ein Werkzeug, das die Beziehungen einer Active-Directory-Domäne als Graphen darstellt. Die Daten stammen aus einer Sammlung über LDAP und Dienste der Domäne. BloodHound macht daraus eine Karte: Wer ist in welcher Gruppe, wer hat auf welchem Objekt welches Recht, wo ist welches Konto angemeldet. Die Karte beantwortet Fragen, die in Tabellen schwer zu beantworten sind.

Die aktuelle Version heißt BloodHound Community Edition. Sie besteht aus einer Weboberfläche und einer Datenbank, die Installation folgt der Dokumentation des Projekts.

Warum Graphanalysen wichtig sind

Ein Angriffspfad ist eine Kette von Beziehungen. Tabellen zeigen einzelne Beziehungen, aber nicht die Kette. Ein Graph zeigt sie direkt, und er macht Umwege sichtbar, die in Listen untergehen. Gerade bei gewachsenen Domänen liegt die Gefahr in solchen Umwegen, deshalb ist die Graphanalyse das Standardwerkzeug für die Prüfung.

Knoten und Beziehungen

Im Graphen gibt es Knoten und Kanten. Knoten sind Objekte wie Benutzer, Gruppen, Computer, OUs, Gruppenrichtlinien und die Domäne selbst. Kanten sind Beziehungen zwischen ihnen, etwa Mitgliedschaft in einer Gruppe, ein Recht auf ein Objekt oder eine Anmeldung.

Diagramm 9.1: Ein Ausschnitt aus einem Graphen (vereinfacht)

```
(max.mustermann) --MemberOf--> (Helpdesk)
(Helpdesk) --GenericWrite--> (svc_backup)
(svc_backup) --MemberOf--> (Server-Admins)
(Server-Admins) --AdminTo--> (SRV01)
(SRV01) --HasSession--> (Domain Admin: admin.test)
```

Der Ausschnitt zeigt eine Kette von fünf Kanten. Keine einzelne Kante wäre für sich ein Vorfall, die Kette ist es. Jede Kante muss im Graphen einzeln belegbar sein, sonst ist die Kette nur eine Vermutung.

Benutzer, Gruppen und Computer

Benutzer und Gruppen sind die häufigsten Knoten. Computer sind wichtig, weil sie die Orte sind, an denen Konten angemeldet sind und Rechte gelten. Die Gruppe der Administratoren auf einem Computer, die lokal vergeben ist, erscheint als Kante AdminTo.

Sessions

Eine Session ist eine Anmeldung eines Kontos an einem Computer. BloodHound speichert solche Anmeldungen als Kante HasSession. Eine Session ist nur ein Momentbild. Sie besteht, solange die Anmeldung besteht, und sie fehlt, wenn sich das Konto abgemeldet hat. Die Sammlung ist deshalb immer nur eine Aufnahme zu einem Zeitpunkt.

Admin Rights

Admin Rights sind Rechte auf einem Computer, meist über die lokale Administratorgruppe. Sie sind eine eigene Kategorie, weil sie einem Konto erlauben, auf dem Computer weitreichend zu handeln. Hat ein Konto Admin Rights auf einem Computer, auf dem ein Domänenadministrator angemeldet ist, entsteht die klassische Kette.

Angriffspfade

Ein Angriffspfad ist die Kette von Knoten zu einem Ziel mit hohen Rechten, meist der Gruppe Domain Admins. BloodHound berechnet solche Pfade aus dem Graphen. Die Länge des Pfades ist ein Maß, aber nicht das einzige: Ein kurzer Pfad über ein Konto mit weitreichenden Rechten kann gefährlicher sein als ein langer Pfad über schwache Glieder.

SharpHound und Datensammlung

SharpHound ist der Sammler, der die Daten für BloodHound erzeugt. Er liest die Domäne über LDAP und fragt die Computer nach Sessions und lokalen Administratoren ab. Die Sammlung erzeugt Netzwerkverkehr und Abfragen, die in den Protokollen sichtbar werden. Deshalb wird sie in der Testdomäne mit Ankündigung und zu einem festgelegten Zeitpunkt durchgeführt, wenn sie als Übung dient. In einer produktiven Domäne braucht sie eine Freigabe.

Die Sammlung liefert eine ZIP-Datei mit mehreren Dateien, die BloodHound importiert.

Graphabfragen

BloodHound bietet vorgefertigte Abfragen, etwa die Suche nach dem kürzesten Pfad zu den Domänenadministratoren. Die genaue Bezeichnung der Abfragen hängt von der Version ab, deshalb prüfst du sie in der Oberfläche. Eigene Abfragen lassen sich nach der Dokumentation des Projekts formulieren.

Analyse kritischer Beziehungen

Die Analyse beginnt mit den Zielen: Domain Admins, Enterprise Admins, Konten mit Rechten auf Domänencontrollern. Danach werden die Kanten zu diesen Zielen rückwärts betrachtet. Jede Kante wird geprüft: Gibt es den Eintrag wirklich, war er beabsichtigt, und gibt es eine Begründung? Erst dann ist der Pfad belegt.

Grenzen der Datensammlung

Die Sammlung ist eine Momentaufnahme. Sessions ändern sich, Berechtigungen werden geändert, Computer sind zeitweise nicht erreichbar. Ein Pfad, der in der Sammlung fehlt, kann existieren, und ein Pfad, der darin steht, kann bereits behoben sein. Die Sammlung braucht außerdem Rechte, die nicht jedes Konto hat, und sie sieht nur, was ihr Konto lesen darf.

Datenschutz und sichere Verwendung

Die Sammlung enthält Namen, Gruppen, Anmeldezeiten und Computerbezeichnungen. Sie ist deshalb ein personenbezogener Datenbestand. Lege sie nur auf einem geschützten Datenträger ab, lösche die ZIP-Datei nach dem Import und die Datenbank nach dem Projekt, und dokumentiere, wer Zugriff hatte. Die Speicherung ist im Rahmen des Auftrags zu regeln.

Praxis: Angriffspfade in der Testdomäne analysieren

Die Übungen laufen auf DC01 und einem Analysesystem, das die BloodHound-Oberfläche bereitstellt. Vorbereitung: Die Testdomäne enthält die Konten aus Kapitel 2 und 5, die Gruppe IT-Admins mit Verschachtelung aus Kapitel 4. Hast du Kapitel 8, Übung E durchgeführt, stelle den Testeintrag wieder her, damit der Pfad aus Übung D vorhanden ist.

Übung A: Testdomäne und Analysesystem vorbereiten

Lernziel: eine klar abgegrenzte Umgebung für die Sammlung schaffen. **Aufgabenstellung:** Prüfe, dass die Testdomäne isoliert ist und keine produktiven Systeme erreichen kann. Notiere Datum, Uhrzeit und den Zweck der Sammlung. **Erwartetes Ergebnis:** Ein Protokollvermerk mit Netzwerkgrenzen, Konto und Zeitfenster. **Fehleranalyse:** Das Analysesystem erreicht Systeme außerhalb der Testdomäne? Trenne es vom Netz, bevor du weitermachst.

Übung B: Daten sammeln

Lernziel: eine Sammlung in der Testdomäne erzeugen. **Voraussetzungen:** SharpHound auf einem Windows-System der Testdomäne, Konto mit Leserecht auf der Domäne.

Befehle zu Übung B

```
PS> .\SharpHound.exe -c All
```

Erklärung: `-c All` wählt alle Erfassungsmethoden aus. Das ist für die Testdomäne sinnvoll, weil die Übung alle Beziehungen braucht. Das Programm legt die ZIP-Datei im aktuellen Verzeichnis ab. Die Ausgabe nennt die Anzahl der gesammelten Objekte. **Erwartetes Ergebnis:** Eine ZIP-Datei mit den Objekten der Domäne. Die Anzahl der Benutzer und Gruppen entspricht deiner Testdomäne. **Überprüfung:** Prüfe Anzahl und Zeitstempel. Lege die Datei in den geschützten Speicher. **Fehleranalyse:** Die Sammlung bricht ab? Prüfe das Konto, die Netzwerkverbindung zu DC01 und die Namensauflösung über DNS. **Sicherheitsbetrachtung:** Diese Sammlung ist vertraulich. Sie wird nach der Analyse gelöscht.

Übung C: Daten importieren und Umfang prüfen

Lernziel: die Sammlung in BloodHound laden und prüfen, ob sie vollständig ist. **Aufgabenstellung:** Importiere die ZIP-Datei in die Oberfläche. Vergleiche die angezeigten Anzahlen mit deiner Testdomäne. **Erwartetes Ergebnis:** Die Oberfläche zeigt Benutzer, Gruppen, Computer und Domänen. Die Zahlen stimmen mit der Testdomäne überein. **Überprüfung:** Fehlt ein Objekttyp, war die Sammlung unvollständig. Dokumentiere das, bevor du Schlüsse ziehst.

Übung D: Den kürzesten Pfad zu Domain Admins betrachten

Lernziel: einen Angriffspfad im Graphen lesen und jede Kante prüfen. **Aufgabenstellung:** Führe die vorgefertigte Abfrage zum kürzesten Pfad zu Domain Admins aus. Wähle als Startpunkt das Konto max.mustermann. **Erwartetes Ergebnis:** Ein Pfad mit mehreren Kanten, zum Beispiel über eine Gruppenmitgliedschaft, einen Rechteeintrag und eine Anmeldung. Ist kein Pfad vorhanden, ist das für die Testdomäne ein erwünschtes Ergebnis, sofern die Konfiguration sauber ist. **Überprüfung:** Prüfe jede Kante einzeln: Ist der Eintrag in der Domäne vorhanden, und wann ist er entstanden? Dokumentiere den Pfad mit diesen Angaben. **Fehleranalyse:** Der Pfad fehlt, obwohl du einen erwartest? Prüfe die Verschachtelung aus Kapitel 4 und den Testeintrag aus Kapitel 8.

Übung E: Pfade priorisieren

Lernziel: mehrere Pfade nach Risiko ordnen. **Aufgabenstellung:** Bewerte jeden gefundenen Pfad nach drei Kriterien: Länge, Art des Rechts (etwa GenericAll gegenüber AdminTo), und Wert des Startkontos. Erstelle eine Rangliste. **Erwartetes Ergebnis:** Eine Liste mit Pfaden, die jeweils eine Bewertung und eine Begründung haben. **Überprüfung:** Ist die Reihenfolge nachvollziehbar? Ein Pfad mit einem kritischen Recht und einem Konto mit hohen Rechten steht vor einem langen Pfad über schwache Glieder.

Übung F: Maßnahmen ableiten und Wirkung prüfen

Lernziel: aus einem Pfad eine konkrete Maßnahme ableiten und ihre Wirkung in einer neuen Sammlung belegen. **Aufgabenstellung:** Entferne das kritische Recht aus Übung E und sammle neu. Vergleiche die Pfade vor und nach der Änderung. **Erwartetes Ergebnis:** Der betroffene Pfad fehlt in der neuen Sammlung, die übrigen Pfade bleiben, sofern sie nicht ebenfalls geändert wurden. **Überprüfung:** Notiere den Vorher-Nachher-Vergleich mit Zeitpunkt und Anzahl der Pfade. **Sicherheitsbetrachtung:** Lösche die alten Sammlungen nach dem Vergleich.

Typische Fehler

- Ein Pfad wird als bestätigt gewertet, ohne jede Kante zu prüfen
- Eine Session wird als dauerhafter Zustand verstanden

• Die Sammlung wird ohne Freigabe in einer produktiven Domäne durchgeführt

• Die ZIP-Datei bleibt ungeschützt auf dem Analysesystem liegen

• Ein fehlender Pfad wird als Beweis für Sicherheit gewertet

> **Zusammenfassung**
>
> • BloodHound stellt Beziehungen der Domäne als Graphen dar, in denen Angriffspfade als Ketten erscheinen.
> • Eine Sammlung ist eine Momentaufnahme. Sessions und Rechte können sich ändern.
> • Jeder Pfad wird kantenweise geprüft, bevor er als Befund gilt.
> • Die Daten sind vertraulich und werden nach der Analyse gelöscht.

Kontrollfragen

1. Was ist der Unterschied zwischen einer Kante AdminTo und einer Kante HasSession? (leicht)

2. Warum ist eine Sammlung nur eine Momentaufnahme? (leicht)

3. Ein kurzer Pfad über ein Konto mit weitreichenden Rechten ist gefährlicher als ein längerer über schwache Glieder. Begründe das. (mittel)

4. Ein Pfad fehlt in der Sammlung. Heißt das, dass die Domäne sicher ist? Begründe deine Antwort. (mittel)

5. Eine Sammlung enthält Daten aller Konten der Domäne. Welche Pflichten entstehen daraus, und welche Maßnahmen sind vor und nach der Analyse nötig? (schwer)

Lösungshinweise: 1. AdminTo beschreibt ein Recht auf einem Computer, HasSession eine Anmeldung eines Kontos an einem Computer. 2. Die Daten beschreiben den Zustand zum Zeitpunkt der Sammlung, Sessions und Rechte ändern sich laufend. 3. Ein Konto mit weitreichenden Rechten gibt dem Angreifer viel Macht über wenige Schritte, weil die Länge des Pfades nicht das entscheidende Maß ist. 4. Nein. Die Sammlung ist unvollständig, wenn Objekte oder Rechte fehlen, und sie zeigt nur, was zum Zeitpunkt und mit dem Konto der Sammlung sichtbar war. 5. Pflicht zur geschützten Speicherung, Zugriffsbegrenzung, Dokumentation und Löschung. Vor der

Analyse braucht es eine Freigabe, nach der Analyse die Löschung und einen Protokollvermerk.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] Knoten, Kanten, Sessions und Admin Rights in einem Graphen erkennst,
- [ ] eine Sammlung in der Testdomäne durchführst und importierst,
- [ ] einen Pfad kantenweise prüfst und priorisierst,
- [ ] die Datenschutzpflichten der Sammlung benennen kannst.

Kapitel 10:
Active-Directory-Persistenz und Domänenkompromittierung

Lernziele

- Du erklärst, wie ein Angreifer seinen Zugang über das ursprüngliche Ereignis hinaus sichert.
- Du benennst die Mechanismen, die Persistenz ermöglichen, und findest Hinweise darauf in der Testdomäne.
- Du erklärst, warum Golden und Silver Tickets und DCSync die Domäne auf Dauer gefährden und wie sie erkannt werden.

WARNUNG – Sicherheitsrisiko

Dieses Kapitel beschreibt Mechanismen auf Prinzipebene. Es enthält keine Schritte, mit denen Schlüssel der Domäne ausgelesen oder Tickets erzeugt werden. Die Übungen prüfen Konfigurationen und Spuren in der Testdomäne.

Was Persistenz bedeutet

Persistenz ist der Versuch, einen Zugang zu erhalten, selbst wenn der ursprüngliche Weg geschlossen wird. Ein Angreifer, der ein Konto übernommen hat, sichert sich zusätzlich ab, weil ein Kennwortwechsel allein den Zugang sonst beendet. Die Mechanismen greifen dabei in die Bausteine der Domäne ein: Konten, Gruppen, Richtlinien, Delegation und die Schlüssel der Domäne.

Persistenz ist deshalb ein Thema der Erkennung und der Wiederherstellung, nicht nur des ersten Eindringens. Wer nur das ursprüngliche Konto bereinigt, lässt die Mechanismen zurück.

Gefährdete Benutzerkonten

Ein Konto, das für den Angreifer nützlich ist, muss nicht privilegiert sein. Ein altes Konto mit unveränderten Kennwort, ein Dienstkonto mit Rechten oder ein vergessenes Testkonto eignen sich. Die Bestandsaufnahme aus Kapitel 2 und die Prüfung der Kennwortalter aus Kapitel 5 finden solche Konten.

Manipulierte Gruppenmitgliedschaften

Eine zusätzliche Aufnahme in eine Gruppe mit Rechten ist der einfachste Weg, den Zugang zu erhalten. Die Gruppenänderungen sind im Protokoll sichtbar (Kapitel 13). Eine Mitgliedschaft, die über Verschachtelung entsteht, ist schwerer zu sehen und wird über die rekursive Auflösung aus Kapitel 4 gefunden.

Delegationskonfigurationen

Ein Konto mit unbeschränkter Delegation oder mit Rechten zur Änderung der Delegation bleibt auch nach einem Kennwortwechsel ein Zugang, sofern die Delegation erhalten bleibt. Die Prüfung aus Kapitel 11 deckt diese Fälle auf.

Ungewöhnliche Berechtigungen

Ein Recht auf einem Objekt, das nur einem Konto dient, ist ein Mechanismus der Persistenz. Die ACL-Prüfung aus Kapitel 8 findet solche Einträge. Vererbte Rechte auf hohen Ebenen sind besonders schwer zu erkennen.

Gruppenrichtlinienmissbrauch

Eine Gruppenrichtlinie, die auf viele Systeme wirkt, kann einen Mechanismus auf allen Systemen verteilen. Wer eine GPO ändern darf, kontrolliert die Einstellungen aller Systeme, auf die sie wirkt. Die Prüfung der GPO-Änderungen aus Kapitel 12 und 13 ist deshalb Teil jeder Untersuchung.

Replikationsrechte und DCSync

Domänencontroller tauschen Verzeichnisdaten über Replikation aus. Dafür braucht ein Konto besondere Replikationsrechte auf der Domäne. Ein Konto außerhalb der Domänencontroller mit diesen Rechten kann die Replikation anfordern, ohne auf einem Domänencontroller angemeldet zu sein. Die Anforderung heißt DCSync, Kapitel 13 beschreibt die Erkennung über Ereignis 4662. Ob ein solches Konto einen Angriff darstellt oder eine legitime Ausnahme ist, entscheidet die Prüfung des Befunds.

Die Replikationsrechte gehören ausschließlich den Domänencontrollern und wenigen dafür vorgesehenen Gruppen. Jedes andere Konto mit diesen Rechten ist ein Befund, der zu prüfen ist; legitime Ausnahmen müssen dokumentiert sein.

Schlüssel der Domäne und das Konto krbtgt

Das Konto krbtgt besitzt den langfristigen Schlüssel, mit dem der KDC Ticket-Granting-Tickets (TGTs) verschlüsselt. Wer diesen Schlüssel besitzt, kann gefälschte TGTs erzeugen, die der Domäne als gültig erscheinen. Ein solches Ticket heißt Golden Ticket. Es ist unabhängig davon, ob das Kennwort eines Benutzers geändert wurde, und gilt, bis der Schlüssel gewechselt wird.

Ein Silver Ticket wird mit dem Schlüssel eines Dienstkontos erzeugt und gilt nur für diesen Dienst. Es umgeht die Prüfung durch den Domänencontroller, weil es nicht bei ihm angefordert wird. Gegen beide Formen helfen dieselben Maßnahmen: AES für alle Dienste, gMSA für Dienstkonten, die Überwachung ungewöhnlicher Tickets und der Wechsel des krbtgt-Kennworts nach Herstellerdokumentation (Kapitel 14).

> **Gut zu wissen**
>
> Golden und Silver Tickets werden in diesem Buch nur als Konzept behandelt. Wer sie erkennen will, prüft die Kennwortalter und Verschlüsselungstypen (Kapitel 5), die Ereignisse für Tickets (Kapitel 13) und die Konsistenz der Anmeldungen. Ein Ticket selbst ist nicht zwingend auffällig, deshalb sind die Muster wichtiger als ein einzelnes Ereignis.

Credential Theft

Anmeldedaten, die auf Systemen im Speicher liegen, erleichtern jede weitere Persistenz. Die Schutzmechanismen aus Kapitel 7 (Credential Guard, Protected Users, Tiering) verringern diese Gefahr. Ein Administrator, dessen Anmeldung auf einem Arbeitsplatz gespeichert ist, ist die häufigste Quelle.

Erkennung verdächtiger Änderungen

Die Erkennung kombiniert die Quellen aus Kapitel 13. Jede Änderung an Gruppen mit Verwaltungsrechten, an Replikationsrechten, an GPOs und an Delegationen ist ein Befund. Die Änderungszeitpunkte werden mit der Timeline aus Kapitel 8 des Forensik-Handbuchs dieser Reihe verglichen, wo die Methode der Zeitangaben vertieft ist.

Wiederherstellung einer kompromittierten Domäne

Die Wiederherstellung umfasst alle Mechanismen dieses Kapitels. Gruppen, GPOs, Delegationen, Replikationsrechte, Dienste und Schlüssel werden geprüft, bevor die Domäne als vertrauenswürdig gilt. Der krbtgt-Wechsel ist ein Schritt, kein Abschluss. Kapitel 14 beschreibt die Reihenfolge.

Praxis: Persistenzspuren in der Testdomäne prüfen

Die Übungen laufen auf DC01 mit einem Administratorkonto und lesen nur.

Übung A: Kürzlich geänderte Konten und Gruppen finden

Lernziel: Änderungen mit Zeitbezug finden, die auf Persistenz hindeuten können.

Befehle zu Übung A

```
PS> $Stichtag = (Get-Date).AddDays(-30)
PS> Get-ADUser -Filter {whenChanged -gt $Stichtag} -Properties
    whenChanged |
    Select-Object SamAccountName, whenChanged
PS> Get-ADGroup -Filter {whenChanged -gt $Stichtag} -Properties
    whenChanged |
    Select-Object Name, whenChanged
```

Erklärung: Die beiden Abfragen listen Konten und Gruppen mit einer Änderung in den letzten 30 Tagen. `whenChanged` zeigt den Zeitpunkt der letzten Änderung, der Filter wählt nach diesem Zeitpunkt aus. **Erwartetes Ergebnis:** Eine Liste der geänderten Objekte. Jede Änderung ohne geplanten Vorgang ist ein Prüfpunkt. **Überprüfung:** Ordne jeden Treffer einem Vorgang aus dem Änderungsprotokoll zu.

Übung B: Replikationsrechte auf der Domäne prüfen

Lernziel: Konten mit erweiterten Rechten auf der Domänenwurzel finden, die keine Domänencontroller sind.

Befehle zu Übung B

```
PS> (Get-Acl "AD:\DC=nova,DC=int").Access |
    Where-Object { $_.ActiveDirectoryRights -match 'ExtendedRight'
        -and $_.AccessControlType -eq 'Allow' } |
    Select-Object IdentityReference, ActiveDirectoryRights
```

Erklärung: Der Filter wählt die erlaubten erweiterten Rechte auf der Domänenwurzel. Replikationsrechte sind erweiterte Rechte. Die Liste enthält auch andere Rechte, die für die Prüfung auszuschließen sind. Die genaue Zuordnung der Replikationsrechte zu den Namen steht in der Microsoft-Dokumentation. **Erwartetes Ergebnis:** Eine Liste mit Domänencontrollern und Standardgruppen. Jedes andere Konto ist zu begründen. **Überprüfung:** Vergleiche die Liste mit der Dokumentation und entferne berechtigte Einträge nur nach Freigabe. **Fehleranalyse:** Die Liste ist zu lang, um sie zu bewerten? Filtere zuerst nach den Konten, die nicht Domänencontroller sind.

Übung C: GPO-Änderungen prüfen

Lernziel: die Änderungszeiten der Gruppenrichtlinien erfassen. **Voraussetzungen:** Modul GroupPolicy, das in den Remoteserver-Verwaltungstools enthalten ist.

Befehle zu Übung C

```
PS> Get-GPO -All | Select-Object DisplayName, ModificationTime |
    Sort-Object ModificationTime -Descending
```

Erklärung: `Get-GPO` liefert alle Gruppenrichtlinien. `ModificationTime` zeigt die letzte Änderung. Die Sortierung stellt die jüngsten Änderungen nach oben. **Erwartetes Ergebnis:** Eine Liste der GPOs mit Änderungszeit. Eine unerwartete Änderung an einer GPO mit weitreichender Wirkung ist ein Befund. **Überprüfung:** Prüfe Verknüpfungen und Einstellungen der obersten Treffer (Kapitel 12).

Typische Fehler

- Nur das ursprüngliche Konto wird bereinigt, die Mechanismen bleiben bestehen
- Ein Kennwortwechsel wird als Beseitigung der Persistenz verstanden
- Replikationsrechte für Dienstkonten werden übersehen
- Golden Tickets werden ohne Wechsel des krbtgt-Schlüssels als beseitigt betrachtet

> **Zusammenfassung**
>
> - Persistenz sichert einen Zugang über den ursprünglichen Angriff hinaus und greift in Konten, Gruppen, Richtlinien, Delegation und Schlüssel ein.
> - Replikationsrechte außerhalb der Domänencontroller sind ein wichtiger Befund, DCSync wird über Ereignis 4662 erkannt.
> - Golden und Silver Tickets gegen die Schlüssel von krbtgt und Dienstkonten erfordern den Wechsel der Schlüssel und Monitoring.
> - Die Wiederherstellung schließt alle Mechanismen, nicht nur das ursprüngliche Konto.

Kontrollfragen

1. Warum genügt ein Kennwortwechsel nicht, um Persistenz zu beseitigen? (leicht)
2. Welche Rechte erlauben DCSync, und warum sind sie für andere Konten gefährlich? (mittel)
3. Worin unterscheidet sich ein Golden Ticket von einem Silver Ticket? (mittel)
4. In der Prüfung findet sich ein Dienstkonto mit Replikationsrechten. Welche Schritte folgen? (schwer)

Lösungshinweise: 1. Die Mechanismen, die der Angreifer eingerichtet hat, bleiben bestehen, etwa Gruppen, Richtlinien, Delegationen und Replikationsrechte. 2. Replikationsrechte auf der Domäne erlauben die Anforderung von Verzeichnisdaten, einschließlich Kennwortdaten. Für andere Konten sind sie gefährlich, weil sie ohne Anmeldung auf einem Domänencontroller wirken. 3. Ein Golden Ticket wird mit dem krbtgt-Schlüssel erzeugt und gilt für die ganze Domäne. Ein Silver Ticket wird mit einem Dienstschlüssel erzeugt und gilt nur für diesen Dienst. 4. Die Replikationsrechte werden entfernt, nach Sicherung und Begründung. Das Konto wird überprüft, die Anmeldungen und Änderungen untersucht. Da Kennwortdaten möglicherweise abgerufen wurden, gehört das Konto in die Credential Rotation nach Kapitel 14.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die Mechanismen der Persistenz benennst und ihren Bezug zu den Kapiteln erklärst,
- [ ] Replikationsrechte außerhalb der Domänencontroller findest,
- [ ] Golden und Silver Tickets unterscheidest und die gemeinsamen Gegenmaßnahmen nennst.

Kapitel 11:
Active-Directory-Delegation und kritische Konfigurationen

Lernziele

- Du unterscheidest unbeschränkte, beschränkte und ressourcenbasierte Delegation und erklärst ihre Risiken.
- Du findest Delegationen, Vertrauensstellungen und SPN-Konfigurationen in der Testdomäne.
- Du entschärfst eine riskante Delegation und dokumentierst die Wirkung.

WARNUNG – Sicherheitsrisiko

Dieses Kapitel erklärt, wie Delegation funktioniert und an welcher Stelle sie zum Risiko wird. Die Übungen lesen Konfigurationen aus und ändern in der Testdomäne nur Testobjekte, nach Sicherung der bisherigen Werte.

Was Delegation ist

Delegation erlaubt einem Dienst, im Auftrag eines Benutzers auf andere Dienste zuzugreifen. Ein Webserver, der die Anmeldung eines Benutzers entgegennimmt, muss beispielsweise auf eine Datenbank zugreifen, und zwar mit den Rechten des Benutzers. Dafür muss der Dienst ein Ticket des Benutzers weiterverwenden dürfen. Genau das regelt Delegation.

Die Funktion ist nützlich und in vielen Umgebungen nötig. Sie wird aber gefährlich, sobald sie weiter reicht, als der Dienst braucht.

Unbeschränkte Delegation

Bei unbeschränkter Delegation darf ein Computer oder Dienst jedes Ticket eines Benutzers, der sich bei ihm anmeldet, weiterverwenden, und zwar für jeden beliebigen Dienst im Netz. Dafür speichert das System die Tickets der Anmeldenden im Speicher. Wer einen Computer mit unbeschränkter Delegation kompromittiert, erhält damit die Möglichkeit, sich als jeder Benutzer auszugeben, der sich dort angemeldet hat, einschließlich Administratoren.

Die Einstellung heißt im Verzeichnis TrustedForDelegation. Sie ist das gefährlichste Delegationsmodell und sollte nur an Stellen verwendet werden, wo es technisch unvermeidbar ist.

Beschränkte Delegation

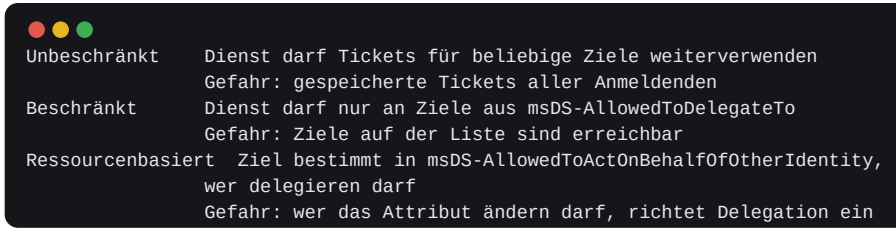
Beschränkte Delegation, im Englischen Constrained Delegation, begrenzt den Dienst auf eine Liste von Zielen. Diese Liste steht im Attribut msDS-AllowedToDelegateTo des Dienstkontos. Der Dienst darf Tickets nur für diese Ziele weiterverwenden. Das ist deutlich sicherer, weil ein Angreifer nur die Ziele erreicht, die auf der Liste stehen.

Eine Variante mit Protokollübergang erlaubt dem Dienst, Tickets für Benutzer zu erzeugen, ohne dass sich diese im Moment anmelden. Sie ist ein zusätzliches Risiko und braucht eine besonders sorgfältige Prüfung.

Ressourcenbasierte Delegation

Bei der ressourcenbasierten Delegation (Resource-Based Constrained Delegation, RBCD) legt das Zielsystem fest, welche Dienste dort delegieren dürfen. Die Liste steht im Attribut msDS-AllowedToActOnBehalfOfOtherIdentity des Zielcomputers. Das Modell verteilt die Verantwortung: Der Besitzer des Ziels entscheidet, wer hineindarf. Wer das Attribut auf einem Computer schreiben darf, kann damit eine Delegation einrichten, deshalb gehört seine Kontrolle zur Prüfung.

Diagramm 11.1: Delegationsarten im Vergleich



SPN-Konfiguration

Die Delegation hängt an Dienstnamen (SPN), die Kapitel 5 behandelt. Ein Dienstkonto mit Delegation und einem zu allgemeinen SPN kann Ziele erreichen, die nie gedacht waren. Prüfe deshalb Delegation und SPN gemeinsam.

Vertrauensstellungen

Zwischen Domänen und Gesamtstrukturen können Vertrauensstellungen bestehen. Eine Vertrauensstellung erlaubt Konten einer Domäne, auf Ressourcen einer anderen zuzugreifen. Die Richtung (eingehend, ausgehend, beidseitig) und die Art (Domäne, Gesamtstruktur) bestimmen das Ausmaß. Ein Vertrauen ist eine Verbindung zwischen zwei Sicherheitsgrenzen. Wer die eine kompromittiert, erreicht unter Umständen die andere.

Die Filterung über SID-Filterung soll verhindern, dass Konten fremde SID-Historie einbringen. Ob sie aktiv ist, muss geprüft werden, weil sie bei manchen Vertrauensarten nicht standardmäßig gilt.

Risiken fehlerhafter Delegation

Die Risiken lassen sich in drei Gruppen fassen. Unbeschränkte Delegation auf Systemen mit Benutzeranmeldungen ist die direkteste Gefahr. Beschränkte Delegation mit zu breiten Zielen oder Protokollübergang erweitert die Angriffsfläche. Vertrauensstellungen ohne Filterung verbinden Domänen über ihre Grenzen hinweg. In jedem Fall ist die Wirkung davon abhängig, welche Konten an den betroffenen Stellen angemeldet werden.

Sichere Konfiguration

Unbeschränkte Delegation wird entfernt, wo sie nicht nötig ist. Beschränkte Delegation erhält nur die notwendigen Ziele. Konten mit besonderem Schutzbedarf werden als nicht delegierbar markiert, damit keine Dienste ihre Tickets weiterverwenden können. Für Administratorkonten gilt das ohnehin, und Protected Users (Kapitel 7) verhindert Delegation zusätzlich. Vertrauensstellungen werden nur bewusst angelegt und mit Filterung betrieben.

Praxis: Delegation und Vertrauen untersuchen

Die Übungen laufen auf DC01 mit einem Administratorkonto. Die Testumgebung enthält den Server SRV01 und das Dienstkonto svc_backup aus Kapitel 5.

Übung A: Computer mit unbeschränkter Delegation finden

Lernziel: alle Computer mit unbeschränkter Delegation bestimmen. **Voraussetzungen:** Modul ActiveDirectory, Leserecht.

Befehle zu Übung A

```
PS> Get-ADComputer -Filter {TrustedForDelegation -eq $true}
    -Properties TrustedForDelegation |
    Select-Object Name, Enabled, TrustedForDelegation
```

Erklärung: Der Filter wählt Computerkonten mit der Einstellung für unbeschränkte Delegation. Domänencontroller besitzen diese Einstellung standardmäßig, sie erscheinen deshalb in der Liste. Ein anderer Treffer ist ein Befund. **Erwartetes Ergebnis:** In einer sauberen Testdomäne erscheinen nur die Domänencontroller, oder niemand, je nach Aufbau. Jeder Server oder Arbeitsplatz in der Liste ist zu begründen. **Überprüfung:** Notiere die Treffer mit Zweck und Begründung. **Fehleranalyse:** Die Abfrage liefert zu viele Treffer? Prüfe, ob es Domänencontroller sind, und unterscheide sie von Mitgliedsservern.

Übung B: Beschränkte Delegation auslesen

Lernziel: Konten mit beschränkter Delegation und ihre Ziele feststellen. **Aufgabenstellung:** Suche alle Objekte mit einem Eintrag in msDS-AllowedToDelegateTo.

Befehle zu Übung B

```
PS> Get-ADObject -LDAPFilter "(msDS-AllowedToDelegateTo=*)"
    -Properties msDS-AllowedToDelegateTo |
    Select-Object Name, msDS-AllowedToDelegateTo
```

Erklärung: `-LDAPFilter` nutzt die Abfragesprache des Verzeichnisses, hier für Objekte mit gesetztem Attribut. Das Attribut selbst wird mit `-Properties` angefordert. Die Ausgabe zeigt jedes Ziel, an das ein Konto delegieren darf. **Erwartetes Ergebnis:** Die Liste enthält die Dienstkonten mit Delegation und ihre Ziele. Ist keine Delegation eingerichtet, bleibt die Liste leer. **Überprüfung:** Jedes Ziel muss zu einem Dienst gehören, den das Konto tatsächlich braucht. **Fehleranalyse:** Ein Ziel ist zu allgemein, etwa ein ganzer Dienstname ohne Host? Notiere es als Befund.

Übung C: Ressourcenbasierte Delegation prüfen

Lernziel: das Attribut auf einem Zielcomputer lesen. **Aufgabenstellung:** Prüfe, ob auf SRV01 eine ressourcenbasierte Delegation eingetragen ist.

Befehle zu Übung C

```
PS> Get-ADComputer -Identity SRV01 -Properties
    msDS-AllowedToActOnBehalfOfOtherIdentity |
    Select-Object Name, msDS-AllowedToActOnBehalfOfOtherIdentity
```

Erklärung: Das Attribut enthält eine Sicherheitsbeschreibung mit den Konten, die für diesen Computer delegieren dürfen. Ist es leer, besteht keine ressourcenbasierte Delegation. **Erwartetes Ergebnis:** In der Testdomäne ist das Attribut leer, sofern du keine Delegation eingerichtet hast. **Überprüfung:** Ein Eintrag ist ein Befund. Prüfe, wer ihn gesetzt hat und warum. **Fehleranalyse:** Der Wert ist eine Bytefolge und nicht lesbar? Das ist normal. Ein Eintrag zeigt sich durch seine Existenz, die Konten darin lassen sich mit einer Sicherheitsbeschreibung auflösen.

Übung D: Vertrauensstellungen prüfen

Lernziel: bestehende Vertrauensstellungen mit Richtung und Art erfassen. **Aufgabenstellung:** Lies alle Vertrauensstellungen der Domäne aus.

Befehle zu Übung D

```
PS> Get-ADTrust -Filter * | Select-Object Name, Direction,
    TrustType, ForestTransitive
```

Erklärung: Der Filter liefert alle Vertrauensstellungen. `Direction` zeigt die Richtung, `TrustType` die Art, `ForestTransitive` ob das Vertrauen die Gesamtstruktur überschreitet. **Erwartetes Ergebnis:** In einer einfachen Testdomäne ist die Liste leer. Jede Vertrauensstellung ist zu dokumentieren, mit Begründung und Gegenseite. **Überprüfung:** Prüfe, ob zu jeder Vertrauensstellung eine Gegenseite existiert, die du kennst. **Fehleranalyse:** Die Abfrage schlägt fehl? In einer Domäne ohne Vertrauensstellungen kann das Ergebnis leer sein, das ist kein Fehler.

Übung E: Riskante Delegation entfernen

Lernziel: eine unbeschränkte Delegation auf einem Testcomputer entfernen und die Änderung nachvollziehbar sichern. **Voraussetzungen:** Administratorkonto, Testcomputer SRV01 mit gesetzter unbeschränkter Delegation (zur Vorbereitung mit `Set-ADAccountControl -Identity SRV01 -TrustedForDelegation $true` setzen). **Aufgabenstellung:** Sichere den bisherigen Wert, entferne die unbeschränkte Delegation und prüfe das Ergebnis.

Befehle zu Übung E

```
PS> Get-ADComputer -Identity SRV01 -Properties
    TrustedForDelegation |
    Export-Clixml -Path .\srv01_delegation_backup.xml
PS> Set-ADAccountControl -Identity SRV01 -TrustedForDelegation
    $false
PS> Get-ADComputer -Identity SRV01 -Properties
    TrustedForDelegation | Select-Object Name,
    TrustedForDelegation
```

Erklärung: Die Sicherung speichert den vorherigen Zustand in einer Datei, die sich wieder einlesen lässt. `Set-ADAccountControl` schaltet die

Einstellung ab. Die letzte Zeile prüft das Ergebnis. **Erwartetes Ergebnis:** `TrustedForDelegation` ist danach `False`. Die Sicherungsdatei existiert. **Überprüfung:** Prüfe, ob die Anwendung auf SRV01, die diese Delegation vielleicht brauchte, noch funktioniert. Fällt sie aus, ist das ein Befund, der für eine sichere Konfiguration mit beschränkter Delegation zu lösen ist. **Fehleranalyse:** Der Befehl schlägt fehl? Prüfe die Berechtigung auf dem Computerkonto. **Sicherheitsbetrachtung:** Die Sicherungsdatei enthält Konfigurationsdaten. Behandle sie vertraulich und lösche sie nach dem Projekt.

Übung F: Sensibles Konto als nicht delegierbar markieren

Lernziel: ein Konto mit besonderem Schutzbedarf vor Delegation schützen. **Aufgabenstellung:** Markiere svc_backup als nicht delegierbar und prüfe die Einstellung.

Befehle zu Übung F

```
PS> Set-ADAccountControl -Identity svc_backup -AccountNotDelegated
    $true
PS> Get-ADUser -Identity svc_backup -Properties
    AccountNotDelegated | Select-Object SamAccountName,
    AccountNotDelegated
```

Erklärung: Die Einstellung AccountNotDelegated verhindert, dass Dienste die Anmeldung dieses Kontos delegieren. Das wirkt auch bei unbeschränkter und beschränkter Delegation. **Erwartetes Ergebnis:** `AccountNotDelegated` ist `True`. **Überprüfung:** Ist ein Dienst auf den Schutz angewiesen, der eine Delegation des Kontos braucht, fällt er aus. Das ist vorher zu prüfen.

Typische Fehler

- Unbeschränkte Delegation bleibt auf einem Server, weil niemand weiß, warum sie gesetzt wurde
- Ein SPN ist zu allgemein und öffnet unerwartete Ziele
- Das Recht, das Attribut für ressourcenbasierte Delegation zu schreiben, ist nicht kontrolliert
- Vertrauensstellungen werden ohne Gegenseite und Filterung betrieben

Zusammenfassung

- Unbeschränkte Delegation ist die gefährlichste Form, weil gespeicherte Tickets aller Anmeldenden weiterverwendet werden können.
- Beschränkte und ressourcenbasierte Delegation begrenzen die Ziele, ihre Listen sind aber zu prüfen.
- Vertrauensstellungen verbinden Sicherheitsgrenzen und brauchen Dokumentation und Filterung.
- Sensible Konten werden als nicht delegierbar markiert.

Kontrollfragen

1. Welcher Unterschied besteht zwischen unbeschränkter und beschränkter Delegation? (leicht)
2. Wo steht bei ressourcenbasierter Delegation die Liste der berechtigten Dienste? (leicht)
3. Warum ist die Kontrolle des Schreibrechts auf msDS-AllowedToActOnBehalfOfOtherIdentity wichtig? (mittel)
4. Ein Server mit unbeschränkter Delegation dient einer alten Anwendung. Welche Schritte priorisierst du? (mittel)
5. Eine Vertrauensstellung ist eingehend und ohne Filterung eingerichtet. Welche Wirkung hat das, und wie prüfst du, ob sie noch gebraucht wird? (schwer)

Lösungshinweise: 1. Unbeschränkt darf jedes Ziel angesprochen werden, beschränkt nur Ziele aus der Liste. 2. Im Attribut msDS-AllowedToActOnBehalfOfOtherIdentity des Zielcomputers. 3. Wer das Attribut schreiben kann, richtet eine Delegation auf dem Ziel ein, ohne Domänenadministrator zu sein. 4. Die Anwendung prüfen und auf beschränkte Delegation mit den nötigen Zielen umstellen. Solange die Umstellung läuft, den Server isolieren und die Anmeldungen überwachen. 5. Konten der Gegenseite können auf Ressourcen zugreifen, ohne dass das eingeschränkt ist. Prüfen lässt sich die Nutzung über Anmeldeereignisse auf der Gegenseite und die Abstimmung mit dem Betreiber.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die drei Delegationsarten unterscheidest und ihre Risiken benennst,
- [ ] Delegationen und Vertrauensstellungen in der Testdomäne findest,
- [ ] eine riskante Delegation sicherst, entfernst und prüfst,
- [ ] sensible Konten als nicht delegierbar markierst.

Kapitel 12: Active Directory absichern – Hardening

Lernziele

- Du erklärst die Grundprinzipien des Hardenings: geringste Rechte, Tiering, getrennte Administrationskonten.
- Du prüfst in der Testdomäne den Stand von LAPS, LDAP-Signierung, SMB-Signierung und NTLM-Einstellungen.
- Du setzt eine Härtung um und dokumentierst Ausgangszustand und Wirkung.

Gut zu wissen

Die Grundlagen zu Gruppenrichtlinien und zur Einrichtung von gMSA stehen in Band 2 der Windows-Security-Reihe (Kapitel 4 und 12). Dieses Kapitel setzt sie voraus und konzentriert sich auf Active-Directory-spezifische Härtung.

Grundprinzipien

Hardening bedeutet, die Angriffsfläche einer Domäne zu verkleinern, bevor ein Angriff stattfindet. Drei Prinzipien stehen im Vordergrund. Das Prinzip der geringsten Rechte gibt jedem Konto nur die Rechte, die es für seine Aufgabe braucht. Das Tiering-Modell trennt die Verwaltung nach der Bedeutung der Systeme. Getrennte Administrationskonten verhindern, dass ein tägliches Konto und ein Verwaltungskonto dieselbe Sitzung teilen.

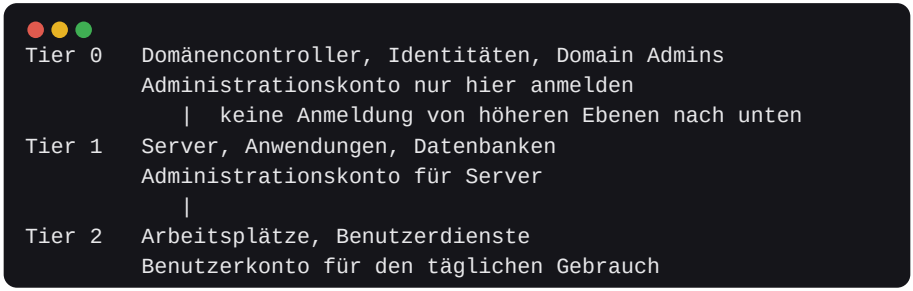
Least Privilege

Die Umsetzung beginnt mit einer Bestandsaufnahme: Welche Gruppe hat welche Rechte, und welches Konto braucht sie tatsächlich. Kapitel 8 zeigt, wie das Berechtigungsmodell gelesen wird. Ein Ergebnis dieser Prüfung ist fast immer eine Liste von Berechtigungen, die entfernt werden können. Die Entfernung erfolgt schrittweise, mit Sicherung und Beobachtung.

Tiering-Modell

Das Tiering-Modell teilt die Administration in drei Ebenen. Tier 0 umfasst die Domänencontroller und alles, was Identitäten verwaltet, also auch die Gruppen mit höchsten Rechten. Tier 1 umfasst Server und ihre Dienste. Tier 2 umfasst Arbeitsplätze und Benutzerdienste.

Diagramm 12.1: Tiering-Modell



Die Regel lautet: Ein Konto einer höheren Ebene meldet sich nie auf einer niedrigeren an. Dann ist ein Konto von Tier 2, das auf einem Arbeitsplatz kompromittiert wird, für Tier 0 wertlos, weil es dort nie angemeldet war. Kapitel 7 hat diese Logik am Beispiel der Anmeldedaten gezeigt.

Separate Administratorkonten

Ein Administrator hat ein tägliches Konto für E-Mail und Dokumente, und ein eigenes Konto für Verwaltungsarbeiten. Das Verwaltungskonto meldet sich nur auf Systemen seiner Ebene an. Die Namenskonvention macht die Trennung sichtbar, etwa adm.max für das Verwaltungskonto und max.mustermann für das tägliche Konto.

Privileged Access Workstations

Eine Privileged Access Workstation (PAW) ist ein Arbeitsplatz, der ausschließlich für Verwaltungsaufgaben der höchsten Ebenen genutzt wird. Sie ist gehärtet, hat kein Internet und keine Anwendungen für den Alltag. Das Ziel ist, dass die Anmeldedaten von Administratoren nur auf einem Gerät liegen, das ein Angreifer schwer erreicht. PAWs sind ein wirksames Mittel, aber mit Aufwand verbunden, und sie sind vor allem für Tier 0 sinnvoll.

Microsoft LAPS

Die lokalen Administratorkennwörter von Arbeitsplätzen und Servern sollten auf jedem System verschieden sein. Windows LAPS verwaltet diese Kennwörter, ändert sie regelmäßig und speichert sie im Verzeichnis, geschützt durch Berechtigungen. Welche Voraussetzungen gelten, hängt vom Speicherort der Kennwörter und vom Verwaltungsmodell ab. Bei der Speicherung im Verzeichnis ist ein Schema-Update nötig, die Konfiguration erfolgt über Richtlinien. Die genauen Voraussetzungen stehen in der Dokumentation zu Windows LAPS und sind für die eingesetzte Umgebung zu prüfen. Die ältere Lösung Microsoft LAPS ist durch Windows LAPS abgelöst; prüfe bei deiner Version, welche Komponente aktiv ist.

LDAP-Sicherheit

LDAP-Verbindungen können unverschlüsselt und unsigniert sein. Die Serversignierung verlangt, dass Clients ihre Anfragen signieren, und verhindert Manipulation. Der Kanalschutz (LDAP Channel Binding) bindet die Authentifizierung an den konkreten TLS-Kanal. Eine Authentifizierung, die ein Angreifer über einen anderen Kanal weiterleitet, wird damit abgelehnt. Beide Einstellungen wirken auf den Domänencontrollern und werden in der Regel über Gruppenrichtlinien für die Domänencontroller gesetzt. Eine einzelne Registrierung allein beschreibt die Wirkung nicht vollständig.

SMB-Signierung und NTLM-Einschränkungen

Die SMB-Signierung schützt die Integrität von Dateiverbindungen: Jede Nachricht trägt eine Signatur, die manipulierte Nachrichten erkennbar macht. Domänencontroller verlangen SMB-Signierung insbesondere für Zugriffe auf SYSVOL und NETLOGON. Welche weiteren SMB-Verbindungen standardmäßig signiert werden, hängt von der Windows-Version und der Rolle des Systems ab. Client- und Serverseite sind getrennt zu prüfen; gezielt wird die Anforderung über `RequireSecuritySignature` gesetzt. Dadurch werden Weiterleitungsangriffe auf Dateidienste erschwert, nicht ausgeschlossen. Die NTLM-Einschränkungen gehen weiter: Sie legen fest, welche Verfahren zulässig sind und wo NTLM überhaupt noch akzeptiert wird. Der Wert der Einstellung LmCompatibilityLevel bestimmt, welche Antworten der Server akzeptiert. Der Wert 5 bedeutet, dass nur NTLMv2-Antworten zulässig sind und LM sowie NTLMv1 abgelehnt werden.

Kerberos-Hardening

Kerberos wird gehärtet, indem Dienstkonten mit AES arbeiten, RC4 nicht mehr akzeptiert wird, Delegation nur bewusst eingerichtet ist und Konten mit besonderem Schutzbedarf als nicht delegierbar markiert sind. Kapitel 5 und 11 haben die einzelnen Schritte gezeigt.

Sichere Gruppenrichtlinien

GPOs sind das Werkzeug, mit dem Härtungen auf alle Systeme verteilt werden. Sie brauchen dieselbe Kontrolle wie Berechtigungen: Wer eine GPO ändern darf, bestimmt Einstellungen auf allen Systemen, auf die sie wirkt. Die Verknüpfungen werden überprüft, und Änderungen an kritischen GPOs sind zu protokollieren.

Passwort- und Kontosperrrichtlinien

Die Standardrichtlinie der Domäne legt Länge, Historie und Sperrschwelle fest. Feinabgestimmte Kennwortrichtlinien können für bestimmte Konten strengere Vorgaben setzen, etwa für Administratorkonten. Die Sperrschwelle schützt vor Kennwortversuchen, darf aber nicht so niedrig sein, dass sie einen Angriff auf Konten auslöst.

MFA und phishing-resistente Authentifizierung

Mehrfaktor-Authentifizierung erschwert die Nutzung gestohlener Kennwörter, schützt aber nicht gegen jede Form der Weitergabe von Anmeldedaten. Phishing-resistente Verfahren binden die Anmeldung an ein Gerät oder einen Schlüssel. Die Einführung betrifft vor allem Administratoren und den Zugang von außen, und sie ist eine Entscheidung für den Betrieb, nicht nur für die Technik.

Patchmanagement und Domänencontroller-Härtung

Domänencontroller sind die wertvollsten Systeme der Domäne und müssen den höchsten Schutz erhalten. Dazu gehören zeitnahe Patches, die Beschränkung der Anmeldungen auf Tier 0, die Überwachung der Dienste und die Trennung von anderen Rollen. Ein Domänencontroller, auf dem zugleich ein Dateiserver oder eine Webanwendung läuft, ist eine vermeidbare Schwachstelle.

Backup und Recovery

Ein Backup der Domäne ist nur nützlich, wenn es vollständig, geschützt und getestet ist. Der Systemzustand der Domänencontroller und die Wiederherstellung einzelner Objekte sind getrennte Themen. Kapitel 14 behandelt die Wiederherstellung nach einer Kompromittierung, die sich von einem Ausfall unterscheidet.

Praxis: Den Stand der Domäne prüfen und härten

Die Übungen laufen auf DC01 mit einem Administratorkonto. Sie prüfen Einstellungen und setzen eine Härtung um. Vor jeder Änderung wird der Ausgangszustand notiert.

Übung A: Separates Verwaltungskonto anlegen

Lernziel: die Trennung der Konten umsetzen. **Voraussetzungen:** Administratorkonto auf DC01.

Befehle zu Übung A

```
PS> New-ADUser -Name adm.max -SamAccountName adm.max -Enabled
    $true `
    -AccountPassword (Read-Host -AsSecureString "Kennwort für
        adm.max")
PS> Get-ADUser -Identity adm.max | Select-Object SamAccountName,
    Enabled
```

Erklärung: Das Konto adm.max ist das Verwaltungskonto. `Read-Host -AsSecureString` fragt das Kennwort ab, ohne es zu speichern. Das Konto erhält keine Mitgliedschaften, die über die Ebene hinausgehen, für die es gedacht ist. **Erwartetes Ergebnis:** Das Konto ist aktiv und hat keine

Gruppenmitgliedschaft außer den Standardgruppen. **Überprüfung:** `Get-ADPrincipalGroupMembership adm.max` zeigt die Gruppen des Kontos. **Fehleranalyse:** Das Kennwort wird abgelehnt? Die Richtlinie verlangt eine bestimmte Länge und Komplexität.

Übung B: Die Kennwortrichtlinie prüfen

Lernziel: die Standardrichtlinie und vorhandene feinabgestimmte Richtlinien erfassen.

Befehle zu Übung B

```
PS> Get-ADDefaultDomainPasswordPolicy | Select-Object
    MinPasswordLength, PasswordHistoryCount, LockoutThreshold,
    LockoutDuration
PS> Get-ADFineGrainedPasswordPolicy -Filter * | Select-Object
    Name, Precedence, MinPasswordLength
```

Erklärung: Die erste Abfrage zeigt die Standardrichtlinie, die zweite die feinabgestimmten Richtlinien mit ihrer Rangfolge. Eine Richtlinie mit niedrigerer Rangzahl gilt vor einer mit höherer. **Erwartetes Ergebnis:** Die Werte stehen in der Ausgabe. Die Bewertung erfolgt gegen die Vorgaben deines Betriebs. **Überprüfung:** Notiere die Werte mit Datum. Eine Änderung ist eine Entscheidung für die Gesamtdomäne.

Übung C: LDAP-Serversignierung prüfen

Lernziel: den Stand der LDAP-Signierung auf dem Domänencontroller bestimmen. **Voraussetzungen:** Administratorkonto, Zugriff auf DC01.

Befehle zu Übung C

```
PS> Get-ItemProperty -Path
    "HKLM:\SYSTEM\CurrentControlSet\Services\NTDS\Parameters"
    -Name LDAPServerIntegrity, LdapEnforceChannelBinding
```

Erklärung: `LDAPServerIntegrity` steuert die Serversignierung. Der Wert 1 entspricht der Richtlinie „None“ (Clients dürfen unsigniert binden), der Wert 2 der Richtlinie „Require signing“ (unsignierte Bindungen werden abgelehnt). `LdapEnforceChannelBinding` steuert den Kanalschutz: 0 steht für „Never“, 1 für „When supported“, 2 für „Always“. Die Zuordnung entspricht der Microsoft-Dokumentation KB4520412. Die Richtlinie kann über eine

Gruppenrichtlinie oder direkt in der Registry gesetzt sein, deshalb zeigt die Registry nur den gesetzten Wert, nicht die Wirkung aller Schutzfunktionen. **Erwartetes Ergebnis:** Für eine gehärtete Domäne ist `LDAPServerIntegrity` 2 und `LdapEnforceChannelBinding` 2. Fehlt ein Wert, gilt der Standard der Richtlinie, und das ist ein Befund. **Überprüfung:** Vergleiche die Werte mit der wirksamen Gruppenrichtlinie (`gpresult /r` auf dem Domänencontroller). Zusätzlich liefert die Auditierung der Ereignisse 2886 bis 2889 und 3039 bis 3041 Hinweise auf unsignierte Bindungen und fehlenden Kanalschutz. Die Ereignisse müssen für deine Version aktiviert sein. Prüfe das in der Dokumentation zu KB4520412. **Fehleranalyse:** Der Wert fehlt? Dann ist die Einstellung nicht gesetzt, und der Standard gilt. Das ist ein Befund.

Übung D: NTLM-Stufe und SMB-Signierung prüfen

Lernziel: die NTLM-Einstellung und die SMB-Signierung des Servers lesen. **Voraussetzungen:** Administratorkonto auf SRV01 für die SMB-Abfrage.

Befehle zu Übung D

```
PS> Get-ItemProperty -Path
    "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name
    LmCompatibilityLevel
PS> Get-SmbServerConfiguration | Select-Object
    RequireSecuritySignature, EnableSecuritySignature
PS> Get-SmbClientConfiguration | Select-Object
    RequireSecuritySignature
```

Erklärung: `LmCompatibilityLevel` legt fest, welche Antworten der Server akzeptiert. Der Wert 5 erlaubt nur NTLMv2. Bei SMB 2 und SMB 3 ist allein `RequireSecuritySignature` maßgeblich: Ist der Wert `True`, wird Signierung verlangt. `EnableSecuritySignature` wirkt bei SMB 2 und 3 nicht, es ist eine Einstellung für SMB1. Die Ausgabe wird deshalb nur nach `RequireSecuritySignature` beurteilt. Signierung findet nur nicht statt, wenn Client und Server beide `RequireSecuritySignature` auf 0 haben. **Erwartetes Ergebnis:** Auf einem gehärteten Server steht `LmCompatibilityLevel` auf 5 und `RequireSecuritySignature` auf `True`. Abweichungen sind Befunde. `EnableSecuritySignature` wird nicht bewertet. Für ausgehende Verbindungen wird zusätzlich die Clientseite betrachtet (`Get-SmbClientConfiguration`, Übung D). **Überprüfung:**

Notiere die Werte für jeden Server. **Fehleranalyse:** Die SMB-Abfrage ist nicht verfügbar? Das Cmdlet gehört zum Serverbetriebssystem und ist auf Clients nicht immer vorhanden.

Übung E: Eine Härtung umsetzen und ihre Wirkung prüfen

Lernziel: eine Härtung mit Vorher-Nachher-Vergleich durchführen. **Aufgabenstellung:** Erzwinge für das Dienstkonto svc_backup aus Kapitel 5 die AES-Verschlüsselung und halte den Zustand vorher und nachher fest.

Befehle zu Übung E

```
PS> Get-ADUser -Identity svc_backup -Properties
    msDS-SupportedEncryptionTypes |
    Select-Object SamAccountName, msDS-SupportedEncryptionTypes
PS> Set-ADUser -Identity svc_backup -Replace
    @{'msDS-SupportedEncryptionTypes'=24}
PS> Get-ADUser -Identity svc_backup -Properties
    msDS-SupportedEncryptionTypes | Select-Object
    msDS-SupportedEncryptionTypes
```

Erklärung: Die erste Zeile erfasst den Ausgangszustand. Die zweite erzwingt AES, wie in Kapitel 5 beschrieben. Die dritte prüft das Ergebnis. Die nicht-delegierbare Markierung aus Kapitel 11, Übung F, ist davon unabhängig und bleibt unverändert. **Erwartetes Ergebnis:** Der Wert ist 24 (AES128 und AES256 ohne RC4). **Überprüfung:** Vergleiche Vorher und Nachher und halte beides mit Zeit im Protokoll fest. **Fehleranalyse:** Ein Dienst fällt aus? Eine Anwendung unterstützt AES nicht. Dokumentiere das und entscheide mit dem Betrieb.

Übung F: Dokumentation des Ausgangszustands

Lernziel: den Stand der Härtung als Bericht festhalten. **Aufgabenstellung:** Fasse die Ergebnisse der Übungen A bis E in einer Tabelle zusammen: Einstellung, Ausgangswert, Zielwert, Befund, Maßnahme. **Erwartetes Ergebnis:** Eine Tabelle, in der jede Zeile eine Einstellung mit Befund und Maßnahme enthält. **Überprüfung:** Ist jede Abweichung mit einer Maßnahme oder einer begründeten Ausnahme verknüpft?

Typische Fehler

• Verwaltungskonten werden nicht getrennt und melden sich auf Arbeitsplätzen an

• LDAP-Signierung ist eingestellt, aber nicht wirksam, weil eine Gruppenrichtlinie fehlt

• NTLM bleibt auf Stufen erlaubt, die kein Dienst braucht

• Eine Härtung wird ohne Vorher-Nachher-Vergleich umgesetzt

• Ein Domänencontroller trägt Rollen, die nicht zu Tier 0 gehören

> **Zusammenfassung**
>
> • Least Privilege, Tiering und getrennte Administrationskonten sind die Grundlage jeder Härtung.
> • LDAP-Signierung, SMB-Signierung und NTLM-Stufen müssen wirksam sein, nicht nur konfiguriert.
> • Änderungen an Richtlinien, GPOs und Berechtigungen werden vorher erfasst und nachher geprüft.
> • Die Dokumentation des Ausgangszustands ist Teil der Maßnahme.

Kontrollfragen

1. Was verbietet das Tiering-Modell? (leicht)
2. Welcher Wert von LmCompatibilityLevel erlaubt nur NTLMv2? (leicht)
3. Warum reicht eine gesetzte Einstellung für LDAP-Signierung nicht aus, um die Wirkung zu belegen? (mittel)
4. Ein Administrator meldet sich an einem Arbeitsplatz mit dem Verwaltungskonto an. Welche Regel wird verletzt, und welche Maßnahme ist zuerst nötig? (mittel)
5. Eine Härtung blockiert eine alte Anwendung. Wie gehst du vor, ohne die Härtung zurückzunehmen? (schwer)

Lösungshinweise: 1. Dass ein Konto einer höheren Ebene sich auf einer niedrigeren Ebene anmeldet. 2. 5. 3. Der Registrywert zeigt den gesetzten Zustand, aber die Wirkung zeigt sich erst, wenn die Richtlinie auf den Domänencontrollern angewendet wurde und Clients signieren. Die Prüfung

umfasst Richtlinie, Registrywert und Verhalten. 4. Die Trennung nach Ebenen. Zuerst muss das Verwaltungskonto von Arbeitsplätzen abgemeldet und auf Tier-0-Systeme beschränkt werden. 5. Die Anwendung prüfen, die betroffene Stelle isolieren, Ausnahme dokumentieren und zeitlich begrenzt festlegen, bis die Anwendung angepasst ist. Die Härtung bleibt bestehen.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] Tiering, Least Privilege und getrennte Konten erklären kannst,
- [ ] LDAP-Signierung, SMB-Signierung und NTLM-Stufen prüfst,
- [ ] eine Härtung mit Vorher-Nachher-Vergleich umsetzt,
- [ ] Ausnahmen begründet dokumentierst.

Kapitel 13:
Active-Directory-Monitoring und Angriffserkennung

Lernziele

- Du benennst die Protokollquellen, die für die Erkennung von Angriffen auf Active Directory nötig sind.
- Du aktivierst und prüfst die erweiterte Überwachung und die Protokollierung von PowerShell.
- Du formulierst eine einfache Erkennungsregel und prüfst sie anhand von Ereignissen.

Warum Monitoring Angriffe überhaupt sichtbar macht

Die meisten Angriffe auf Active Directory bestehen aus Vorgängen, die legitim aussehen: Anmeldungen, Ticketanforderungen, Abfragen des Verzeichnisses. Sichtbar werden sie erst, wenn Protokolle vorhanden sind, Ereignisse gezielt aktiviert wurden und jemand sie auswertet. Ohne Monitoring bleibt ein Angriff unbemerkt, auch wenn alle Spuren vorhanden sind.

Monitoring ist deshalb kein Zusatz zur Härtung, sondern deren Gegenstück. Die Härtung verkleinert die Angriffsfläche, das Monitoring zeigt, wann jemand sie trotzdem nutzt.

Windows-Ereignisprotokolle

Das Sicherheitsprotokoll (Security) enthält Anmeldungen, Kontoänderungen, Gruppenänderungen und Zugriffe auf Objekte. Das Verzeichnisdienst-Protokoll (Directory Service) zeigt Änderungen am Verzeichnis selbst, wenn die entsprechende Überwachung aktiv ist. Das Systemprotokoll enthält Dienste und Treiber der Domänencontroller. Das PowerShell-Protokoll dokumentiert Skriptausführungen, wenn die Protokollierung aktiv ist.

Die Quellen unterscheiden sich in Umfang und Standardeinstellung. Viele wichtige Ereignisse entstehen nur, wenn die Überwachung ausdrücklich eingeschaltet ist. Das ist die häufigste Lücke.

Erweiterte Überwachungsrichtlinie

Die klassische Überwachung ist grob. Die erweiterte Überwachungsrichtlinie (Advanced Audit Policy) steuert einzelne Kategorien, etwa Kontoverwaltung, Anmeldung, Kerberos-Dienstticketvorgänge und Verzeichnisdienstzugriffe. Sie wird über Gruppenrichtlinien gesetzt und lässt sich mit `auditpol` prüfen. Die Namen der Kategorien hängen von der Systemsprache ab.

> **Gut zu wissen**
>
> Erfolgreiche und fehlgeschlagene Vorgänge sollten jeweils getrennt überwacht werden. Ein Anstieg fehlgeschlagener Anmeldungen ist ein anderer Befund als eine Serie erfolgreicher Ticketanforderungen. Beide Richtungen gehören in die Konfiguration.

Sysmon

Sysmon ist ein Dienst von Microsoft, der Prozessstarts, Netzwerkverbindungen, Dateierstellungen und Registry-Änderungen in einem eigenen Protokoll festhält. Er wird separat installiert und mit einer Konfigurationsdatei gesteuert. Für die Erkennung ist Sysmon besonders wertvoll, weil er Vorgänge auf dem Endgerät sichtbar macht, die im Sicherheitsprotokoll fehlen. Die Konfigurationsdatei muss aus einer vertrauenswürdigen Quelle stammen und zur eigenen Umgebung passen.

Wichtige Ereignis-IDs

Für die Erkennung im Verzeichnis sind folgende Ereignisse zentral:

- 4720 (Konto angelegt), 4722 (Konto aktiviert), 4726 (Konto gelöscht)
- 4728, 4732, 4756 (Mitglied zu einer Gruppe hinzugefügt)
- 4738 (Kontoeigenschaften geändert), 4740 (Konto gesperrt)
- 4662 (Vorgang an einem Verzeichnisobjekt), 5136 (Verzeichnisobjekt geändert), 4670 (Berechtigungen geändert)
- 4768, 4769, 4771 (Kerberos-Anforderungen), 4776 (NTLM-Prüfung)
- 4104 (PowerShell-Skriptblock, wenn die Protokollierung aktiv ist)
- 1102 (Sicherheitsprotokoll gelöscht)

Die Kennungen stammen aus der Microsoft-Dokumentation zu Windows-Sicherheitsereignissen. Prüfe sie für deine Version, bevor du Regeln darauf aufbaust.

Erkennung von Gruppenänderungen

Änderungen an privilegierten Gruppen sind eine der wichtigsten Erkennungsregeln. Jede Aufnahme in Domain Admins, Enterprise Admins oder eine andere Verwaltungsgruppe erzeugt eines der Gruppenereignisse. Die Regel ist einfach: Jede solche Aufnahme wird gemeldet und geprüft, ob sie angekündigt war. Eine ungeplante Aufnahme ist ein Vorfall, bis das Gegenteil belegt ist.

Kerberos-Ereignisse

Die Ereignisse 4768 und 4769 zeigen Ticketanforderungen. Das Feld Ticket Encryption Type nennt den Typ des ausgestellten Tickets im hexadezimalen Format, 0x17 steht für RC4, 0x12 für AES256 und 0x11 für AES128. Das Feld ist nicht der Wert von `msDS-SupportedEncryptionTypes`, sondern der tatsächlich verwendete Typ (Kapitel 5). Das Feld Session Encryption Type nennt den Sitzungsschlüssel. Die Felder mit den unterstützten Typen des Kontos werden nur bei der Kontosuche befüllt und fehlen daher häufig im Ereignis. Eine Regel kann Häufungen von Anforderungen eines einzelnen Kontos über viele Dienstnamen zählen und den RC4-Anteil messen. Die Schwelle muss zur Umgebung passen, sonst entsteht Rauschen. Eine Ereignis-ID allein beweist keinen Angriff: RC4 kann auch legitime Altsysteme betreffen, und ein Fehlercode ungleich 0x0 bedeutet, dass die Anforderung fehlgeschlagen ist. Der Kontext entscheidet, etwa ob der Dienst existiert, welches Konto anfordert und wie viele verschiedene Dienste in welchem Zeitraum angefragt werden.

DCSync-Erkennung

DCSync bezeichnet das Anfordern von Replikationsdaten durch ein Konto, das dafür nicht Domänencontroller ist, sondern nur bestimmte Replikationsrechte besitzt. Die Erkennung beruht auf dem Ereignis 4662 an der Domäne, wenn Replikationsrechte genutzt werden. Die Berechtigungen für Replikation sind in der Dokumentation nach Namen aufgeführt. Ein Konto außerhalb der Domänencontroller, das sie nutzt, ist ein verdächtiger Befund, kein automatischer Beweis für einen Angriff. Synchronisationsdienste können legitim Replikationsrechte besitzen; dokumentierte Ausnahmen sind zu berücksichtigen. Der Nachweis setzt voraus, dass die Überwachung aktiv ist und die SACL des Domänenobjekts das Ereignis 4662 erzeugt.

SIEM, Microsoft Sentinel und Defender for Identity

Ein SIEM sammelt Ereignisse aus vielen Quellen und wertet sie zentral aus. Microsoft Sentinel ist ein solches Produkt in der Cloud, Microsoft Defender for Identity überwacht Identitäten in der Domäne und erkennt bekannte Angriffsmuster. Beide Lösungen setzen die oben beschriebenen Quellen voraus. Ohne aktive Überwachung liefern sie nichts. Die Einführung ist eine Entscheidung für Lizenz, Betrieb und Zuständigkeit und nicht nur für die Technik.

MITRE ATT&CK und die Erkennung

Die Erkennungsregeln lassen sich den Techniken aus Kapitel 4 zuordnen. Kerberoasting und AS-REP Roasting entsprechen den Ereignissen 4769 und 4768. Pass-the-Hash entspricht Anmeldeereignissen mit NTLM. Kontoänderungen entsprechen den Gruppenereignissen. Diese Zuordnung macht eine Regelliste überprüfbar: Jede Technik hat mindestens eine Regel, und jede Regel gehört zu einer Technik.

Diagramm 13.1: Workflow von Erkennung bis Reaktion

```
Quelle (Security, Directory Service, Sysmon, PowerShell)
  -> Erkennungsregel (Ereignis-ID, Muster, Schwelle)
  -> Alarm mit Kontext (Konto, Zeit, Quelle, Ziel)
  -> Prüfung: angekündigt oder unbekannt?
  -> bei Unbekanntem: Vorfall nach Kapitel 14
  -> Regel anpassen und Ergebnis dokumentieren
```

Praxis: Überwachung aktivieren und Ereignisse auswerten

Die Übungen laufen auf DC01 und CLIENT01 mit einem Administratorkonto. Sie aktivieren Überwachung und werten Ereignisse aus, die du selbst erzeugst.

Übung A: Erweiterte Überwachung prüfen

Lernziel: den aktuellen Stand der Überwachung erfassen.
Voraussetzungen: Administratorkonto auf DC01.

Befehle zu Übung A

```
PS> auditpol /get /category:*
```

Erklärung: `auditpol` zeigt für jede Kategorie, ob Erfolg oder Fehler protokolliert werden. Die Kategorien heißen in deutschen Systemen anders als in englischen, deshalb nutzt die Ausgabe die Sprache des Systems. **Erwartetes Ergebnis:** Eine Liste der Kategorien mit den Einstellungen Erfolg, Fehler, beides oder keine Überwachung. **Überprüfung:** Notiere für Kontoverwaltung, Anmeldung, Kerberos-Dienstticketvorgänge und Verzeichnisdienstzugriffe den aktuellen Wert. **Fehleranalyse:** Eine Kategorie ist nicht überwacht? Das ist ein Befund. Die Änderung erfolgt über die Gruppenrichtlinie, nicht durch einen einzelnen Befehl auf dem Server.

Übung B: PowerShell-Protokollierung prüfen

Lernziel: feststellen, ob Skriptblöcke protokolliert werden.
Aufgabenstellung: Prüfe den Registrywert für die Skriptblockprotokollierung auf DC01.

Befehle zu Übung B

```
PS> Get-ItemProperty -Path
    "HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBl
    ockLogging" -Name EnableScriptBlockLogging
```

Erklärung: Der Wert 1 aktiviert die Protokollierung. Fehlt der Schlüssel, ist sie nicht konfiguriert. **Erwartetes Ergebnis:** Der Wert 1. Fehlt er, ist das ein Befund, und die Richtlinie wird ergänzt. **Überprüfung:** Führe einen einfachen Befehl aus und suche das Ereignis 4104 im PowerShell-Protokoll. **Fehleranalyse:** Der Schlüssel fehlt, obwohl die Richtlinie gesetzt sein sollte? Prüfe, ob die Richtlinie auf DC01 angewendet wurde (`gpresult /r`).

Übung C: Kontoänderungen und Gruppenaufnahmen finden

Lernziel: die Ereignisse für Kontoanlage und Gruppenaufnahme lesen.

Befehle zu Übung C

```
PS> Get-WinEvent -FilterHashtable @{LogName='Security';
    Id=4720,4728,4732,4756} -MaxEvents 20 |
    Format-List TimeCreated, Id, Message
```

Erklärung: Der Filter wählt Kontoanlagen und Gruppenaufnahmen. Die Ausgabe enthält Zeit, Kennung und Text. Ereignis 4728 betrifft globale Gruppen, 4732 lokale Gruppen, 4756 universelle Gruppen. **Erwartetes Ergebnis:** Ereignisse für die Konten und Gruppen, die du in den vorigen Kapiteln angelegt hast. **Überprüfung:** Jede Aufnahme in eine Gruppe mit Verwaltungsrechten muss sich einem geplanten Vorgang zuordnen lassen.

Übung D: Kerberos-Anforderungen mit RC4 zählen

Lernziel: den RC4-Anteil der Dienstticketanforderungen bestimmen.

Befehle zu Übung D

```
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4769}
    -MaxEvents 200 |
    Where-Object { $_.Message -match 'Ticket Encryption
        Type:\s+0x17' } | Measure-Object
```

Erklärung: Der Filter wählt die letzten 200 Ticketanforderungen. Der zweite Schritt zählt jene mit dem Verschlüsselungstyp 0x17, also RC4. `Measure-Object` gibt die Anzahl aus. **Erwartetes Ergebnis:** Die Anzahl. Nach der Umstellung aus Kapitel 5 sollte sie für svc_backup nicht mehr steigen. **Überprüfung:** Vergleiche Anzahl und Zeitraum mit deinen Übungen aus Kapitel 5. **Fehleranalyse:** Es ist kein Treffer vorhanden? Ältere Ereignisse sind möglicherweise schon überschrieben. Erhöhe die Ereignismenge oder prüfe die Größe des Protokolls.

Übung E: Sysmon installieren und prüfen

Lernziel: Sysmon mit einer geprüften Konfiguration einrichten und die Protokollquelle kontrollieren. **Voraussetzungen:** Sysmon heruntergeladen von der Microsoft-Seite, Konfigurationsdatei aus einer vertrauenswürdigen Quelle, Administratorkonto auf CLIENT01.

Befehle zu Übung E

```
PS> .\Sysmon64.exe -accepteula -i sysmonconfig.xml
PS> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational"
    -MaxEvents 10 | Format-List TimeCreated, Id, Message
```

Erklärung: `-accepteula` akzeptiert die Lizenz bei der Installation, `-i` installiert den Dienst mit der angegebenen Konfiguration. Die zweite Zeile liest das Sysmon-Protokoll. **Erwartetes Ergebnis:** Eine Liste mit Sysmon-Ereignissen, etwa Prozessstarts mit der Kennung 1. **Überprüfung:** Starte einen Prozess und finde das zugehörige Ereignis. **Fehleranalyse:** Keine Ereignisse? Die Konfiguration enthält möglicherweise Filter, die den Prozess ausschließen. Prüfe die Konfiguration. **Sicherheitsbetrachtung:** Lade Sysmon nur von der offiziellen Quelle. Prüfe die Konfigurationsdatei, bevor du sie einsetzt, denn sie bestimmt, was erfasst wird.

Übung F: Eine Erkennungsregel dokumentieren und prüfen

Lernziel: eine Regel aufschreiben und mit einem echten Ereignis belegen. **Aufgabenstellung:** Formuliere für Aufnahmen in Domain Admins eine Regel nach dem Schema Quelle, Ereignis-ID, Bedingung, Reaktion. Prüfe sie, indem du einen Testbenutzer vorübergehend aufnimmst und das Ereignis findest.

Befehle zu Übung F

```
PS> Add-ADGroupMember -Identity "Domain Admins" -Members testuser
PS> Get-WinEvent -FilterHashtable @{LogName='Security';
    Id=4728,4732,4756} -MaxEvents 5 | Format-List TimeCreated,
    Message
PS> Remove-ADGroupMember -Identity "Domain Admins" -Members
    testuser -Confirm:$false
```

Erklärung: Der Befehl nimmt den Testbenutzer in die Gruppe auf, das Ereignis dokumentiert die Aufnahme. Der letzte Befehl entfernt den Testbenutzer wieder. Die Reihenfolge stellt sicher, dass die Regel gegen ein reales Ereignis getestet wird. **Erwartetes Ergebnis:** Ein Ereignis mit dem Kontonamen testuser und der Gruppe Domain Admins. Danach ist testuser wieder außerhalb der Gruppe. **Überprüfung:** Die Regel erkennt die Aufnahme über die Kennung und den Gruppennamen. **Sicherheitsbetrachtung:** Nimm den Testbenutzer nur für den Test auf und entferne ihn sofort wieder. Die Übung ändert eine privilegierte Gruppe und gehört nur in die isolierte Testdomäne.

Typische Fehler

- Die erweiterte Überwachung ist nicht gesetzt, und die Ereignisse fehlen

• Ereignisprotokolle sind zu klein und werden überschrieben, bevor jemand sie liest

• Erkennungsregeln erzeugen so viele Alarme, dass sie ignoriert werden

• Eine Sysmon-Konfiguration wird ungeprüft aus dem Netz übernommen

• Eine Regel wird nie gegen ein echtes Ereignis getestet

> **Zusammenfassung**
>
> • Angriffe auf Active Directory werden durch Protokolle sichtbar, die aktiv sein müssen.
> • Die erweiterte Überwachung, die PowerShell-Protokollierung und Sysmon liefern die Grundlage.
> • Gruppenänderungen, Kerberos-Anforderungen und DCSync-Muster sind die wichtigsten Erkennungsregeln.
> • Jede Regel wird gegen ein reales Ereignis getestet und einer Technik zugeordnet.

Kontrollfragen

1. Warum reicht das Sicherheitsprotokoll allein oft nicht aus? (leicht)

2. Welches Ereignis zeigt die Aufnahme eines Kontos in eine Gruppe? (leicht)

3. Warum ist ein Anstieg von RC4-Anforderungen ein Befund, und was muss die Schwelle berücksichtigen? (mittel)

4. Eine Erkennungsregel erzeugt täglich hundert Alarme, die niemand prüft. Was ist das Problem, und wie gehst du vor? (mittel)

5. Eine Gruppenaufnahme in Domain Admins findet sich im Protokoll, aber niemand kennt sie. Welche Schritte folgen? (schwer)

Lösungshinweise: 1. Viele Vorgänge, etwa Vorgänge auf dem Endgerät, werden nur mit Sysmon oder mit aktivierter erweiterter Überwachung protokolliert. 2. Eines der Gruppenereignisse, zum Beispiel 4728 oder 4732. 3. RC4 ist für Kerberoasting typisch, aber auch in Altsystemen normal. Die Schwelle muss die Umgebung kennen. 4. Die Regel ist zu breit, und Alarmmüdigkeit entsteht. Die Regel wird eingegrenzt, um die echten Fälle sichtbar zu machen, und jeder Alarm erhält eine Zuständigkeit. 5. Der Vorfall

wird nach Kapitel 14 behandelt: Sicherung der Protokolle, Bewertung des Kontos, Klärung mit den Verantwortlichen und gegebenenfalls Entfernung und Untersuchung.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die Überwachung auf dem Domänencontroller prüfst,
- [ ] Gruppen- und Kerberos-Ereignisse findest und deutest,
- [ ] Sysmon installierst und seine Ereignisse liest,
- [ ] eine Erkennungsregel formulierst und gegen ein echtes Ereignis prüfst.

Kapitel 14: Incident Response bei kompromittiertem Active Directory

Lernziele

- Du unterscheidest einen kleineren Sicherheitsvorfall von einer vollständigen Domänenkompromittierung.
- Du beschreibst die Phasen der Reaktion von der ersten Bewertung bis zu den Lessons Learned.
- Du erklärst, warum eine kompromittierte Domäne nicht durch ein einzelnes Kennwort wieder vertrauenswürdig wird.

WARNUNG – Sicherheitsrisiko

Dieses Kapitel beschreibt die Reaktion auf einen Vorfall. Die Übungen laufen in der Testdomäne. Mehrere Schritte, etwa der Kennwortwechsel des krbtgt-Kontos, betreffen die gesamte Domäne und dürfen in einer produktiven Umgebung nur nach einem abgestimmten Plan erfolgen.

Kleiner Vorfall oder Domänenkompromittierung

Nicht jeder Verdacht ist eine Domänenkompromittierung. Ein kleiner Vorfall betrifft ein Konto oder einen Rechner, ohne dass der Angreifer die höchsten Rechte erlangt hat. Er wird lokal bereinigt, das betroffene Konto wird gewechselt, und die Ursache wird behoben.

Eine Domänenkompromittierung liegt vor, wenn der Angreifer die höchsten Rechte besitzt oder Anmeldedaten aller Konten erhalten kann. Dann reicht die lokale Bereinigung nicht mehr, weil der Angreifer sich jederzeit neu einrichten kann. Die Unterscheidung bestimmt den gesamten Ablauf der Reaktion.

Verdacht auf Domänenkompromittierung

Ein Verdacht entsteht aus einem Ereignis, einer Beobachtung oder einer Meldung. Typische Auslöser sind eine ungeplante Aufnahme in Domain Admins, ein gelöschtes Sicherheitsprotokoll, eine Erkennung aus Kapitel 13 oder eine Meldung eines Nutzers. Der Verdacht wird als Vorfall eröffnet, mit Zeit, Quelle und verantwortlicher Person.

Erste Bewertung

Die erste Bewertung beantwortet vier Fragen. Welche Konten und Systeme sind betroffen? Welche Rechte hatten sie? Seit wann ist der Vorfall nachweisbar? Gibt es Hinweise auf höhere Rechte? Die Antworten bestimmen, ob der Vorfall klein oder groß ist. Die Bewertung ist vorläufig und wird im Verlauf korrigiert.

Eindämmung

Eindämmung verhindert, dass der Angriff weiterläuft, ohne die Spuren zu zerstören. Dazu gehört das Sperren oder Deaktivieren betroffener Konten, das Trennen auffälliger Verbindungen und die Einschränkung des Netzes, etwa durch Isolation eines Servers. Jede Maßnahme wird vorher festgelegt und dokumentiert, weil sie den Angreifer warnen kann.

Beweissicherung

Vor den Eingriffen in die Domäne werden die Protokolle gesichert. Die Protokolle der Domänencontroller sind die wichtigsten Quellen. Ihre Sicherung folgt den Grundsätzen aus den Kapiteln 3 bis 5: Hashwert, Protokoll der Sicherung, Aufbewahrung. Die Sicherung erfolgt möglichst früh und vor den Änderungen, sonst gehen Spuren verloren. Bei akuter Gefahr, etwa einem laufenden Datenabfluss, darf eine notwendige Eindämmung nicht wegen der Sicherung verzögert werden. In diesem Fall wird die Sicherung so früh wie möglich nachgeholt, und die Entscheidung über die Reihenfolge wird dokumentiert.

> **Gut zu wissen**
>
> Snapshots virtueller Domänencontroller sind riskant. Die Rückkehr eines Controllers auf einen älteren Zustand kann die Replikation stören (USN-Rollback). Die Sicherung des Systemzustands oder die Vorgaben des Herstellers für virtualisierte Domänencontroller haben Vorrang vor einem Snapshot.

Analyse privilegierter Konten

Die privilegierten Konten werden auf unerwartete Änderungen geprüft: Gruppenmitgliedschaften, Kennwortänderungen, neu angelegte Konten, veränderte Berechtigungen. Die Änderungszeiten zeigen den Zeitraum des Vorfalls. Jede Änderung ohne geplanten Vorgang wird dem Vorfall zugeordnet, bis das Gegenteil belegt ist.

Untersuchung des krbtgt-Kontos

Das Konto krbtgt ist das Konto, dessen langfristiger Schlüssel der KDC zum Verschlüsseln der Ticket-Granting-Tickets verwendet. Wer seinen Kennwortschlüssel besitzt, kann selbst gültige Tickets erzeugen, deshalb ist es ein zentraler Prüfpunkt. Das Alter des Kennworts zeigt, wie lange ein solcher Schlüssel bestehen kann.

Untersuchung von Domänencontroller-Änderungen

Änderungen an Domänencontrollern umfassen Dienste, geplante Aufgaben, Gruppenrichtlinien und Replikationsrechte. Jede dieser Änderungen kann ein Hinterlassen sein, das den Zugang nach der Bereinigung erhält. Die Prüfung umfasst also nicht nur die Konten, sondern auch die Systeme, auf denen die Domäne läuft.

Credential Rotation

Nach der Eindämmung werden die Anmeldedaten betroffener Konten erneuert: Kennwörter, Dienstkonten, gMSA-Konten und alle Geheimnisse, die aus den Systemen gelesen werden konnten. Die Reihenfolge ist wichtig, weil ein Wechsel an der falschen Stelle den Angreifer nicht aussperrt. Die Erneuerung folgt dem Plan und wird pro Konto dokumentiert.

Wiederherstellung und KRBTGT-Kennwortwechsel

Der Wechsel des krbtgt-Kennworts ist ein Schritt der Wiederherstellung, aber kein Ersatz für sie. Nach der Herstellerdokumentation wird das Kennwort zweimal mit einem Abstand gewechselt, damit Tickets, die mit dem alten Schlüssel ausgestellt wurden, ablaufen. Der Abstand und die Reihenfolge stehen in der aktuellen Dokumentation, sie werden nicht frei gewählt.

Vertrauenswürdige Wiederherstellung

Eine Domäne gilt erst als vertrauenswürdig wieder, wenn der Angreifer keinen Zugang mehr besitzt. Das erfordert, dass alle Mechanismen geprüft sind, mit denen er sich eingerichtet haben könnte: Konten, Gruppen, Gruppenrichtlinien, Delegationen, Replikationsrechte, Dienste und die Schlüssel der Domäne. Ein einzelnes Kennwort zu ändern, lässt alle übrigen Wege offen.

Ein Beispiel verdeutlicht das. Der Administrator ändert sein Kennwort, der Angreifer besitzt aber ein zusätzliches Konto mit Replikationsrechten, das niemand kennt. Der Angreifer bleibt dann Herr über die Domäne, obwohl das bekannte Konto sicher ist.

Überwachung nach dem Vorfall

Nach der Wiederherstellung wird die Überwachung verstärkt, bis mindestens eine Periode ohne Auffälligkeiten vergangen ist. Die Erkennungsregeln aus Kapitel 13 werden für die betroffenen Konten enger gefasst. Die Dauer der erhöhten Überwachung wird festgelegt und dokumentiert.

Dokumentation und Lessons Learned

Die Dokumentation hält fest, was passiert ist, wer was entschieden hat, welche Maßnahmen umgesetzt wurden und welche Lücken offen bleiben. Die Lessons Learned fragen, warum der Angriff möglich war, warum er nicht früher erkannt wurde und welche Härtung oder Regel das verhindert hätte. Der Bericht trennt Beobachtungen, Schlussfolgerungen und offene Fragen, wie in Kapitel 10 gezeigt.

Diagramm 14.1: Phasen der Reaktion

```
1. Verdacht eröffnen (Zeit, Quelle, Verantwortliche)
2. Erste Bewertung (Umfang, Rechte, Zeitraum)
3. Beweissicherung so früh wie möglich (Protokolle vor den Änderungen)
4. Eindämmung (Konten, Verbindungen, Netz); bei akuter Gefahr nicht verzögern
5. Analyse privilegierter Konten und Systeme
6. Credential Rotation nach Plan
7. Wiederherstellung und KRBTGT-Wechsel nach Herstellerdokumentation
8. Überwachung und Dokumentation
9. Lessons Learned
```

Praxis: Einen Vorfall in der Testdomäne bearbeiten

Die Übungen laufen auf DC01 mit einem Administratorkonto. Sie simulieren einen Vorfall mit dem Testbenutzer testuser, der vorübergehend in eine privilegierte Gruppe aufgenommen wurde.

Übung A: Erste Bewertung

Lernziel: den Umfang eines Verdachts mit Abfragen bestimmen.

Befehle zu Übung A

```
PS> Get-ADGroupMember -Identity "Domain Admins" | Select-Object
    Name, SamAccountName
PS> $Stichtag = (Get-Date).AddDays(-7)
PS> Get-ADUser -Filter {whenChanged -gt $Stichtag} -Properties
    whenChanged |
    Select-Object SamAccountName, whenChanged
```

Erklärung: Die erste Abfrage zeigt die aktuellen Mitglieder der privilegierten Gruppe. Die zweite listet Konten, die in den letzten sieben Tagen geändert wurden. `whenChanged` ist der Zeitpunkt der letzten Änderung. **Erwartetes Ergebnis:** Eine Liste der Mitglieder und der geänderten Konten. Konten, die du nicht zuordnen kannst, sind zu prüfen. **Überprüfung:** Notiere Umfang und Zeit für den Vorfall.

Übung B: Protokolle sichern

Lernziel: das Sicherheitsprotokoll vor weiteren Eingriffen sichern und den Hashwert festhalten. **Voraussetzungen:** Administratorkonto auf DC01, Zielverzeichnis C:\IR.

Befehle zu Übung B

```
PS> New-Item -ItemType Directory -Path C:\IR -Force | Out-Null
PS> wevtutil epl Security "C:\IR\security_dc01.evtx"
PS> Get-FileHash -Path "C:\IR\security_dc01.evtx" -Algorithm
    SHA256
```

Erklärung: `wevtutil epl` exportiert das Protokoll in eine Datei, ohne es zu leeren. Der Hashwert belegt die Unversehrtheit der Kopie. Der Export wird im Protokoll mit Zeit und Verantwortlichen vermerkt. **Erwartetes Ergebnis:** Eine Datei security_dc01.evtx mit dem Hashwert. **Überprüfung:** Der Hashwert wird später erneut berechnet und muss übereinstimmen. **Fehleranalyse:** Der Export schlägt fehl? Prüfe die Berechtigung und den Speicherplatz.

Übung C: Konto vorläufig sperren

Lernziel: ein betroffenes Konto deaktivieren und die Wirkung prüfen.

Befehle zu Übung C

```
PS> Disable-ADAccount -Identity testuser
PS> Get-ADUser -Identity testuser -Properties Enabled |
    Select-Object SamAccountName, Enabled
```

Erklärung: `Disable-ADAccount` deaktiviert das Konto. Die Abfrage prüft den Zustand. Die Sperre ist eine Eindämmung und keine Lösung, die Ursache wird danach untersucht. **Erwartetes Ergebnis:** Enabled ist False. **Überprüfung:** Vermerke die Sperre mit Zeitpunkt und Begründung.

Übung D: krbtgt-Konto prüfen

Lernziel: das Alter des krbtgt-Kennworts bestimmen.

Befehle zu Übung D

```
PS> Get-ADUser -Identity krbtgt -Properties PasswordLastSet |
    Select-Object SamAccountName, PasswordLastSet
```

Erklärung: `PasswordLastSet` zeigt den Zeitpunkt der letzten Kennwortänderung. Ein altes Datum bedeutet, dass der Schlüssel lange unverändert ist. **Erwartetes Ergebnis:** Ein Datum. In der Testdomäne ist es das Datum der Einrichtung. **Überprüfung:** Vergleiche das Datum mit dem

Plan der Wiederherstellung.

Übung E: Konto wieder aktivieren und den Vorfall abschließen

Lernziel: die Eindämmung zurücknehmen, nachdem die Ursache geklärt ist, und den Vorfall dokumentieren.

Befehle zu Übung E

```
PS> Remove-ADGroupMember -Identity "Domain Admins" -Members
    testuser -Confirm:$false
PS> Enable-ADAccount -Identity testuser
PS> Get-ADGroupMember -Identity "Domain Admins" | Select-Object
    SamAccountName
```

Erklärung: Der Testbenutzer wird aus der privilegierten Gruppe entfernt, das Konto wieder aktiviert. Die Abfrage bestätigt, dass nur die erwarteten Konten in der Gruppe sind. **Erwartetes Ergebnis:** testuser ist nicht mehr in Domain Admins, das Konto ist aktiv. **Überprüfung:** Der Vorfallsbericht enthält Beginn, Eindämmung, Ursache und Abschluss. **Sicherheitsbetrachtung:** Der krbtgt-Kennwortwechsel wird in dieser Übung nicht durchgeführt. In der Testdomäne ist er ein eigenes Projekt, das nur nach dem Plan der Herstellerdokumentation erfolgt.

Typische Fehler

- Die Eindämmung beginnt, bevor die Protokolle gesichert sind
- Ein einzelnes Kennwort wird gewechselt, und der Vorfall gilt als erledigt
- Nur die Konten werden geprüft, nicht die Systeme, Dienste und Replikationsrechte
- Der krbtgt-Wechsel wird ohne Abstand oder außerhalb der Dokumentation durchgeführt
- Der Vorfall wird ohne Lessons Learned abgeschlossen

Zusammenfassung

- Ein Vorfall ist klein oder groß. Ob es sich um eine Domänenkompromittierung handelt, bestimmt die Reaktion.
- Protokolle werden vor den Eingriffen gesichert, Eindämmung ist dokumentiert.
- Die Wiederherstellung umfasst alle Mechanismen, mit denen der Angreifer sich einrichten kann, nicht nur ein Kennwort.
- Der krbtgt-Wechsel folgt der Herstellerdokumentation und braucht einen Plan.

Kontrollfragen

1. Was unterscheidet einen kleinen Vorfall von einer Domänenkompromittierung? (leicht)
2. Warum werden die Protokolle vor der Eindämmung gesichert? (leicht)
3. Warum reicht ein Wechsel des Administratorkennworts für eine vertrauenswürdige Wiederherstellung nicht aus? (mittel)
4. Warum wird der krbtgt-Schlüssel zweimal mit Abstand gewechselt? (mittel)
5. Nach einer Bereinigung zeigt die Überwachung eine Gruppenaufnahme, die im Plan nicht vorkommt. Welche Schritte folgen, und was ändert das für die Wiederherstellung? (schwer)

Lösungshinweise: 1. Ob der Angreifer die höchsten Rechte oder Anmeldedaten aller Konten erlangt hat. 2. Eindämmungsmaßnahmen und Änderungen können Spuren überschreiben oder löschen. 3. Der Angreifer kann andere Konten, Gruppen, Richtlinien, Delegationen oder Replikationsrechte für sich eingerichtet haben, die ein Kennwortwechsel nicht erfasst. 4. Tickets, die mit dem alten Schlüssel ausgestellt wurden, müssen ablaufen, sonst bleiben sie gültig. Der Abstand und die Reihenfolge stehen in der Dokumentation. 5. Der Vorfall wird neu bewertet, die Aufnahme wird untersucht, und die Wiederherstellung muss diesen Weg ebenfalls schließen. Die Bereinigung ist erst abgeschlossen, wenn auch dieser Mechanismus geprüft und beseitigt ist.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] einen kleinen Vorfall von einer Domänenkompromittierung unterscheidest,
- [ ] Protokolle vor der Eindämmung sicherst und ihre Unversehrtheit belegst,
- [ ] erklärst, warum ein einzelnes Kennwort nicht ausreicht,
- [ ] den Ablauf der Reaktion in neun Phasen beschreiben kannst.

Kapitel 15: Praxisprojekt – Eine Windows-Domäne prüfen, angreifen lassen und absichern

Lernziele

- Du führst eine zusammenhängende Untersuchung einer Testdomäne durch, von der Ausgangsanalyse bis zum Abschlussbericht.
- Du simulierst kontrolliert zwei Angriffsfälle und beobachtest ihre Spuren im Protokoll.
- Du misst die Wirkung der Härtung mit einem Vorher-Nachher-Vergleich und benennst die Restrisiken.

WARNUNG – Sicherheitsrisiko

Alle Simulationen finden ausschließlich in der isolierten Testdomäne nova.int statt. Keine der Techniken wird gegen produktive Systeme oder fremde Domänen eingesetzt. Bewahre die Ausgaben der Baseline und der Simulationen so auf, dass sie nur im Projekt verwendet werden.

Ausgangslage und Voraussetzungen

Das Projekt setzt die Testdomäne voraus, die in Band 2 der Windows-Security-Reihe aufgebaut wurde: den Domänencontroller DC01 (192.168.56.10), den Server SRV01 (192.168.56.20) und den Arbeitsplatz CLIENT01 (192.168.56.50), alle in der Domäne nova.int. Hinzu kommen die Konten und Gruppen aus Kapitel 2 und 5: max.mustermann, svc_backup, die Gruppen IT-Admins und Helpdesk sowie die Organisationseinheiten Benutzer, Computer, Server und Administration.

Lege vor Beginn für alle drei Systeme einen Snapshot an. Für DC01 gilt der Hinweis aus Kapitel 14: Ein Snapshot eines Domänencontrollers kann die Replikation stören. Sichere die Domäne deshalb über die Sicherung des Systemzustands oder verzichte auf den Snapshot des Controllers und arbeite mit den Sicherungsdateien aus den Übungen.

Diagramm 15.1: Ablauf des Projekts

```
Phase 1  Auftrag und Ausgangsanalyse
Phase 2  Baseline sichern (Kapitel 2, 12)
Phase 3  Angriffsfläche analysieren (Kapitel 4, 5, 8, 9)
Phase 4  Kontrollierte Simulation (Kapitel 5, 6)
Phase 5  Erkennung aktivieren und prüfen (Kapitel 13)
Phase 6  Härtung umsetzen (Kapitel 5, 6, 7, 11, 12)
Phase 7  Vorher-Nachher-Vergleich und Bericht (Kapitel 12, 14, Anhang)
```

Aufgabe 1: Auftrag formulieren und Domäne prüfen

Lernziel: einen begrenzten Auftrag formulieren und die Domäne in ihrem Bestand bestätigen. **Voraussetzungen:** Administratorkonto auf DC01, Modul ActiveDirectory. **Aufgabenstellung:** Formuliere den Auftrag nach dem Muster aus Kapitel 2: Domäne nova.int, Zeitraum, betroffene Systeme, Entscheidungsweg für Änderungen. Bestätige danach den Bestand.

Befehle zu Aufgabe 1

```
PS> Get-ADDomain | Select-Object Name, DNSRoot, PDCEmulator,
    DomainMode
PS> Get-ADDomainController -Filter * | Select-Object Name,
    IPv4Address, Site
PS> Get-ADOrganizationalUnit -Filter * | Select-Object Name
```

Erwartetes Ergebnis: Die Domäne heißt nova.int, DC01 ist der einzige Domänencontroller, die OUs Benutzer, Computer, Server und Administration sind vorhanden. **Typischer Fehler:** Der Auftrag ist zu weit gefasst. Begrenze ihn auf die Domäne und die genannten Systeme.

Aufgabe 2: Baseline sichern

Lernziel: den Ausgangszustand der Sicherheitseinstellungen als Datei festhalten, damit der Vorher-Nachher-Vergleich möglich ist.
Voraussetzungen: Aufgabe 1 abgeschlossen. **Aufgabenstellung:** Erfasse die wichtigsten Einstellungen in einem Verzeichnis C:\Projekt und exportiere sie.

Befehle zu Aufgabe 2

```
PS> New-Item -ItemType Directory -Path C:\Projekt -Force |
    Out-Null
PS> Get-ADDefaultDomainPasswordPolicy | Select-Object
    MinPasswordLength, LockoutThreshold |
    Export-Csv C:\Projekt\baseline_kennwort.csv -NoTypeInformation
PS> Get-ADUser -Filter {ServicePrincipalName -like "*"}
    -Properties ServicePrincipalName, PasswordLastSet |
    Select-Object SamAccountName, PasswordLastSet,
        ServicePrincipalName |
    Export-Csv C:\Projekt\baseline_dienstkonten.csv
        -NoTypeInformation
PS> Get-ADComputer -Filter {TrustedForDelegation -eq $true} |
    Select-Object Name |
    Export-Csv C:\Projekt\baseline_delegation.csv
        -NoTypeInformation
PS> Get-ItemProperty -Path
    "HKLM:\SYSTEM\CurrentControlSet\Services\NTDS\Parameters"
    -Name LDAPServerIntegrity |
    Select-Object LDAPServerIntegrity | Export-Csv
        C:\Projekt\baseline_ldap.csv -NoTypeInformation
PS> Get-ItemProperty -Path
    "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name
    LmCompatibilityLevel |
    Select-Object LmCompatibilityLevel | Export-Csv
        C:\Projekt\baseline_ntlm.csv -NoTypeInformation
```

Erklärung: `Export-Csv` schreibt die Ausgabe als Tabelle in eine Datei. `-NoTypeInformation` verhindert die zusätzliche Typzeile. Die Dateien bilden den Vorher-Zustand. **Erwartetes Ergebnis:** Fünf CSV-Dateien im Verzeichnis C:\Projekt. **Überprüfung:** Der Hashwert jeder Datei wird notiert (Kapitel 5). **Fehleranalyse:** Eine Datei ist leer? Die Abfrage liefert möglicherweise nichts, weil das Attribut nicht gesetzt ist. Das ist für die Baseline ein gültiger Zustand, notiere ihn.

Aufgabe 3: Angriffsfläche analysieren

Lernziel: Angriffspfade mit den Werkzeugen aus Kapitel 4, 8 und 9 bestimmen. **Voraussetzungen:** Aufgabe 2 abgeschlossen, das Analysesystem ist in der Testdomäne isoliert. **Aufgabenstellung:** Prüfe die verschachtelten Gruppen in Domain Admins, die Rechte auf der OU Server und die Angriffspfade mit BloodHound.

Befehle zu Aufgabe 3

```
PS> Get-ADGroupMember -Identity "Domain Admins" | Where-Object {
    $_.objectClass -eq 'group' }
PS> (Get-Acl "AD:\OU=Server,DC=nova,DC=int").Access |
    Where-Object { $_.ActiveDirectoryRights -match
        'GenericAll|WriteDacl|WriteOwner' }
PS> .\SharpHound.exe -c All
```

Erklärung: Die erste Abfrage findet verschachtelte Gruppen in der Gruppe der Domänenadministratoren. Die zweite zeigt kritische Rechte auf der OU Server. Die dritte sammelt die Daten für BloodHound, wie in Kapitel 9 beschrieben. Die Ergebnisse werden importiert und der Pfad zu Domain Admins kantenweise geprüft. **Erwartetes Ergebnis:** Die Liste der Befunde ist kurz, jede Abweichung ist begründet. Ein gefundener Pfad ist die Grundlage für Aufgabe 4 und 6. **Überprüfung:** Notiere je Befund Konto, Recht, Ziel und Zeitpunkt.

Aufgabe 4: Kontrollierte Simulation

Lernziel: zwei Angriffsfälle in der Testdomäne nachvollziehen und ihre Spuren auswerten. **Voraussetzungen:** Der SPN aus Kapitel 5, Übung C, ist gesetzt. Das Konto testpreauth aus Kapitel 6, Übung B existiert. Für dieses Konto ist die Kerberos-Vorauthentifizierung deaktiviert, das Attribut DoesNotRequirePreAuth steht also auf True. Ob das weiterhin gilt, prüfst du vor der Simulation. Hast du Kapitel 5, Übung E durchgeführt, setze den Verschlüsselungstyp des Dienstkontos zuerst zurück mit `Set-ADUser -Identity svc_backup -Clear 'msDS-SupportedEncryptionTypes'`, damit die Simulation den Ausgangszustand trifft.

Fall A: Kerberoasting. Das Dienstkonto svc_backup hat einen SPN, und sein Verschlüsselungstyp ist noch nicht auf AES erzwungen. Ein Testbenutzer fordert das Dienstticket an, wie es eine Anwendung täte.

Befehle zu Fall A

```
PS> Get-ADUser -Identity svc_backup -Properties
    msDS-SupportedEncryptionTypes | Select-Object SamAccountName,
    msDS-SupportedEncryptionTypes
```

```
PS> klist purge
PS> klist get HTTP/backup.nova.int
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4769}
    -MaxEvents 5 | Format-List TimeCreated, Message
```

Erwartetes Ergebnis: Das Ereignis 4769 zeigt den Dienstnamen und den Verschlüsselungstyp. Der Befund ist RC4 oder AES, je nachdem, wie das Konto konfiguriert ist.

Fall B: AS-REP-Konfiguration. Das Konto testpreauth ist als betroffen markiert. Die Simulation beschränkt sich auf die Konfigurationsprüfung. Die Anfrage ohne Vorauthentifizierung ist mit Bordmitteln nicht erzeugbar, wie Kapitel 6 erklärt.

Befehle zu Fall B

```
PS> Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true}
    -Properties DoesNotRequirePreAuth | Select-Object
    SamAccountName, Enabled
```

Erwartetes Ergebnis: testpreauth erscheint in der Liste.

Typischer Fehler: Die Simulation wird als Angriff auf eine produktive Domäne verstanden. Sie bleibt auf die Testdomäne begrenzt, der Befund dokumentiert die Konfiguration und die Spur, nicht den Erfolg eines Zugriffs.

Aufgabe 5: Erkennung aktivieren und prüfen

Lernziel: die Überwachung so einstellen, dass die Simulation aus Aufgabe 4 sichtbar wird. **Voraussetzungen:** Administratorkonto auf DC01. Sysmon ist auf CLIENT01 installiert (Kapitel 13, Übung E). **Aufgabenstellung:** Prüfe und aktiviere die Kategorien für Kerberos-Dienstticketvorgänge und Kontoverwaltung, prüfe die Gruppenereignisse und zähle die RC4-Anforderungen.

Befehle zu Aufgabe 5

```
PS> auditpol /get /category:*
PS> auditpol /set /subcategory:"Kerberos-Dienstticketvorgänge"
    /success:enable /failure:enable
PS> auditpol /set /subcategory:"Benutzerkontoverwaltung"
```

```
    /success:enable /failure:enable
PS> auditpol /set /subcategory:"Sicherheitsgruppenverwaltung"
    /success:enable /failure:enable
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4769}
    -MaxEvents 200 |
    Where-Object { $_.Message -match 'Ticket Encryption
        Type:\s+0x17' } | Measure-Object
```

Erklärung: `auditpol /set` aktiviert eine Unterkategorie. Der Name muss genau der Bezeichnung in deiner Systemsprache entsprechen; prüfe ihn mit `auditpol /list /subcategory:*` vor dem Befehl. Die dritte Zeile zählt RC4-Anforderungen, wie in Kapitel 13, Übung D. **Erwartetes Ergebnis:** Die Kategorie ist auf Erfolg und Fehler gesetzt. Die Anzahl der RC4-Anforderungen aus Aufgabe 4 ist größer als null, wenn das Konto nicht auf AES erzwungen ist. **Überprüfung:** Die Simulation aus Aufgabe 4 ist im Protokoll mit Zeit und Konto nachweisbar. **Fehleranalyse:** Die Kategorie ist nicht zu setzen? Die Richtlinie kann über eine Gruppenrichtlinie gesetzt sein und den lokalen Befehl überschreiben. Prüfe die wirksame Richtlinie.

Aufgabe 6: Härtung umsetzen

Lernziel: die Befunde aus den Aufgaben 3 bis 5 mit den Maßnahmen aus den Kapiteln 5, 6, 7, 11 und 12 beseitigen. **Voraussetzungen:** Die Befunde sind dokumentiert. **Aufgabenstellung:** Setze die folgenden Maßnahmen um, jede mit Vorher-Nachher-Prüfung. Die Reihenfolge ist fest: zuerst die Konten, dann die Delegation, dann die Richtlinien.

Befehle zu Aufgabe 6

```
PS> Set-ADUser -Identity svc_backup -Replace
    @{'msDS-SupportedEncryptionTypes'=24}
PS> Set-ADAccountControl -Identity svc_backup -AccountNotDelegated
    $true
PS> Set-ADAccountControl -Identity testpreauth
    -DoesNotRequirePreAuth $false
PS> Add-ADGroupMember -Identity "Protected Users" -Members
    testschutz
PS> Set-ADAccountControl -Identity SRV01 -TrustedForDelegation
    $false
PS> New-ADUser -Name adm.max -SamAccountName adm.max -Enabled
    $true -AccountPassword (Read-Host -AsSecureString "Kennwort
```

```
    für adm.max")
```

Erklärung: Die Befehle erzwingen AES für das Dienstkonto, markieren es als nicht delegierbar, aktivieren die Vorauthentifizierung für testpreauth, nehmen ein Testkonto in Protected Users auf, entfernen die unbeschränkte Delegation von SRV01 und legen das Verwaltungskonto adm.max für die Trennung nach Kapitel 12 an. Die Wirkung jeder Maßnahme prüfst du mit der entsprechenden Abfrage aus den Kapiteln 5, 6, 11 und 12. **Erwartetes Ergebnis:** Alle Abfragen zeigen den Zielzustand. Die Anwendung auf SRV01, die eine Delegation brauchte, ist als Befund dokumentiert, wenn sie ausfällt. **Typischer Fehler:** Die Protected-Users-Gruppe wird auf Administratorkonten angewendet, ohne dass die Dienste darauf geprüft sind. Die Aufnahme bleibt bei Testkonten. **Sicherheitsbetrachtung:** Die Änderungen an Testobjekten sind bewusst. Die Gruppenrichtlinie für die NTLM-Stufe (LmCompatibilityLevel 5) und die LDAP-Signierung werden über eine GPO gesetzt, nicht über einen einzelnen Befehl. Prüfe nur, ob sie wirksam sind (Kapitel 12, Übung C und D).

Aufgabe 7: Vorher-Nachher-Vergleich und Bericht

Lernziel: die Wirkung der Maßnahmen belegen und den Abschlussbericht schreiben. **Voraussetzungen:** Baseline aus Aufgabe 2 und Ergebnisse aus Aufgabe 6. **Aufgabenstellung:** Exportiere den aktuellen Zustand unter demselben Namensschema, vergleiche ihn mit der Baseline und schreibe den Bericht.

Befehle zu Aufgabe 7

```
PS> Get-ADDefaultDomainPasswordPolicy | Select-Object
    MinPasswordLength, LockoutThreshold |
    Export-Csv C:\Projekt\nachher_kennwort.csv -NoTypeInformation
PS> Get-ADUser -Filter {ServicePrincipalName -like "*"}
    -Properties ServicePrincipalName, PasswordLastSet |
    Select-Object SamAccountName, PasswordLastSet,
        ServicePrincipalName |
    Export-Csv C:\Projekt\nachher_dienstkonten.csv
        -NoTypeInformation
PS> Compare-Object (Import-Csv
    C:\Projekt\baseline_dienstkonten.csv) (Import-Csv
    C:\Projekt\nachher_dienstkonten.csv) -Property SamAccountName
```

Erklärung: `Compare-Object` zeigt Unterschiede zwischen den beiden Dateien. Der Vergleich gilt nur für die Eigenschaften, die exportiert wurden, und nicht für Einstellungen, die außerhalb dieser Dateien liegen. **Erwartetes Ergebnis:** Die Unterschiede entsprechen den Maßnahmen aus Aufgabe 6. Ein Unterschied, den du nicht erklären kannst, ist ein offener Punkt. **Bericht:** Gliedere den Bericht nach dem Muster im Anhang: Auftrag, Ausgangszustand, Vorgehen, Feststellungen, Interpretation, nicht Nachweisbares, Grenzen, Anlagen. Für jede Maßnahme nenne den Vorher-Zustand, den Nachher-Zustand und die Restrisiken.

Restrisiken, die im Bericht stehen müssen

Der Bericht nennt die Punkte, die das Projekt nicht schließt. Dazu gehören die Abhängigkeit von Altsystemen, die AES nicht unterstützen, die Frage, ob die Sysmon-Konfiguration vollständig ist, und die Tatsache, dass die Simulation in einer kleinen Domäne nicht alle Fälle abdeckt. Ein Projekt, das keine Restrisiken nennt, hat sie vermutlich übersehen.

Qualitätsprüfung des Projekts

- Jede Aussage über den Zustand stützt sich auf eine Ausgabe oder eine Datei.
- Jede Simulation ist auf die Testdomäne begrenzt und dokumentiert.
- Der Vorher-Nachher-Vergleich zeigt die Wirkung, nicht nur den Zielzustand.
- Die Restrisiken stehen im Bericht.
- Keine Aussage geht über das hinaus, was die Ausgaben belegen.

> **Zusammenfassung**
>
> - Das Projekt verbindet Analyse, kontrollierte Simulation, Erkennung und Härtung in einer Testdomäne.
> - Die Baseline macht den Vorher-Zustand belegbar, der Vergleich zeigt die Wirkung.
> - Jede Simulation wird im Protokoll sichtbar gemacht, bevor sie als Befund gilt.
> - Restrisiken gehören in den Bericht, ein Projekt ohne sie ist unvollständig.

Kontrollfragen

1. Warum wird die Baseline vor der Simulation gesichert? (leicht)
2. Welche Ereignis-ID zeigt die Anforderung eines Dienstickets? (leicht)
3. Warum wird der Fall B in diesem Projekt nur als Konfigurationsprüfung durchgeführt? (mittel)
4. Die Härtung entfernt die unbeschränkte Delegation von SRV01, und eine Anwendung fällt aus. Wie gehst du vor? (mittel)
5. Der Vergleich zeigt eine Abweichung, die in keiner Maßnahme vorkommt. Welche Schritte folgen, und welche Aussage darfst du im Bericht treffen? (schwer)

Lösungshinweise: 1. Ohne Baseline lässt sich die Wirkung der Maßnahmen nicht belegen. 2. Ereignis 4769. 3. Die Anfrage ohne Vorauthentifizierung lässt sich mit den Bordmitteln nicht erzeugen, und das Projekt soll nur kontrolliert arbeiten. Die Konfiguration ist der belegbare Befund. 4. Die Anwendung wird untersucht und auf beschränkte Delegation mit den nötigen Zielen umgestellt. Bis dahin wird die Ausnahme dokumentiert und zeitlich begrenzt. Die Härtung bleibt bestehen. 5. Die Abweichung wird untersucht, bevor eine Aussage getroffen wird. Im Bericht steht nur, dass eine Abweichung festgestellt wurde, mit Zeit und Quelle, und dass ihre Ursache offen ist, bis sie geklärt ist.

Lernzielkontrolle

Du hast dieses Projekt abgeschlossen, wenn du:

- [ ] die Testdomäne ausgewertet und eine Baseline gesichert hast,
- [ ] zwei Simulationen kontrolliert durchgeführt und im Protokoll belegt hast,
- [ ] die Erkennung aktiviert und ihre Wirkung geprüft hast,
- [ ] einen Vorher-Nachher-Vergleich mit Restrisiken im Bericht hast.

Anhang

Active-Directory-Spickzettel

Spickzettel: Domäne und Verzeichnis

```
PS> Get-ADDomain | Select-Object Name, DNSRoot, PDCEmulator,
    DomainMode
PS> Get-ADForest | Select-Object Name, ForestMode, SchemaMaster,
    DomainNamingMaster
PS> Get-ADDomainController -Filter * | Select-Object Name,
    IPv4Address, Site
PS> nltest /dclist:nova.int
PS> repadmin /showrepl
PS> whoami /user
```

Spickzettel: Benutzer, Gruppen und Rechte

```
PS> Get-ADUser -Filter * -Properties Enabled | Select-Object
    SamAccountName, Enabled
PS> Get-ADGroupMember -Identity "Domain Admins" -Recursive
PS> Get-ADPrincipalGroupMembership -Identity max.mustermann
PS> (Get-Acl "AD:\OU=Server,DC=nova,DC=int").Access |
    Select-Object IdentityReference, ActiveDirectoryRights,
    IsInherited
PS> (Get-Acl
    "AD:\OU=Test,DC=nova,DC=int").GetSecurityDescriptorSddlForm('A
    ll') | Out-File .\acl_test_backup.sddl   # vor jeder
    ACL-Änderung
```

Spickzettel: Kerberos, Verschlüsselung und Konfiguration

```
PS> setspn -L svc_backup
PS> setspn -S HTTP/backup.nova.int nova\svc_backup
PS> Get-ADUser -Filter {ServicePrincipalName -like "*"}
    -Properties ServicePrincipalName
PS> Get-ADUser -Identity svc_backup -Properties
    msDS-SupportedEncryptionTypes
PS> Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true}
    -Properties DoesNotRequirePreAuth
PS> Get-ADComputer -Filter {TrustedForDelegation -eq $true}
PS> Get-ADTrust -Filter *
```

```
PS> klist purge
PS> klist get HTTP/backup.nova.int
```

Spickzettel: LDAP-Abfragen und Attribute

```
PS> Get-ADObject -LDAPFilter "(msDS-AllowedToDelegateTo=*)"
    -Properties msDS-AllowedToDelegateTo
PS> Get-ADComputer -Identity SRV01 -Properties
    msDS-AllowedToActOnBehalfOfOtherIdentity
PS> Get-ItemProperty -Path
    "HKLM:\SYSTEM\CurrentControlSet\Services\NTDS\Parameters"
    -Name LDAPServerIntegrity
```

Spickzettel: Änderungen an Konten (nur in der Testdomäne)

```
PS> Set-ADUser -Identity svc_backup -Replace
    @{'msDS-SupportedEncryptionTypes'=24}
PS> Set-ADAccountControl -Identity svc_backup -AccountNotDelegated
    $true
PS> Set-ADAccountControl -Identity testpreauth
    -DoesNotRequirePreAuth $false
PS> Add-ADGroupMember -Identity "Protected Users" -Members
    testschutz
PS> Disable-ADAccount -Identity testuser
PS> Enable-ADAccount -Identity testuser
```

Spickzettel: Ereignisse und Überwachung

```
PS> auditpol /get /category:*
PS> auditpol /list /subcategory:*
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4769}
    -MaxEvents 20
PS> Get-WinEvent -FilterHashtable @{LogName='Security';
    Id=4720,4728,4732,4756} -MaxEvents 20
PS> wevtutil epl Security "C:\IR\security_dc01.evtx"
PS> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational"
    -MaxEvents 10
```

Windows-Security-Ereignisse im Überblick

Kennung	Bedeutung	Kapitel
1102	Sicherheitsprotokoll gelöscht	13
4104	PowerShell-Skriptblock protokolliert	13
4624	erfolgreiche Anmeldung (Logontyp, Authentifizierungspaket)	7, 13
4625	fehlgeschlagene Anmeldung	13
4662	Vorgang an einem Verzeichnisobjekt	8, 13
4670	Berechtigungen eines Objekts geändert	8
4720	Konto angelegt	13
4722	Konto aktiviert	13
4726	Konto gelöscht	13
4728, 4732, 4756	Mitglied zu globaler, lokaler oder universeller Gruppe hinzugefügt	13
4738	Kontoeigenschaften geändert	13
4740	Konto gesperrt	13
4768	Ticket-Granting-Ticket angefordert (Pre-Authentication Type)	6, 13
4769	Dienstticket angefordert (Verschlüsselungstyp)	5, 13

Kennung	Bedeutung	Kapitel
4776	NTLM-Prüfung der Anmeldedaten	7, 13
5136	Verzeichnisobjekt geändert	8, 13

Verschlüsselungstypen und Bitwerte

Wert	Bedeutung	Kapitel
0x4	RC4 (in msDS-SupportedEncryptionTypes)	5
0x8	AES128	5
0x10	AES256	5
0x11	AES128 im Ticket	5
0x12	AES256 im Ticket	5
0x17	RC4 im Ticket	5, 13
24	AES128 und AES256 zusammen, RC4 ausgeschlossen	5, 12

Sysmon-Übersicht

Kennung	Ereignis	Nutzen für die Erkennung
1	Prozessstart	Befehle und Programme auf Endgeräten
3	Netzwerkverbindung	Verbindungen von Prozessen

Kennung	Ereignis	Nutzen für die Erkennung
11	Datei erstellt	Ablage verdächtiger Dateien
13	Registrywert gesetzt	Persistenz und Konfigurationsänderungen

Die Konfigurationsdatei bestimmt, was erfasst wird. Sie muss aus einer geprüften Quelle stammen und zur Umgebung passen.

Hardening-Checkliste

- Verwaltungskonten getrennt von den täglichen Konten, nur auf Systemen der eigenen Ebene anmeldbar (Kapitel 12)
- Domänenadministratoren nicht auf Arbeitsplätzen angemeldet (Kapitel 7, 12)
- Keine Konten mit deaktivierter Vorauthentifizierung ohne dokumentierte Ausnahme (Kapitel 6)
- Dienstkonten mit gMSA oder langem, zufälligem Kennwort, AES erzwungen, keine Mitgliedschaft in Domain Admins (Kapitel 5)
- Keine unbeschränkte Delegation außerhalb der Domänencontroller (Kapitel 11)
- Sensible Konten als nicht delegierbar markiert (Kapitel 11)
- Protected Users für sensible Konten, nach Prüfung der Dienste (Kapitel 7)
- Windows LAPS für lokale Administratorkennwörter (Kapitel 12)
- LDAP-Serversignierung verlangt, Kanalschutz geprüft (Kapitel 12)
- NTLM-Stufe und SMB-Signierung gehärtet, NTLM-Nutzung dokumentiert (Kapitel 12)
- Erweiterte Überwachung für Konto-, Gruppen-, Kerberos- und Verzeichnisdienstvorgänge aktiv (Kapitel 13)
- Sysmon mit geprüfter Konfiguration auf Endgeräten und Servern (Kapitel 13)

• Berechtigungen auf kritischen OUs regelmäßig geprüft, Änderungen begründet (Kapitel 8)

GPO-Sicherheitscheckliste

• Gruppenrichtlinien auf Domänencontrollern und Servern nur von berechtigten Konten änderbar (Kapitel 12)

• Verknüpfungen geprüft, Vererbung bewusst eingesetzt (Band 2, Kapitel 4)

• Änderungen an kritischen GPOs protokolliert (Kapitel 13)

• Einstellungen für LDAP-Signierung, NTLM-Stufe und Überwachung als GPO gesetzt, nicht nur lokal (Kapitel 12, 13)

• Keine Skripte mit Anmeldedaten in GPOs oder Dateifreigaben (Kapitel 7)

• Regelmäßiger Vergleich der wirksamen Richtlinien mit der Sollvorgabe

Incident-Response-Checkliste

• Verdacht eröffnet mit Zeit, Quelle und verantwortlicher Person (Kapitel 14)

• Erste Bewertung: betroffene Konten, Rechte, Zeitraum, Hinweise auf höhere Rechte (Kapitel 14)

• Protokolle vor den Eingriffen gesichert, Hashwert festgehalten (Kapitel 14, Übung B)

• Snapshots von Domänencontrollern nur nach Herstellervorgabe (Kapitel 14)

• Eindämmung dokumentiert: Konten, Verbindungen, Netzsegmente (Kapitel 14)

• Privilegierte Gruppen, krbtgt und Änderungen an Domänencontrollern untersucht (Kapitel 14)

• Credential Rotation nach Plan, pro Konto dokumentiert (Kapitel 14)

• Wiederherstellung umfasst alle Mechanismen: Konten, Gruppen, Richtlinien, Delegationen, Replikationsrechte, Dienste, Schlüssel (Kapitel 14)

- krbtgt-Wechsel nach Herstellerdokumentation, mit Abstand und Reihenfolge (Kapitel 14)
- Verstärkte Überwachung nach dem Vorfall, Dauer festgelegt (Kapitel 14)
- Lessons Learned mit Ursache, Erkennung und Härtung (Kapitel 14)

Verzeichnis der PowerShell-Befehle

Befehl	Zweck	Kapitel
Get-ADDomain	Eigenschaften der Domäne	2
Get-ADForest	Eigenschaften der Gesamtstruktur	2
Get-ADDomainController	Domänencontroller und Standorte	2
Get-ADOrganizationalUnit	Organisationseinheiten	2, 15
Get-ADUser	Benutzerkonten und Attribute	2, 5, 6
Get-ADGroupMember	Gruppenmitglieder, rekursiv mit -Recursive	2, 4, 8
Get-ADGroup	Gruppen abfragen	4
Get-ADPrincipalGroupMembership	Gruppen eines Kontos	12
Get-ADComputer	Computerkonten und Attribute	11, 15
Get-ADObject	allgemeine Objektabfrage mit -LDAPFilter	11
Get-ADServiceAccount	gMSA-Konten	5

Befehl	Zweck	Kapitel
Get-ADDefaultDomainPasswordPolicy	Standard-Kennwortrichtlinie	6, 12
Get-ADFineGrainedPasswordPolicy	feinabgestimmte Richtlinien	12
Get-ADTrust	Vertrauensstellungen	11
Get-Acl	ACL eines Objekts über den Pfad AD:	8
Set-Acl	ACL schreiben (nach Sicherung)	8
Export-Clixml, Import-Clixml	Konfiguration (Attribute) sichern und wiederherstellen	11
GetSecurityDescriptorSddlForm, SetSecurityDescriptorSddlForm	ACL als SDDL-Text sichern und wiederherstellen	8
New-ADUser	Benutzerkonto anlegen	6, 12
Set-ADUser	Attribute setzen, mit -Replace oder -Clear	5, 12
Set-ADAccountControl	Kontoeinstellungen wie Delegation und Vorauthentifizierung	6, 11
Add-ADGroupMember, Remove-ADGroupMember	Gruppenmitgliedschaft ändern	7, 13
Disable-ADAccount, Enable-ADAccount	Konto sperren und freigeben	14
Remove-ADUser	Konto löschen	6
New-ADServiceAccount	gMSA anlegen	5

Befehl	Zweck	Kapitel
Get-WinEvent	Ereignisse aus Protokollen lesen	5, 6, 7, 13
Get-ItemProperty	Registrywerte lesen	12
Get-SmbServerConfiguration	SMB-Einstellungen des Servers	12
Get-CimInstance	Klassen wie Win32_DeviceGuard	7
Get-FileHash	Hashwert einer Datei	14
Compare-Object	Unterschiede zwischen Dateien	15
Export-Csv, Import-Csv	Tabellen in Dateien schreiben und lesen	15

Außerhalb von PowerShell werden `setspn`, `klist`, `whoami`, `nltest`, `repadmin`, `auditpol`, `wevtutil` und `sysmon` verwendet. Die Optionen stehen in den jeweiligen Kapiteln.

Muster eines Abschlussberichts

Der Bericht folgt dieser Gliederung. Jeder Abschnitt nennt, was hineingehört.

1. **Auftrag:** Wortlaut der Fragestellung, Domäne, Zeitraum, Entscheidungsweg für Änderungen.
2. **Ausgangszustand:** Baseline mit Dateinamen, Hashwerten und Zeitpunkt der Erhebung.
3. **Vorgehen:** Schritte in der Reihenfolge der Ausführung, mit Befehlen, Werkzeugen und Versionen.
4. **Feststellungen:** nur Beobachtungen, jede mit Quelle, Ereignis-ID oder Datei und Zeit in der Zeitzone angegeben.
5. **Interpretation:** Schlussfolgerungen, jede als solche gekennzeichnet und mit den Feststellungen verknüpft.
6. **Nicht nachweisbar:** Fragen, die die Quellen nicht beantworten.

7. **Maßnahmen:** je Maßnahme Vorher-Zustand, Nachher-Zustand und Verantwortliche.

8. **Restrisiken und Grenzen:** Lücken, Altsysteme, Abhängigkeiten, Abweichungen ohne Ursache.

9. **Anlagen:** Baseline-Dateien, Vergleichsdateien, Protokollauszüge, Hashnachweise.

Glossar

Access Control Entry (ACE): ein einzelner Eintrag in einer Zugriffssteuerungsliste mit Sicherheitsprinzipal, Recht und Art (Erlauben oder Verweigern), Kapitel 8.

Active Directory Domain Services (AD DS): der Verzeichnisdienst von Windows, der Identitäten und Berechtigungen zentral verwaltet, Kapitel 1.

AS-REP Roasting: Angriff auf Konten ohne Kerberos-Vorauthentifizierung, Kapitel 6.

Authentifizierungspaket: das Verfahren, mit dem eine Anmeldung geprüft wurde, zum Beispiel NTLM oder Kerberos, Kapitel 7.

BloodHound: Werkzeug, das Beziehungen einer Domäne als Graph darstellt und Angriffspfade sichtbar macht, Kapitel 9.

Credential Guard: Schutzfunktion, die Anmeldegeheimnisse in einer isolierten Umgebung hält, Kapitel 7.

Delegation: Erlaubnis, dass ein Dienst im Auftrag eines Benutzers auf andere Dienste zugreift, Kapitel 11.

DCSync: Anforderung von Replikationsdaten durch ein Konto, das nicht Domänencontroller ist, Kapitel 13.

Distinguished Name (DN): vollständiger Pfad eines Objekts im Verzeichnis, Kapitel 2.

DACL (Discretionary Access Control List): die Liste, die Zugriffe erlaubt oder verweigert, Kapitel 8.

FSMO-Rollen: fünf eindeutig vergebene Rollen für koordinierte Änderungen in der Gesamtstruktur und Domäne, Kapitel 2.

Global Catalog: teilweise Kopie des Verzeichnisses aller Domänen einer Gesamtstruktur, Kapitel 2.

gMSA (Group Managed Service Account): Dienstkonto, dessen Kennwort automatisch verwaltet und gewechselt wird, Kapitel 2, 5.

Gesamtstruktur (Forest): die höchste Verwaltungsebene mit gemeinsamem Schema, Kapitel 1, 2.

Golden Ticket und Silver Ticket: Tickets, die mit dem Schlüssel des Kontos krbtgt (Golden) oder eines Dienstkontos (Silver) erzeugt werden. Das Buch behandelt sie als Konzept und mit Gegenmaßnahmen, Kapitel 10, 14.

Kerberoasting: Angriff auf Dienstkonten über Dienstickets, die mit dem Kennwort des Dienstkontos verschlüsselt sind, Kapitel 5.

Kerberos: Standard-Authentifizierungsprotokoll der Domäne mit Tickets, Kapitel 1, 3.

krbtgt: Konto, dessen langfristiger Schlüssel der KDC zur Verschlüsselung der Ticket-Granting-Tickets verwendet, Kapitel 10, 14.

LAPS (Local Administrator Password Solution): Verwaltung der lokalen Administratorkennwörter, Kapitel 12.

LDAP: Protokoll für den Zugriff auf das Verzeichnis, Kapitel 1.

Least Privilege: Grundsatz, jedem Konto nur die nötigen Rechte zu geben, Kapitel 8, 12.

MITRE ATT&CK: Katalog von Angriffstechniken mit Kennungen, Kapitel 4.

NTLM: älteres Authentifizierungsverfahren mit Herausforderung und Antwort, Kapitel 3.

Organisationseinheit (OU): Container im Verzeichnis, Kapitel 2.

Pass-the-Hash: Anmeldung mit einem NTLM-Hash statt dem Kennwort, Kapitel 7.

Pass-the-Ticket: Wiederverwendung eines Kerberos-Tickets auf einem anderen System, Kapitel 7.

Persistenz: Mechanismen, mit denen ein Zugang über das ursprüngliche Ereignis hinaus erhalten bleibt, Kapitel 4, 10.

Protected Users: Schutzgruppe, die NTLM und schwache Kerberos-Verfahren für ihre Mitglieder ausschließt, Kapitel 7.

RBCD (Resource-Based Constrained Delegation): ressourcenbasierte Delegation, die das Zielsystem bestimmt, Kapitel 11.

RID (Relative Identifier): letzter Teil des SID, der das Objekt in der Domäne unterscheidet, Kapitel 2.

Session: Anmeldung eines Kontos an einem Computer, eine Momentaufnahme, Kapitel 9.

SID (Security Identifier): eindeutige Identität eines Kontos oder einer Gruppe, Kapitel 2.

SPN (Service Principal Name): Dienstname, dem ein Konto zugeordnet ist, Kapitel 5.

Tiering-Modell: Einteilung der Administration in Ebenen mit getrennter Anmeldung, Kapitel 7, 12.

Vorauthentifizierung: Kerberos-Prüfung, bei der der Client das Kennwort nachweist, bevor der Domänencontroller antwortet, Kapitel 6.

Quellenverzeichnis

Die folgenden Quellen bilden die Grundlage der Aussagen dieses Buches. Prüfe vor dem Einsatz die aktuelle Fassung, denn Versionen, Standardwerte und Ereignisbeschreibungen ändern sich.

Herstellerdokumentation Microsoft

- Microsoft Learn: Dokumentation zu Active Directory Domain Services, insbesondere zu Sicherheit, Kerberos, LDAP-Signierung und Sicherheitsereignissen.
- Microsoft Learn: Dokumentation zum ActiveDirectory-PowerShell-Modul, einschließlich der Cmdlets Get-ADUser, Set-ADAccountControl, New-ADServiceAccount und Get-ADDefaultDomainPasswordPolicy.
- Microsoft Learn: Dokumentation zu Windows LAPS, zu Protected Users, zu Credential Guard und zur erweiterten Überwachungsrichtlinie.
- Microsoft Learn: Dokumentation zu Sysmon, zu wevtutil und zu auditpol.

• Microsoft Defender for Identity und Microsoft Sentinel, jeweils die aktuelle Produktdokumentation.

Frameworks und Standards

• MITRE ATT&CK, Enterprise-Matrix, Kennungen T1087, T1069, T1558.003, T1558.004, T1550.002, T1550.003 und T1003.006.

• BSI IT-Grundschutz-Kompendium, Bausteine zu Active Directory und Windows-Server.

• NIST Special Publication 800-63B, Richtlinien für digitale Identitäten, zu Kennwörtern und Authentifizierung.

Werkzeugdokumentation

• BloodHound Community Edition und SharpHound, Dokumentation des Projekts.

• Impacket, Dokumentation des Projekts. Das Buch verwendet Impacket nicht in Übungen, erwähnt es aber als optionales Werkzeug im Umfeld der Projektbeschreibung.

Konkret geprüfte Herstellerdokumente (Prüfstand November 2026)

• KB5021131: How to manage the Kerberos protocol changes related to CVE-2022-37966, Microsoft Support: support.microsoft.com/en-US/servicing/os/windows/2022/10/kb5021131-how-to-manage-the-kerberos-protocol-changes-related-to-cve-2022-37966 (Standardauswahl für Sitzungsschlüssel).

• Detect and remediate RC4 usage in Kerberos, Microsoft Learn: learn.microsoft.com/en-us/windows-server/security/kerberos/detect-remediate-rc4-kerberos (Felder der Ereignisse 4768 und 4769, Verschlüsselungstypen, Hexwerte).

• klist, Microsoft Learn, Windows-Befehlsreferenz: learn.microsoft.com/windows-server/administration/windows-commands/klist (Option get).

• 2020, 2023 und 2024 LDAP channel binding and LDAP signing requirements for Windows (KB4520412), Microsoft Support: support.microsoft.com/en-us/help/4520412 (Registrywerte LDAPServerIntegrity und LdapEnforceChannelBinding).

- Overview of Server Message Block signing, Microsoft Learn: learn.microsoft.com/en-us/troubleshoot/windows-server/networking/overview-server-message-block-signing (Bedeutung von RequireSecuritySignature und EnableSecuritySignature bei SMB 2 und 3).

Die Zuordnung der Werte für die LDAP-Serversignierung ist zwischen den Quellen nicht vollständig übereinstimmend. Das Buch nennt nur die Werte, die die Support-Dokumentation belegt. Prüfe die Zuordnung für deine Version, bevor du sie in einem Bericht verwendest.

Dieses Buch nennt keine Fachbücher mit Titel und Jahr, deren Angaben ich nicht vollständig prüfen konnte.

Index

Die Verweise führen auf Kapitel.

ACL 8 · ACE 8 · Active Directory Domain Services 1 · AdminTo 9 · AES 5, 12 · Admin Rights 9 · adm.max 12, 15 · AS-REP Roasting 4, 6, 13 · Authentifizierung 3, 7 · BloodHound 9, 15 · Credential Guard 7 · Credential Rotation 14 · Delegation 11 · DCSync 4, 10, 13 · Distinguished Name 2 · DACL 8 · Domain Admins 2, 8, 9, 13, 14 · Enterprise Admins 2, 8 · Eindämmung 14 · FSMO 2 · gMSA 2, 5, 12 · Gesamtstruktur 1, 2 · Gruppenrichtlinien 1, 12 · Global Catalog 2 · GenericAll 8 · GenericWrite 8 · Golden Ticket 10 · Hardening 12 · IT-Admins 4, 8, 9 · Kerberoasting 4, 5, 13, 15 · Kerberos 1, 3, 5, 7 · krbtgt 10, 14 · klist 5, 15 · LAPS 12 · LDAP 1, 12 · Least Privilege 7, 12 · Lessons Learned 14 · LmCompatibilityLevel 12 · MITRE ATT&CK 4 · NTLM 1, 3, 7, 12 · Organisationseinheit 2 · OU 8, 15 · Pass-the-Hash 7 · Pass-the-Ticket 7 · Persistenz 4, 10 · Protected Users 7, 11 · Replikation 2, 10, 14 · RBCD 11 · RID 2 · Sysmon 13 · SID 2 · SPN 5, 11 · Session 9 · Tiering 7, 12 · Trust 11 · Vorauthentifizierung 6 · Windows LAPS 12 · WriteDACL 8 · WriteOwner 8 · Silver Ticket 10

ACTIVE DIRECTORY SECURITY

Vom Verzeichnisdienst bis zur wirksamen Absicherung der Domäne

Dieses Praxishandbuch erklärt Active Directory von der Architektur bis zur Absicherung: Kerberos, NTLM und Berechtigungen, typische Angriffspfade mit BloodHound, Delegation, Hardening, Monitoring und Incident Response. Jeder Angriff wird zusammen mit seiner Erkennung und seinen Gegenmaßnahmen behandelt.

DAS ERWARTET DICH

- Architektur, Domänen und Berechtigungsmodell verstehen und prüfen
- Kerberoasting, AS-REP Roasting und Angriffspfade mit Erkennung
- Delegation, Hardening und Tiering-Modell umsetzen
- Monitoring und Incident Response bei kompromittierter Domäne
- Praxisprojekt auf der Domäne nova.int

Für wen?

Administratoren, Analysten im Blue Team und Ethical Hacker, die Windows-Domänen verstehen, prüfen und schützen wollen.

Praxishandbuch · Autor: Eugen Becker · Ausgabe November 2026

Hinweis: Alle Übungen nur in eigenen oder ausdrücklich freigegebenen Testumgebungen durchführen. Befehle vor dem Einsatz anh